

TCP/IP Networking

TCP/IP Networking

Il modello ISO/OSI

Nasce dall'ISO nei primi anni '80, dalla necessità di garantire maggiore interoperabilità tra le differenti implementazioni di rete esistenti.

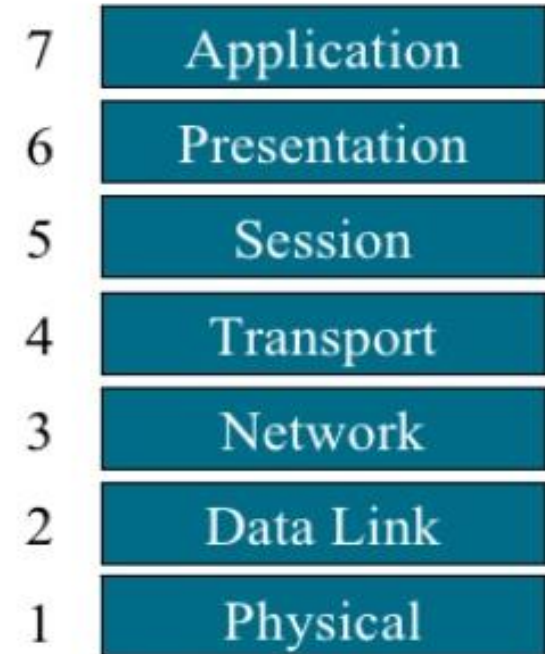
Lo scopo è permettere ad un programma applicativo che esegue su un computer che supporta un determinato insieme di standard di comunicare liberamente con un altro programma su un altro computer che supporta gli stessi standard, indipendentemente dal fornitore dell'hardware e/o del software di ciascun computer.

Ad esempio sono programmi di questo tipo:

- un processo che deve accedere ad un file system remoto
- un processo che fa da file-server centralizzato per un gruppo di client
- un processo su una stazione client che accede il server di posta

Il problema della comunicazione attraverso la rete viene scomposto in sette problemi più semplici, rappresentati dai sette livelli del modello. I primi due sono generalmente implementati con hardware e software, mentre gli altri cinque solo con software.

Ogni livello è responsabile solo di determinate funzioni, che sono ben delimitate e chiaramente distinte dalle funzioni dei livelli adiacenti.



TCP/IP Networking

I tre livelli superiori

Application

È il livello a contatto diretto con i programmi applicativi che richiedono la trasmissione di dati sulla rete. Determina la disponibilità e sincronizza le applicazioni comunicanti, stabilisce procedure comuni per error recovery e controllo d'integrità.

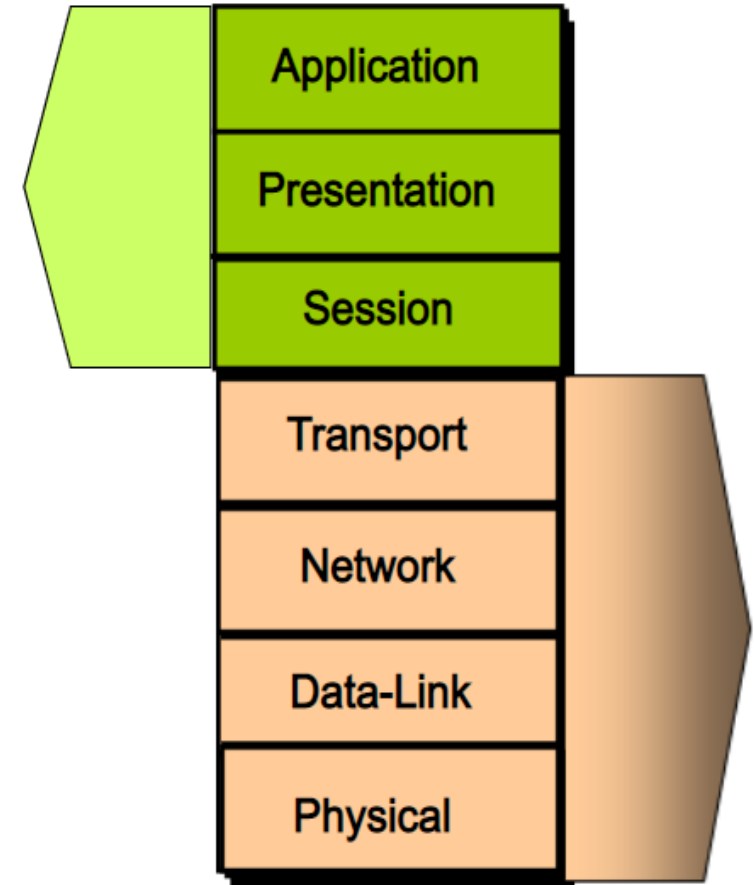
Presentation

assicura l'utilizzo della stessa rappresentazione dei dati tra applicazioni comunicanti. Fornisce routine standard di presentazione dei dati.

Session

si occupa di stabilire, mantenere e chiudere le sessioni tra entità a livello presentation. Sono protocolli a livello session:

NetBIOS	Network Basic Input/Output System
ASP	AppleTalk Session Protocol
DNA SCP	Digital Network Architecture Session Control
Protocol	
NFS	Network File System
RCP	Remote Procedure Call
X Window System	



TCP/IP Networking

Il livello intermedio

Transport

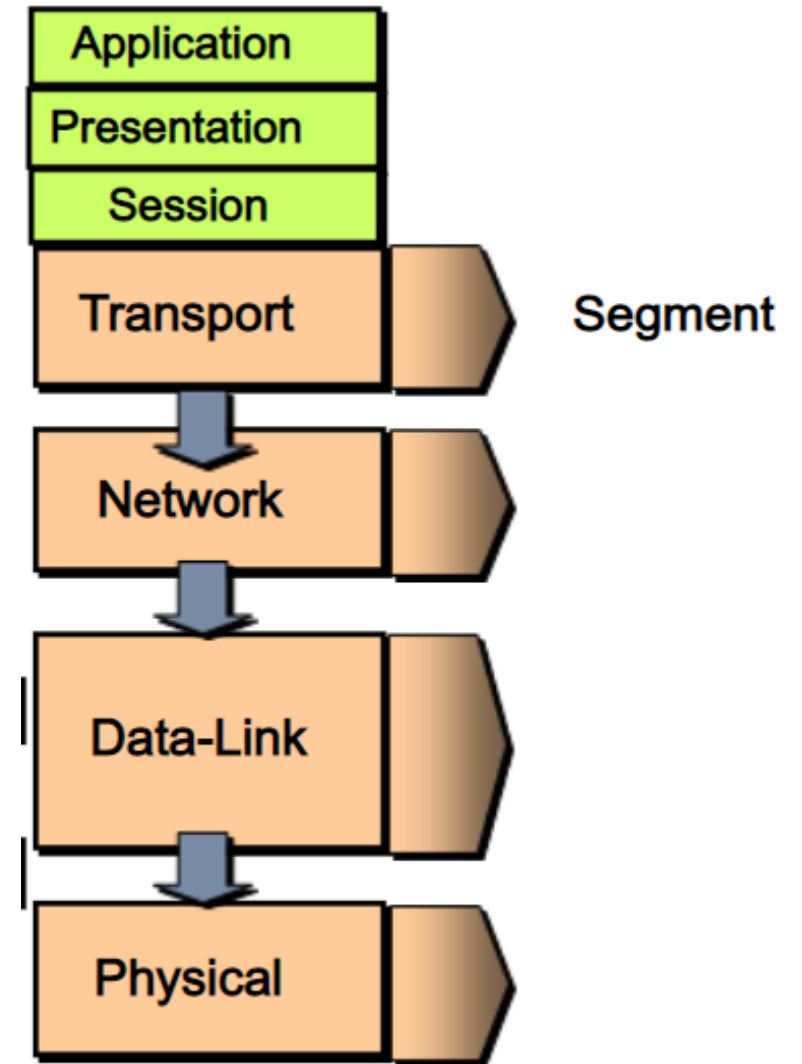
segna il confine tra protocolli application-oriented e protocolli orientati al trasporto dei dati. Divide in dati in **segmenti**. Fornisce ai livelli superiori una connessione affidabile, garantendo:

sessioni **connection-oriented**

inizializzazione, gestione e chiusura della sessione, individuazione e correzione degli errori, controllo del flusso

multiplexing di applicazioni

la stessa connessione a livello transport è condivisa da più applicazioni, distinte tramite un port number.



TCP/IP Networking

I tre livelli inferiori

Network

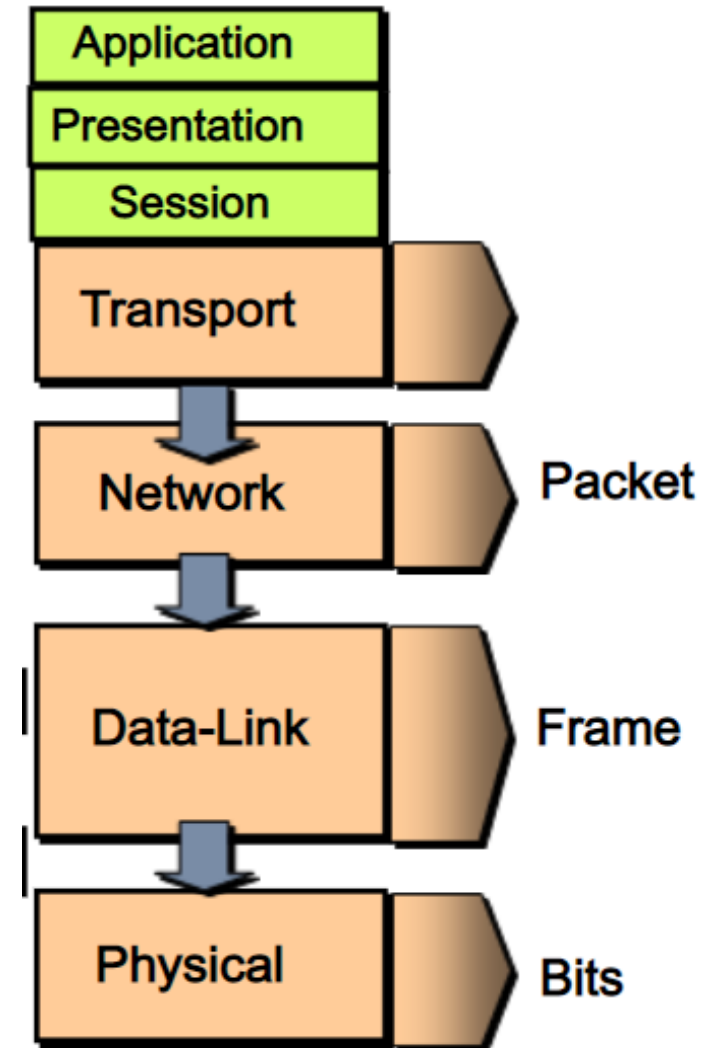
È il livello che si occupa della consegna di **pacchetti** tra una rete di partenza e una di destinazione. Nasconde al livello transport la distanza e la presenza di differenti data link tra i due nodi, creando una unica *internetwork* grazie alle funzioni di *path switching* e di *routing*.

Data Link

fornisce il trasporto di **frames** su un mezzo di trasmissione.
Gestisce l'indirizzamento dei nodi tramite indirizzo MAC, la notifica degli errori, il controllo del flusso.

Physical

definisce la specifiche meccaniche, elettriche e procedurali per l'attivazione e la gestione del collegamento fisico: livelli di tensione, velocità di trasmissione, massima lunghezza del collegamento, connettori, etc...
i dati a questo livello sono solo "bit streams", senza riguardo alla loro struttura o contenuto.

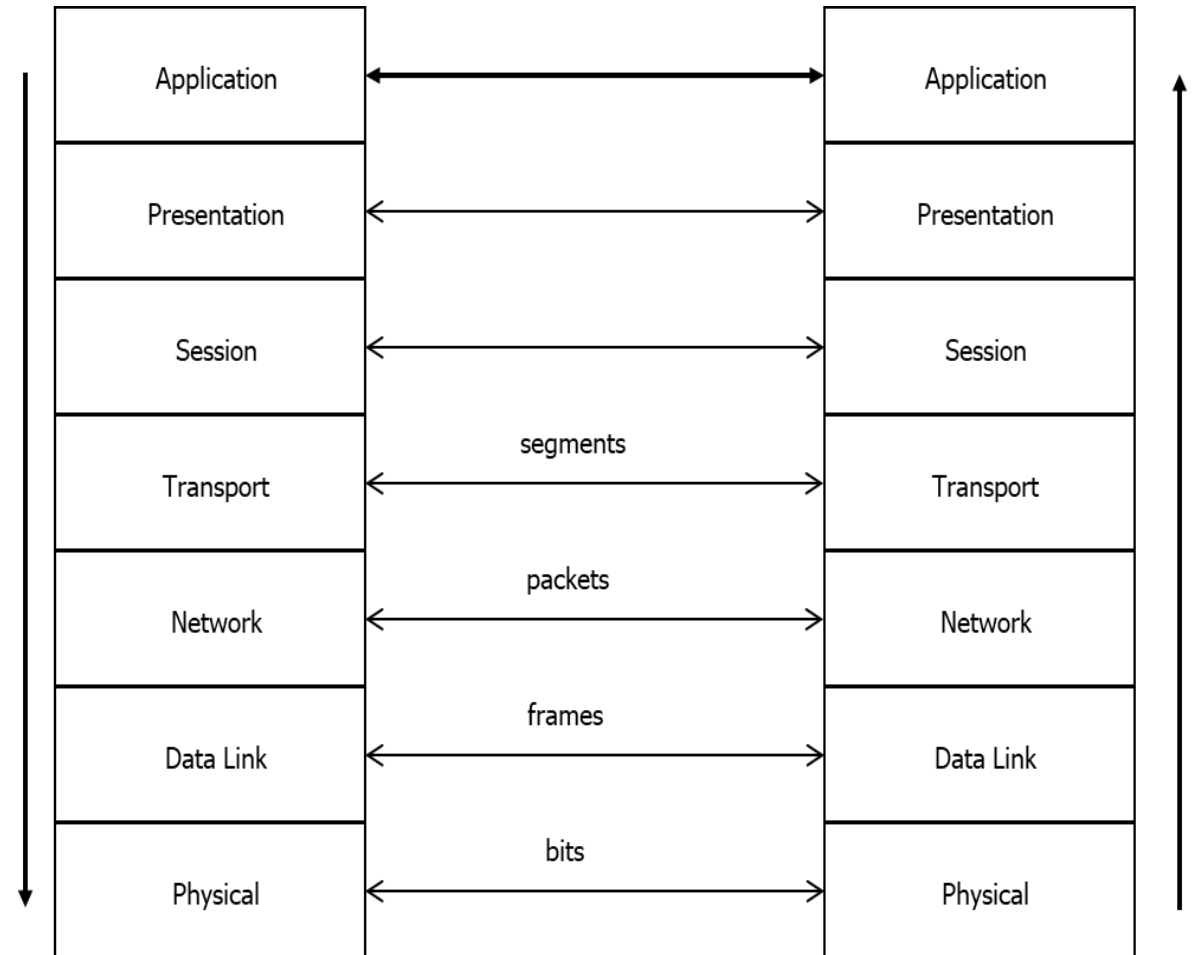


TCP/IP Networking

La comunicazione tra due applicazioni in rete comporta quindi:

1. il passaggio dei dati sul nodo di partenza dal livello Application fino a quello Physical
2. la trasmissione sulla rete a cura del protocollo di livello fisico
3. il passaggio dei dati dal livello fisico a quello Application sul nodo di destinazione

Grazie a questi passaggi ciascun livello può comunicare con il corrispondente, grazie al meccanismo dell'**encapsulation**.



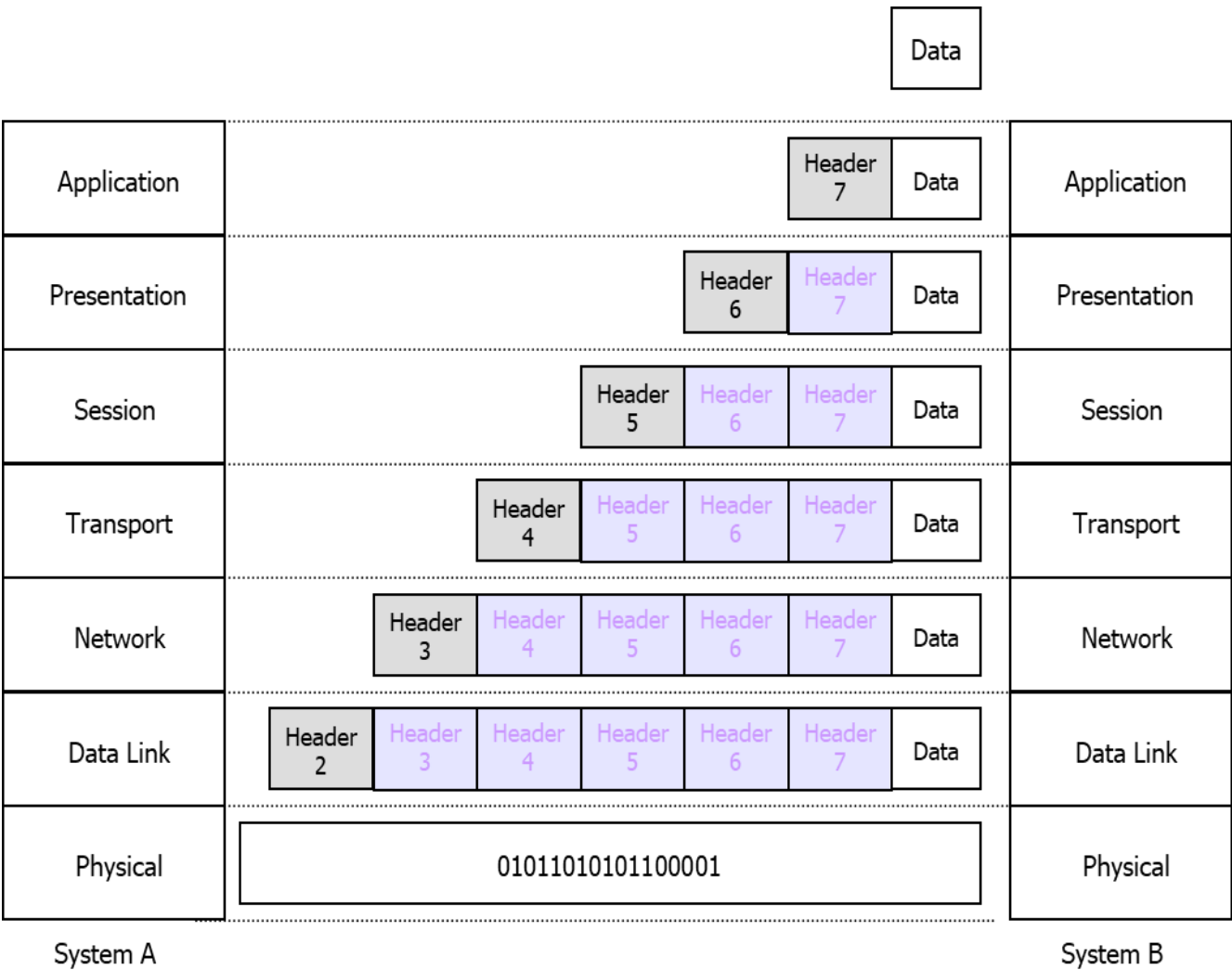
TCP/IP Networking

Encapsulation

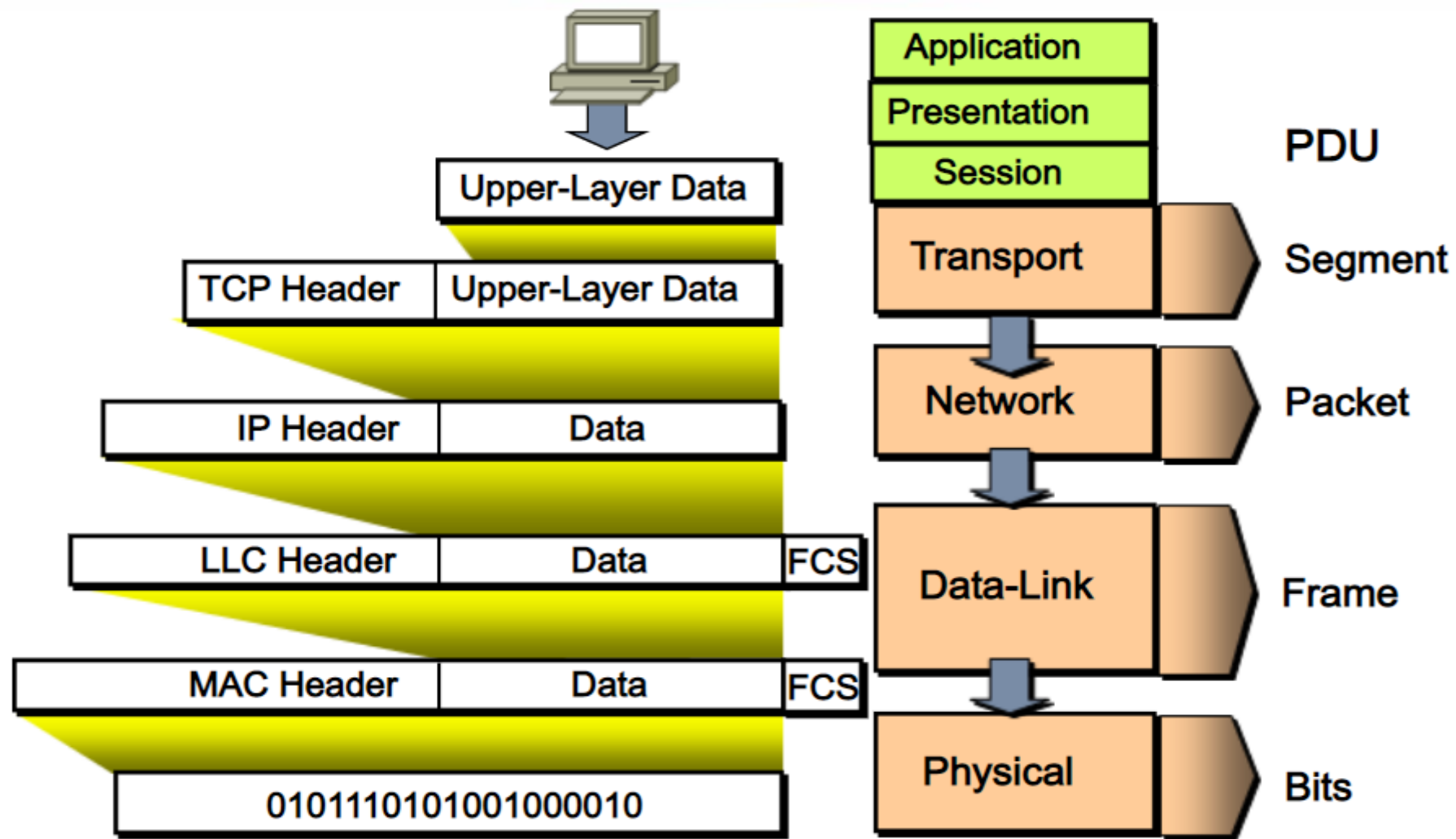
Quando, sul nodo partenza, il livello x riceve i dati dal livello superiore, li suddivide in **protocol data units (PDU)** e li fa precedere da un'intestazione (**header**) che contiene le informazioni di controllo necessarie alla comunicazione con il livello x del nodo di destinazione.

I dati che arrivano al livello fisico contengono il dato originario preceduto dai vari header che ogni livello attraversato ha aggiunto.

Sul nodo di destinazione i dati subiscono il procedimento inverso: ogni livello legge l'header che gli compete e lo elimina prima di passare i dati al livello superiore.



TCP/IP Networking



TCP/IP Networking

Il livello Application

Il livello application fornisce l'interfaccia utente ad una gamma di servizi di rete implementati tramite protocolli standard, come ad esempio:

- posta elettronica
- trasferimento di file
- accesso remoto
- processi client-server
- world wide web

Il programma applicativo utilizza un insieme definito di primitive - supportate dal sistema operativo locale - per accedere ai servizi di rete offerti. Il sistema operativo usa il sottosistema di comunicazione come se fosse un dispositivo locale, per esempio un driver di un disco.

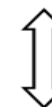
La realizzazione pratica della comunicazione è completamente nascosta all'applicazione, a cui viene solo notificato il risultato dell'operazione richiesta.

È dal livello application che vengono forniti servizi di:

- identificazione dei due partner per nome o indirizzo
- individuazione della disponibilità del partner
- accordo sul meccanismo di crittazione dei dati
- autenticazione del partner
- scelta delle procedure di inizializzazione e rilascio della comunicazione



Programmi utente



Application Layer

trasferimento di file
posta elettronica
scambio di messaggi e documenti
accesso remoto
processi client/server
world wide web

TCP/IP Networking

Il livello Presentation

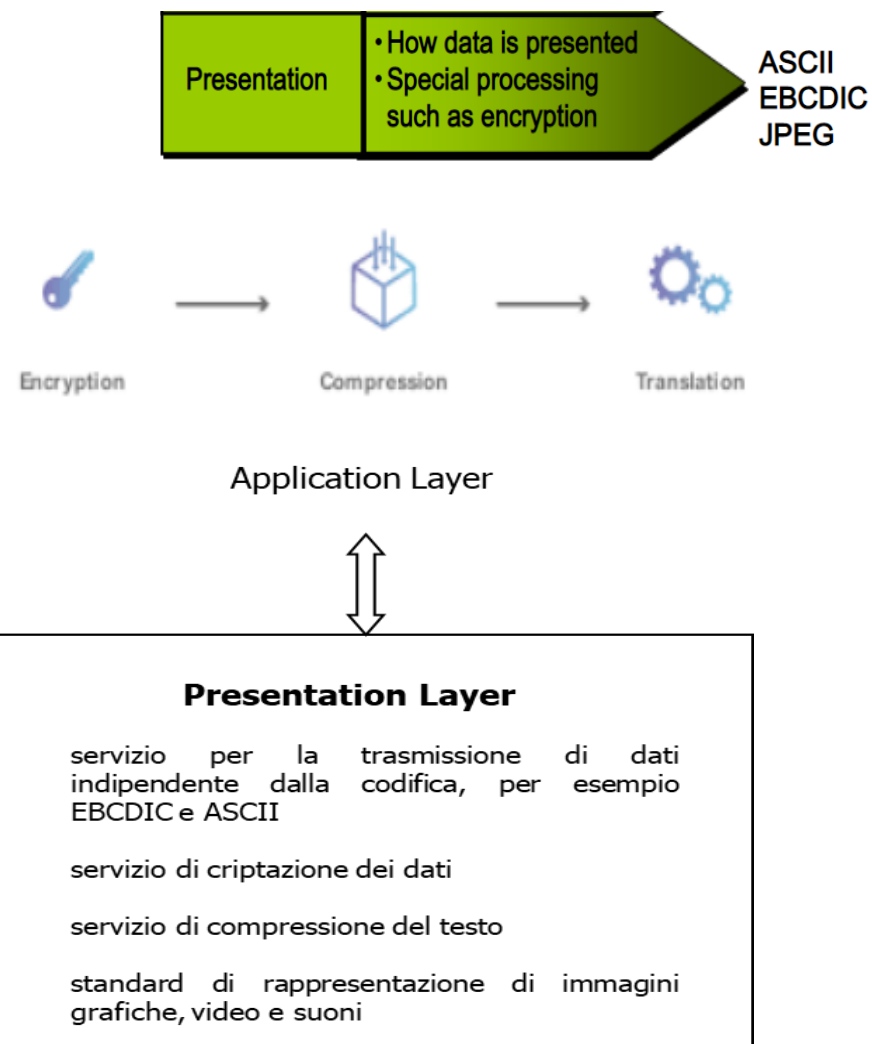
Il livello Presentation si occupa della rappresentazione dei dati durante la comunicazione tra le due applicazioni, e quindi della negoziazione e selezione di una sintassi comune per il trasferimento, in modo che venga mantenuta la struttura del messaggio scambiato. Se questa sintassi è differente da quella utilizzata internamente al sistema, il livello presentation si occupa della conversione.

Si può immaginare questo livello come un "interprete", che sul sistema di partenza traduce dal linguaggio utilizzato al linguaggio comune e fa il contrario sul sistema di arrivo.

Un'altra funzione del livello presentation è la criptazione dei dati, in modo che viaggino sulla rete al sicuro da intercettazioni indesiderate.

Inoltre a questo livello vengono utilizzati gli standard per la rappresentazione di immagini, video e suoni, come ad esempio:

- PICT per il trasferimento di grafici QuickDraw tra Macintosh e PowerPC
- TIFF Tagged Image File Format
- JPEG Joint Photographic Experts Group per le immagini
- MIDI Musical Instruments Digital Interface per i suoni
- MPEG Motion Picture Experts Group per i video



TCP/IP Networking

Il livello Session

Il livello session si occupa della gestione e sincronizzazione del dialogo tra le due applicazioni. Fornisce - ad entità di livello presentation - servizi di:

- inizializzazione e chiusura della connessione
- modalità di connessione half-duplex e full-duplex
- sincronizzazione, in modo che in caso di errore il dialogo possa ripartire da un punto concordato
- reporting degli errori.

Tra i protocolli di livello session rientrano ad esempio:

Remote Procedure Call (RPC)

infrastruttura di comunicazione tra processi attraverso una rete. Di tipo client-server, è alla base di molti servizi di rete distribuiti, come l'NFS

X Windows System

sviluppato dal MIT per sfruttare al meglio le workstation disponibili, si basa su un protocollo di rete che può essere implementato su qualsiasi piattaforma.

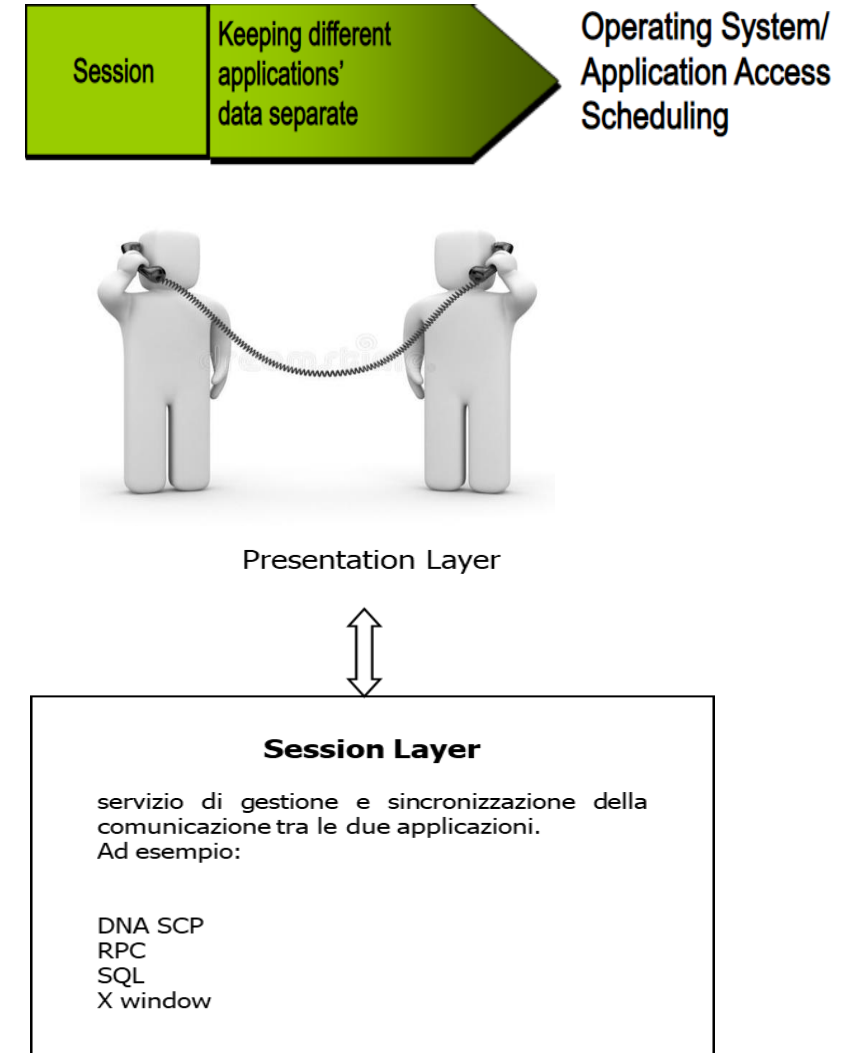
Fornisce una gerarchia di finestre modificabili e supporta una grafica indipendente dal device e ad alte prestazioni

AppleTalk Session Protocol (ASP)

per stabilire e mantenere sessioni tra client e server AppleTalk

Digital Network Architecture Session Control Protocol (DNA SCP)

Il protocollo di livello session dell'architettura DNA



TCP/IP Networking

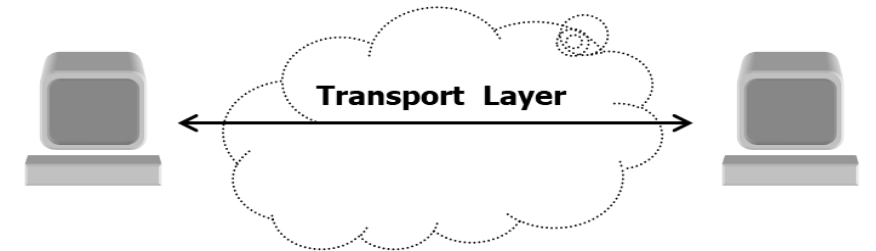
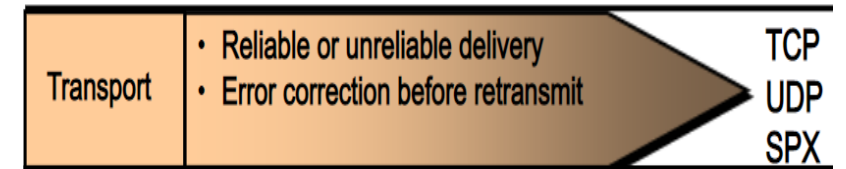
Il livello Transport

I protocolli di livello transport garantiscono ai livelli superiori un servizio di creazione e gestione della connessione logica tra stazione di partenza e stazione di destinazione.

Possono garantire una connessione affidabile, con caratteristiche connection-oriented:

- inizializzazione e chiusura della sessione
- integrità dei dati tramite il controllo del flusso
- individuazione degli errori ed eventuale ritrasmissione dei segmenti
- riordinamento nella sequenza corretta dei segmenti arrivati a destinazione

Inoltre il protocollo di livello transport consente a più applicazioni differenti di condividere la connessione , tramite il multiplexing.



dati visti come **segmenti**

inizializzazione, gestione e chiusura della sessione

individuazione e correzione degli errori

controllo del flusso

multiplexing di applicazioni



TCP/IP Networking

Il livello Network

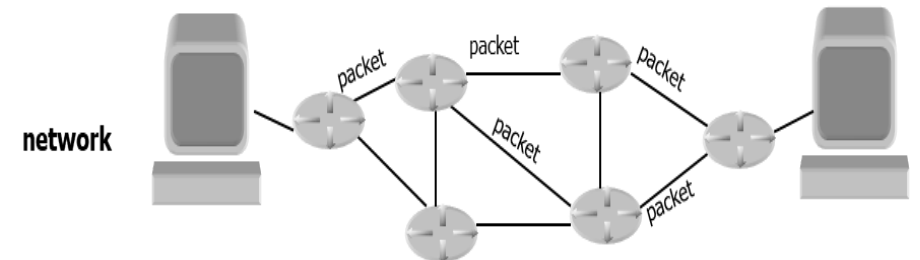
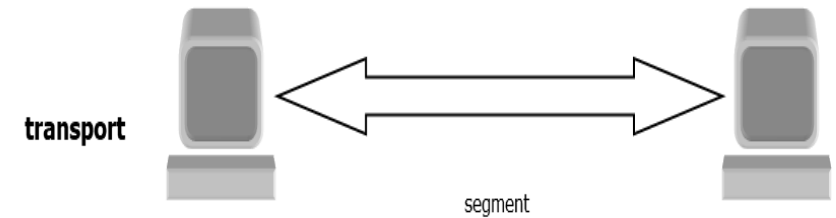
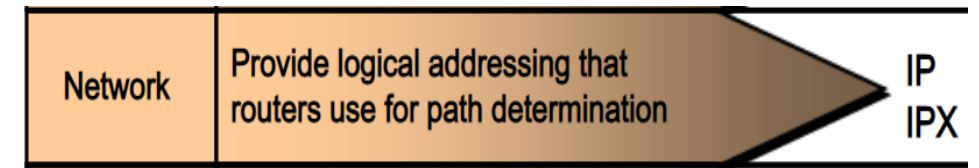
Il protocollo di livello transport vede la rete come il mezzo che collega stazione di partenza e stazione di destinazione, e attraverso il quale far passare i segmenti che costituiscono la comunicazione tra le varie applicazioni.

Questa “vista” della rete è possibile grazie ai servizi forniti dal livello network, che nascondono ai livelli superiori i problemi collegati all'instradamento tra reti differenti e alla determinazione del percorso migliore sorgente-destinazione.

Il livello network incapsula i segmenti in pacchetti e li inoltra da una rete ad un'altra - **packet switching** - selezionando il percorso più conveniente - **path determination** - tra la rete di partenza e quella di destinazione.

Il dispositivo principale che implementa le funzioni del livello network è il router.

L'informazione principale che permette al router di inoltrare pacchetti è l'indirizzo di livello network, unico che ha significato globale all'interno di un'internetwork costituita da più reti di tipo differente.



TCP/IP Networking

Il livello Data Link

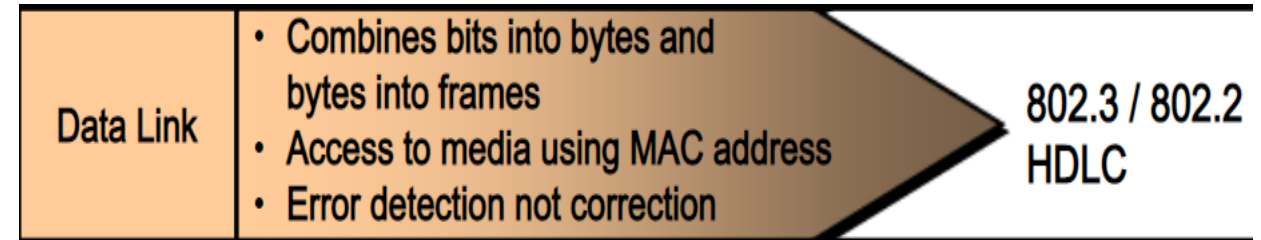
Il livello Data Link si occupa del trasporto affidabile dei dati attraverso un collegamento fisico.

I dati a questo livello vengono formattati in frame.

Le specifiche del collegamento dati includono il sequenziamento dei frame, controllo di flusso, sincronizzazione, notifica di errore, topologia di rete fisica e indirizzamento fisico.

Questo livello converte i frame in bit durante l'invio di informazioni e converte i bit in frame durante la ricezione di informazioni dal supporto fisico.

Bridge e Switch funzionano a livello data link.



TCP/IP Networking

Il livello Data Link

A causa della complessità di questo livello OSI, IEEE suddivide il livello data link in tre sottolivelli per LAN.

Lo strato superiore è il sottolivello **Logical Link** , che gestisce le comunicazioni tra i dispositivi.

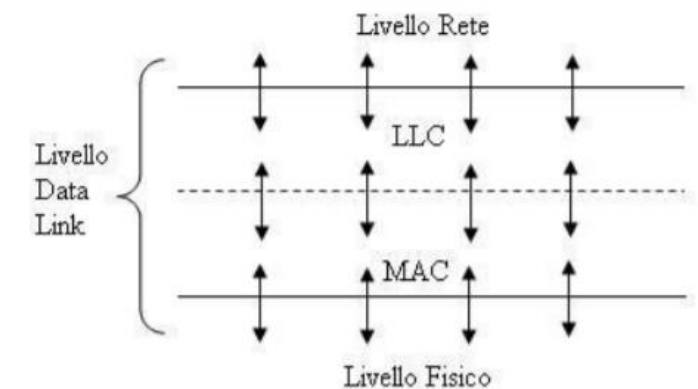
Il **livello bridging**, definito da IEEE 802.1, è il livello intermedio.

Il livello più basso è **Media Access Control (MAC)**, che gestisce l'accesso del protocollo al livello fisico.

I sistemi collegati a un livello Data link comune hanno un unico indirizzo su quel livello di Data link . Tieni presente che potresti trovare alcuni riferimenti che descrivono questo livello con due sottolivelli: il sottolivello **Logical Link Control (LLC)** e il sottolivello **MAC**.

OSI Model	IEEE 802 Specifications
Data Link Layer	802.2 Logical Link
	802.1 Bridging
	Media Access Control

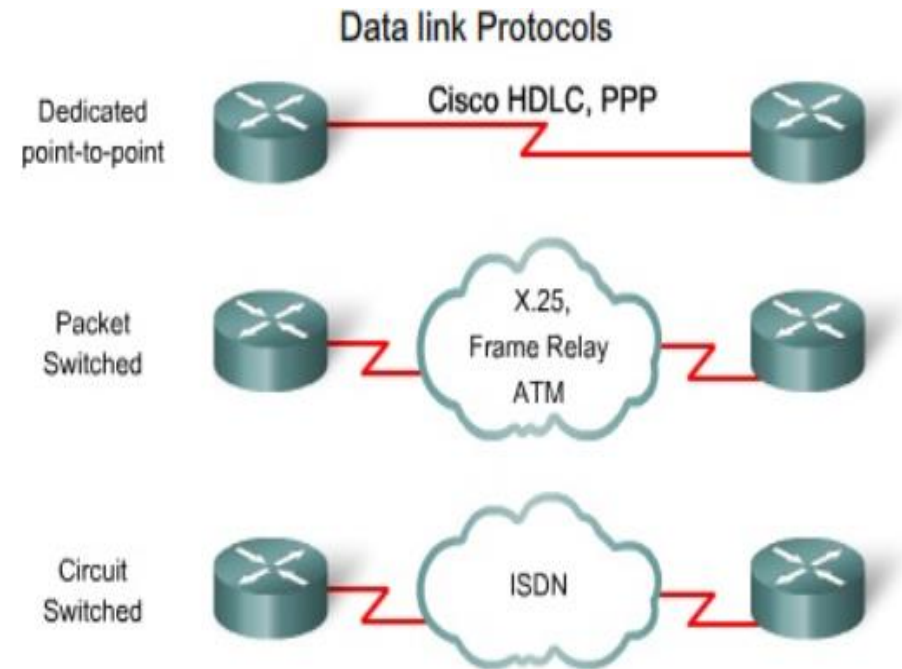
IEEE Data Link Sublayers



Il livello Data Link

Esempi di tecnologie del livello Data Link dati sono :

- Frame Relay
- ATM
- Synchronous Data Link Control (SDLC)
- High-Level Data Link Control (HDLC)
- Point-to-Point Protocol (PPP)
- Ethernet implementations (IEEE 802.3)
- Wireless LAN (IEEE 802.11)



Protocol	Usage
Link Access Procedure Balanced (LAPB)	X.25
Link Access Procedure D Channel (LAPD)	ISDN D channel
Link Access Procedure Frame (LAPF)	Frame Relay
High-Level Data Link Control (HDLC)	Cisco default
Point-to-Point Protocol (PPP)	Serial WAN switched connections

TCP/IP Networking

Il livello Fisico

Il livello Fisico si occupa degli aspetti elettrici/elettronici dell'hardware della scheda di rete e dei mezzi trasmissivi. Esso si occupa della trasmissione di treni di bit. Descrive anche i livelli di tensione, velocità trasmissione dati e distanze di trasmissione massime. In sintesi, si tratta di specifiche elettriche, meccaniche, funzionali e procedurali per i collegamenti tra sistemi di rete. Esempi di specifiche del livello fisico sono:

- EIA/TIA-232 (Electronic Industries Association/ Telecommunications Industry Association)
- EIA/TIA-449
- V.35
- IEEE 802 LAN and metropolitan-area network (MAN) standards
- Physical layer (PHY) groups Synchronous Optical Network/Synchronous Digital Hierarchy (SONET/SDH)

Physical	• Move bits between devices • Specifies voltage, wire speed, and pin-out cables	EIA/TIA-232 V.35
----------	---	---------------------



Hub



Cat5



Network Interface Card

Physical Layer

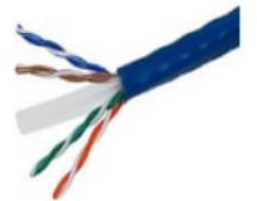
Layer of wires/cables but also has devices that function on this layer



Wireless Access Point



Fibre Optic Wire



Ethernet Copper cable

TCP/IP Networking

II TCP/IP

Il gruppo di protocolli con questo nome viene completato dai ricercatori della Stanford University alla fine degli anni '70, grazie ai fondi del "Defense Advanced Research Project Agency" (DARPA).

Il modello architetturale prevede quattro livelli, inglobando i tre superiori del modello OSI nell'unico livello "Application".

Physical e Data Link non vengono definiti, ma vengono accettati gli standard esistenti.

IP, Internet Protocol, è Il protocollo principale del livello Internet. Fornisce servizi di routing, frammentazione e riassettaggio di "datagrams". È connectionless e si affida al protocollo di livello superiore per l'affidabilità della connessione.

ICMP, Internet Control Message Protocol, a livello Internet e dedicato alla gestione degli errori e all'invio di messaggi di controllo.

TCP, Transmission Control Protocol, è il protocollo principale del livello transport. Fornisce un servizio connection-oriented, full-duplex, con acknowledge e controllo del flusso.

UDP, User Datagram Protocol, a livello transport ma di tipo connectionless.

OSI Model	TCP/IP Model
Application Layer	Application layer
Presentation Layer	
Session Layer	
Transport Layer	Transport Layer
Network Layer	Internet Layer
Data link layer	Link Layer
Physical layer	

TCP/IP Networking

Lo stack

A livello Application nello stack TCP/IP troviamo applicazioni relative a:

- trasferimento di file

FTP File Transfer Protocol
TFTP Trivial File Transfer Protocol

- condivisione di file system

NFS Network File System System

- emulazione terminale e login remoto

telnet
rlogin

- risoluzione dei nomi

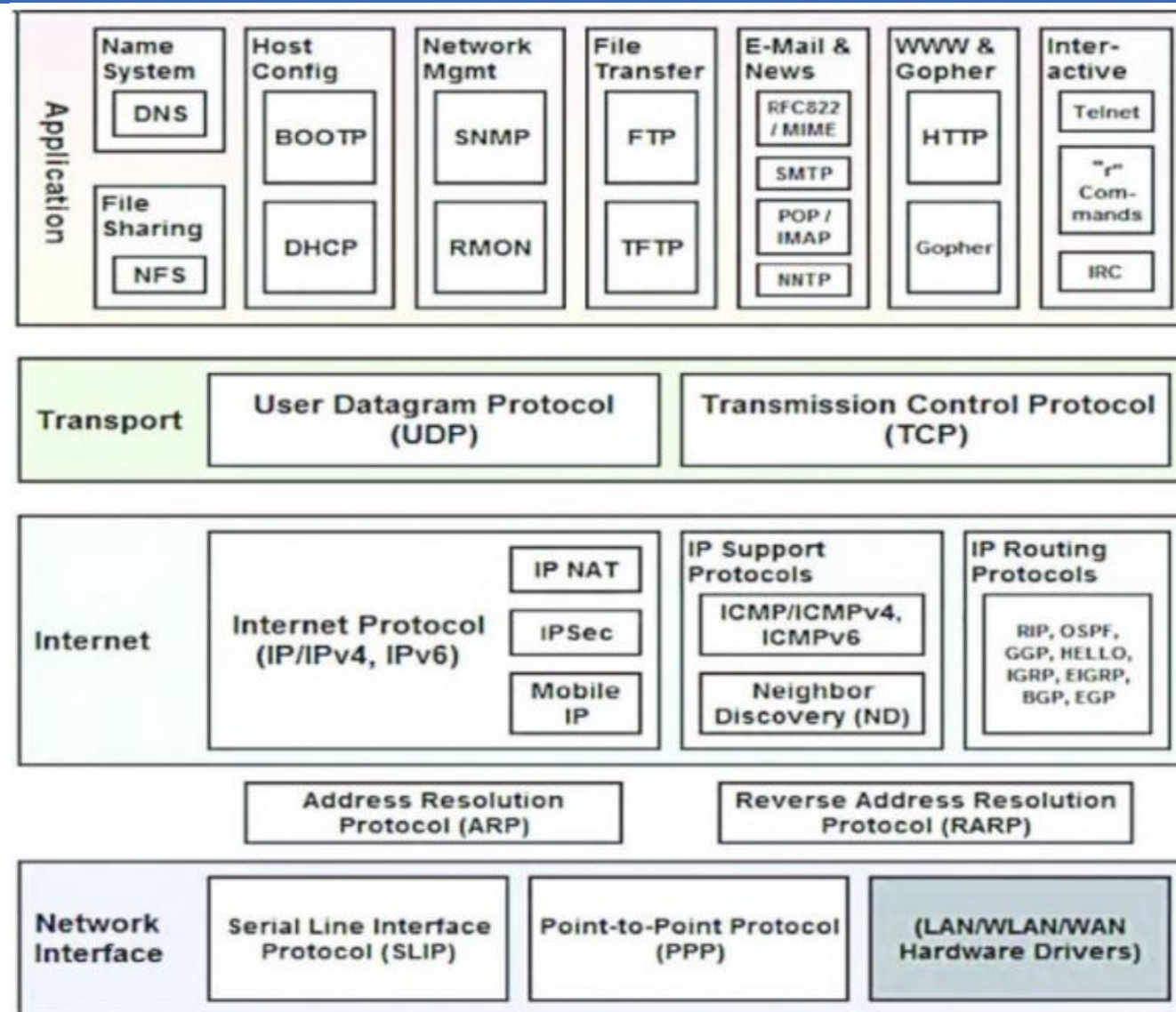
DNS Domain Name System

- e-mail

SMTP Simple Mail Transfer Protocol

- troubleshooting

PING
tracert/route



TCP/IP Networking

Principali protocolli di rete

Protocol/standard	ISO/OSI model layer	Examples
HTTP , SSL/TLS, S/MIME, SSH, DNSsec	Application	Hypertext Transfer Protocol (HTTP); foundation for the world wide web (WWW)
VT RTSE	Presentation	On the SASE sub layer (specific application service element) – Virtual terminal On the CASE Sub layer (common application service element) – Reliable Transfer Service Element
API-sockets Sockets	Session	Application programming interface (API); allows application programs to control and use network sockets
TCP, SSL /TLS	Transport	Transmission Control Protocol Secure Sockets Layer; a protocol for encrypting information over the Internet.
IP, IPsec, IPv6	Internet/Network	Transmission Control Protocol/Internet Protocol
Ethernet, IEEE 802.3, WEP, WPA2	Data Link/Link	Carrier Sense Multiple Access / Collision Detection (CSMA/CD) Defining the physical layer and data link layer's media access control (MAC) of wired Ethernet. (Wi-Fi equivalent: 802.11a,b/g,n)
1000BASE-T, etc.	Physical	Fixed line (cable, LAN, WAN) or wireless connection

TCP/IP Networking

La terminologia

Ogni layer utilizza la sua struttura di dati e adotta la sua terminologia.

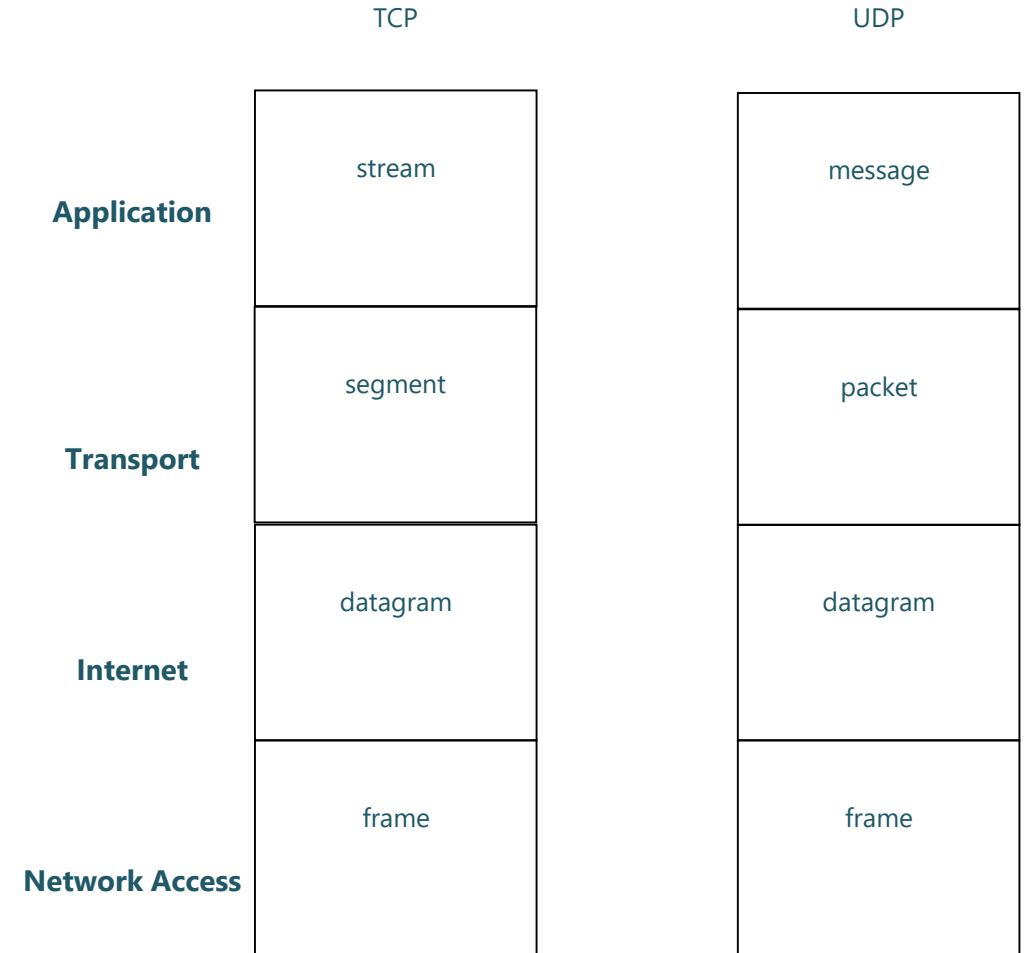
A livello Transport, le applicazioni che usano il TCP e quelle che usano l'UDP si riferiscono ai dati in modo diverso: le prime con stream e le seconde con message.

Il TCP chiama i suoi dati segment, l'UDP packet o datagram.

A livello Internet si parla di datagram mentre a livello data link di frame.

Come nel modello OSI, i dati passano lungo la rete attraversando prima lo stack TCP/IP del sistema di partenza. Ogni livello attraversato aggiunge le sue informazioni di controllo ai dati ricevuti dal livello superiore, "incapsulandoli" nel formato corrispondente a quel livello.

Sul sistema di destinazione il processo effettuato è esattamente l'inverso e richiede ad ogni livello di esaminare e togliere le sue informazioni di controllo prima di passare i dati al livello superiore.



TCP/IP Networking

Il multiplexing

Prima che un'applicazione possa comunicare con un'altra su un sistema remoto, deve conoscere il numero di porta dell'applicazione remota.

Con il numero di porta viene realizzato il meccanismo di "multiplexing", per cui la stessa connessione a livello transport è condivisa da più applicazioni.

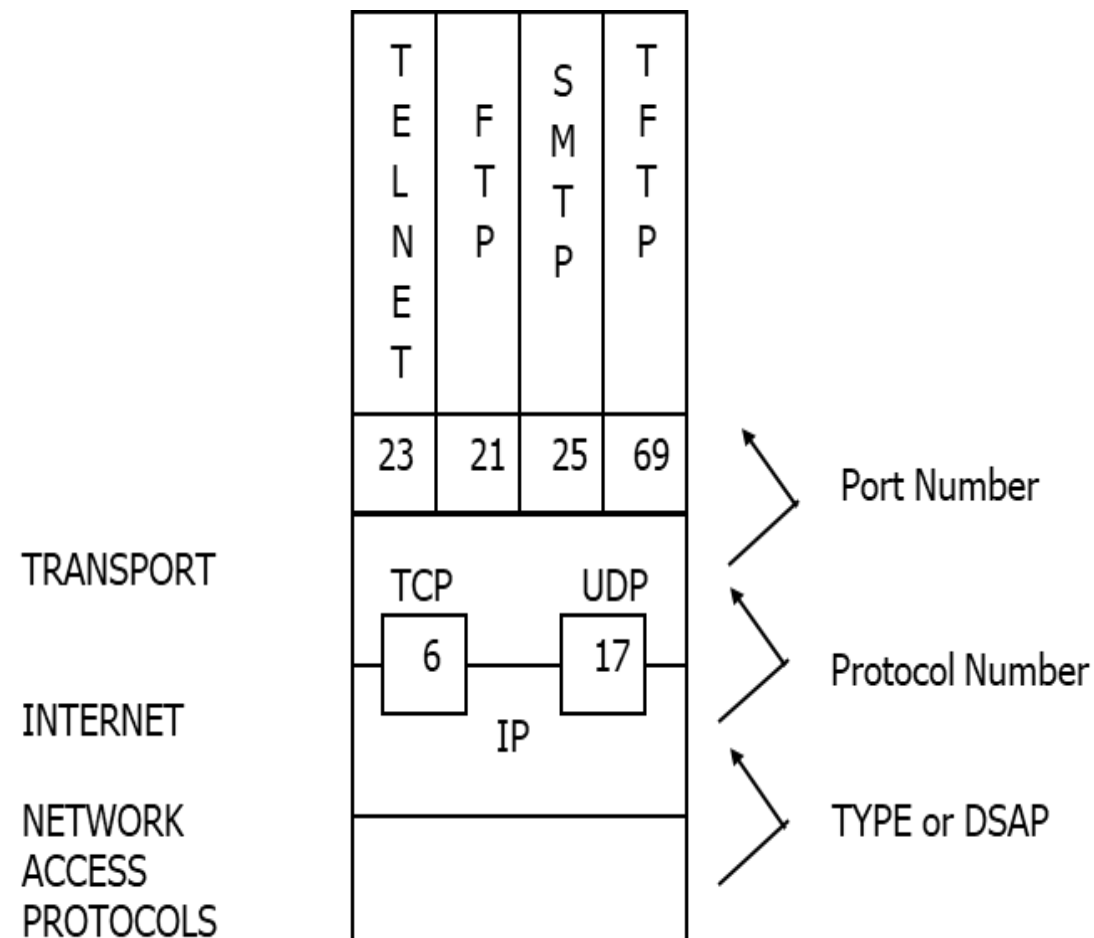
Due applicazioni che si basano sull'UDP sono ad esempio SMTP e il TFTP, che usano i numeri di porta 25 e 69.

A loro volta segmenti TCP e pacchetti UDP devono poter utilizzare contemporaneamente il protocollo IP, e per questo il datagram IP contiene l'informazione relativa al protocollo di Transport nel campo "protocol number".

Nel passaggio inverso, i dati vengono prima consegnati al corretto protocollo di Transport poi alla applicazione di destinazione, realizzando l'operazione inversa alla precedente e detta "demultiplexing".

I numeri di porta e i numeri di protocollo sono definiti nella RFC Assigned Numbers.

I numeri di porta con valore inferiore a 256 sono chiamati "well-know services" e utilizzati dalle principali applicazioni, mentre quelli con valori compresi tra 256 e 1024 identificano gli Unix-specific services.



TCP/IP Networking

Esempi di numeri di porta noti

- **Porta 80, HyperText Transfer Protocol (HTTP):** HTTP è il protocollo di comunicazione tra i browser e i siti web e i dati sono trasmessi in chiaro.
- **Porta 20, File Transfer Protocol (FTP):** FTP è un protocollo per il trasferimento dei file; e utilizza il protocollo TCP per una trasmissione orientata alla connessione in chiaro, inclusa la password. Una trasmissione orientata alla connessione significa che i singoli pacchetti sono numerati e vengono trasmesse delle ricevute (ACK) per aumentare l'integrità del trasferimento di file.
- **Porta 69, Trivial File Transfer Protocol (TFTP):** TFTP è un protocollo per il trasferimento dei file che utilizza il protocollo UDP per una trasmissione non orientata alla connessione. Anche in questo caso il trasferimento è in chiaro. Generalmente viene usato per trasferimenti brevi e veloci poiché non garantisce la consegna dei pacchetti.
- **Porta 23, Terminal Network (Telnet):** protocollo di rete per accedere da remoto ad un altro device. Utilizza TCP e invia i dati in chiaro.
- **Porta 22, Secure Shell (SSH):** protocollo di rete per accedere da remoto ad un altro device. SSH cifra la trasmissione dei dati.
- **Porta 25, Simple Mail Transfer Protocol (SMTP):** protocollo di rete per la posta elettronica
- **Porta 53, Domain Name System (DNS):** protocollo per la risoluzione degli indirizzi IP associati ai nomi dominio

TCP/IP Networking

User Datagram Protocol

Prima che un'applicazione possa comunicare con un'altra su un sistema remoto, deve conoscere il numero di porta dell'applicazione remota.

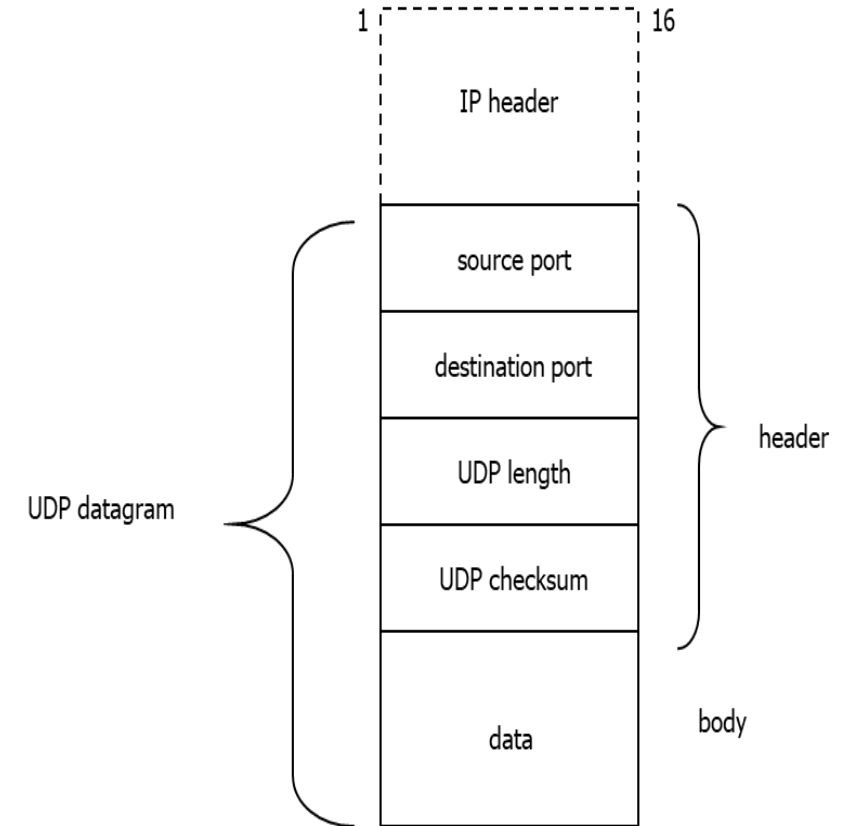
Con il numero di porta viene realizzato il meccanismo di "multiplexing", per cui la stessa connessione a livello transport è condivisa da più applicazioni.

Due applicazioni che si basano sull'UDP sono ad esempio SMTP e il TFTP, che usano i numeri di porta 25 e 69.

A loro volta segmenti TCP e pacchetti UDP devono poter utilizzare contemporaneamente il protocollo IP, e per questo il datagram IP contiene l'informazione relativa al protocollo di Transport nel campo "protocol number".

Nel passaggio inverso, i dati vengono prima consegnati al corretto protocollo di Transport poi alla applicazione di destinazione, realizzando l'operazione inversa alla precedente e detta "demultiplexing".

I numeri di porta e i numeri di protocollo sono definiti nella RFC Assigned Numbers. I numeri di porta con valore inferiore a 256 sono chiamati "well-know services" e utilizzati dalle principali applicazioni, mentre quelli con valori compresi tra 256 e 1024 identificano gli Unix-specific services.



TCP/IP Networking

Transmission Control Protocol

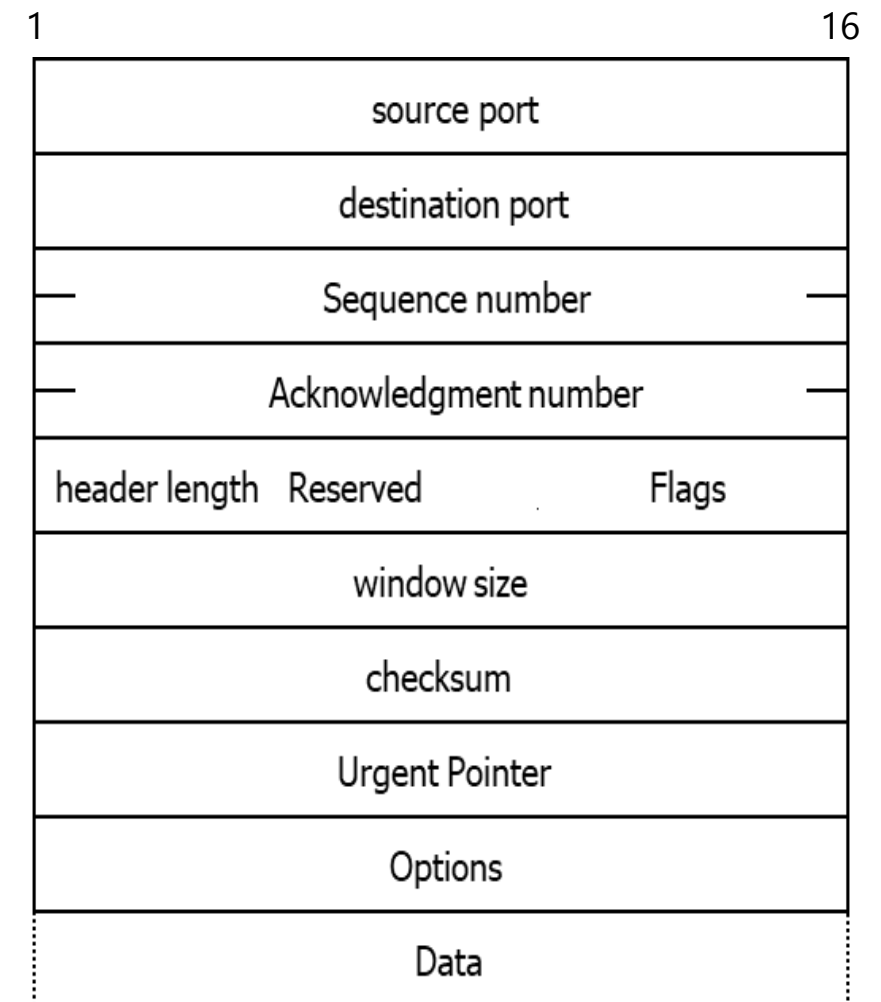
Il TCP è il protocollo principale del livello transport.

Fornisce un servizio connection-oriented, con controllo del flusso e controllo e correzione degli errori. Ha molte caratteristiche comuni con il protocollo HDLC, come il collegamento full-duplex, la procedura go-back-N per il controllo degli errori e il meccanismo di sliding-window per il controllo del flusso.

Le PDU che il TCP usa per inizializzare la connessione, trasferire i dati e chiudere la connessione sono tutte dello stesso formato, vengono chiamate segmenti e sono trasferite nel campo Data del datagram IP.

Il TCP verifica che i segmenti vengano trasmessi correttamente e arrivino a destinazione nella sequenza corretta.

La fase di "three-way handshake" inizializza la comunicazione tramite l'invio di segmenti di sincronizzazione. Al termine del trasferimento la connessione viene chiusa tramite un nuovo "three-way handshake" che segnala la fine dell'invio dei dati.



TCP/IP Networking

Transmission Control Protocol

Il TCP di destinazione riassembla i segmenti e li passa all'applicazione del livello superiore (ftp, telnet, ...) attraverso la "destination port" che identifica l'applicazione.

I numeri di sequenza e riconoscimento, CRC, porte di destinazione e provenienza fanno parte dell' header del pacchetto.

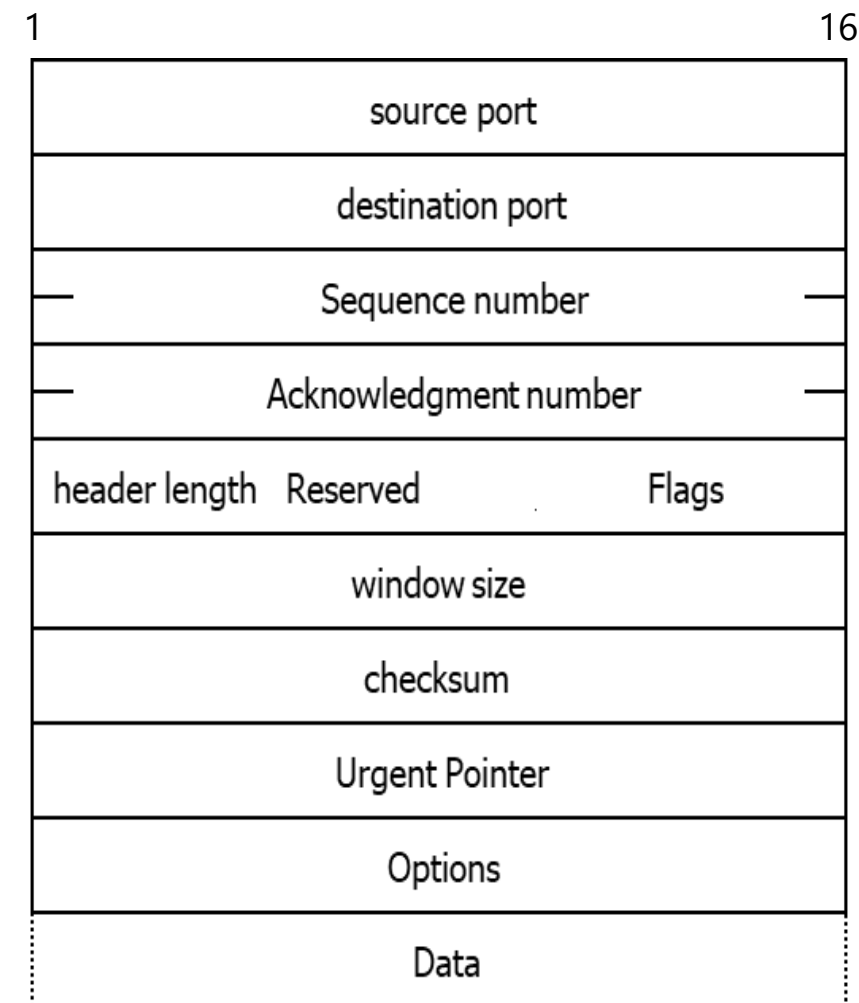
I primi due campi del dell'header coincidono con quelli dell'UDP, e indicano le porte delle applicazioni di partenza e destinazione, questa volta punti terminali di un collegamento logico che non viene invece instaurato nell'UDP.

Il numero di sequenza indica la posizione del primo byte del campo "data" del segmento rispetto all'inizio del messaggio nella direzione chiamante-chiamato, mentre il numero di acknowledge indica la posizione del primo byte del campo dati del segmento rispetto all'inizio del messaggio di risposta, byte che il TCP di partenza si aspetta di ricevere.

Il campo lunghezza da' il numero di parole a 32 bit contenute nell'header.

La window si riferisce al meccanismo di controllo del flusso basato sulla sliding window, e quindi indica quanti ottetti possono essere inviati senza ricevere acknowledge.

Il checksum si riferisce all'intero segmento, header+data. Il numero massimo di ottetti nel campo data e' pari a 536.



TCP/IP Networking

Transmission Control Protocol

I bit del campo “code bits” indicano la validità o meno di alcuni campi dell’header e il comportamento richiesto al TCP dal protocollo applicativo.

Quando ad esempio il flag URG è settato, il campo “urgent pointer” indica il numero di dati urgenti contenuti nel segmento, dati che devono essere trasferiti immediatamente a prescindere dal meccanismo di controllo del flusso.

Code Bits

Tipicamente il TCP di partenza decide quando trasmettere un segmento, che può essere costituito da più messaggi brevi o da una parte di un unico messaggio lungo, e il TCP di destinazione memorizza i dati ricevuti in un buffer e li consegna solo quando il buffer è pieno.

Il flag PSH (push) settato indica invece la richiesta al TCP - da parte del protocollo applicativo - di invio e consegna immediata dei dati ricevuti.

bit position	NAME - function
11	URG - urgent pointer valid
12	ACK - acknowledgment valid
13	PSH - deliver data on receipt
14	RST - reset the seq/ack no.
15	SEQ - sequence no. valid
16	FIN - end of byte stream

TCP/IP Networking

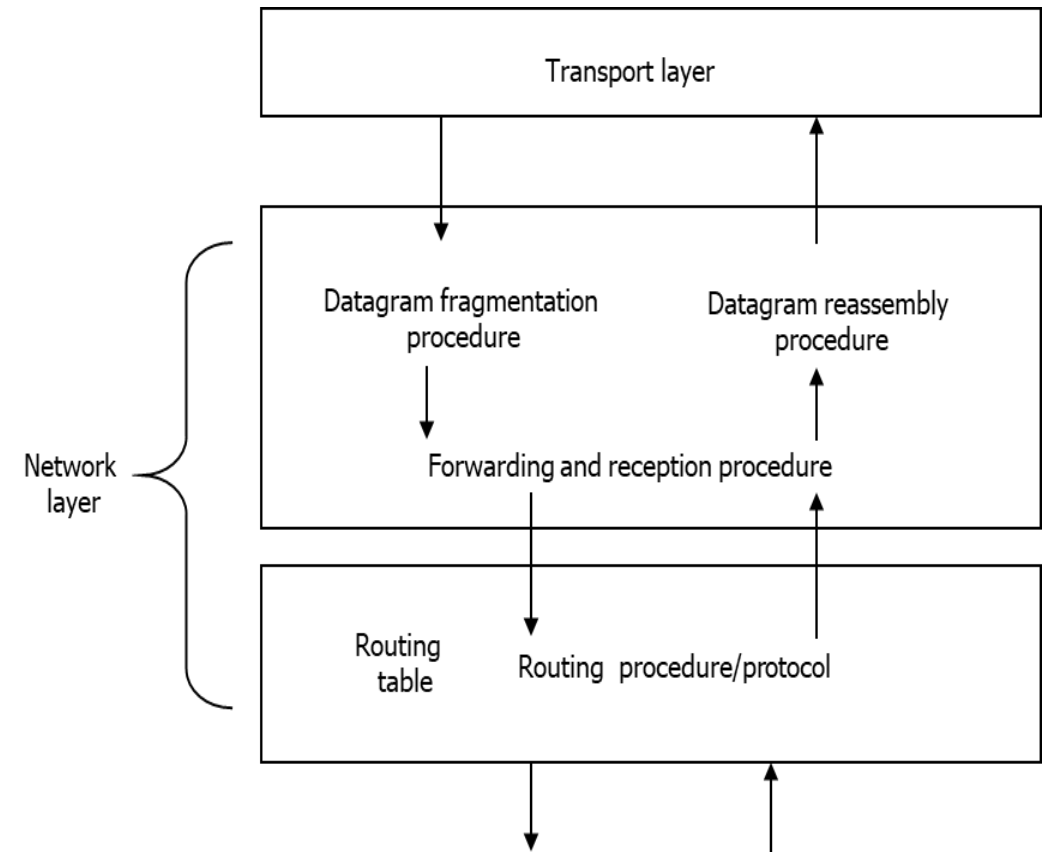
Internet Protocol

A livello network i segmenti provenienti dal livello transport vengono incapsulati in "datagram" dal protocollo IP (Internet Protocol), responsabile principalmente dei servizi di:

- "routing", instradamento dei datagram da una rete all'altra fino alla rete di destinazione
- frammentazione e ricomposizione dei datagram, per il trasferimento dei messaggi attraverso reti che supportano pacchetti di grandezze differenti
- reporting degli errori

Queste funzioni si basano sull'utilizzo di uno schema di indirizzamento strutturato, dove ogni indirizzo indica sia la rete che il sistema.

Una caratteristica importante dell'IP è inoltre il suo funzionare in modalità connectionless, senza acknowledge, controllo del flusso, riordinamento dei pacchetti, e quindi demandando ai protocolli di più alto livello la verifica dell'integrità dei messaggi scambiati.



TCP/IP Networking

Internet Protocol

Version: versione dell'IP. In questo modo tutti i sistemi che analizzano il datagram lo possono interpretare correttamente. Attualmente e' IPv4.

Header Length: l'header e' di lunghezza variabile. La lunghezza e' in parole di 32 bit. Minima pari a 5

Type of Service: E' un informazione che il TCP passa all'IP , e permette al protocollo applicativo di specificare preferenze riguardanti la rotta da seguire. Se per esempio viene indicato di preferenza un servizio affidabile, allora il router dovrebbe scegliere - avendone la possibilità - una rete connection-oriented rispetto ad una connectionless

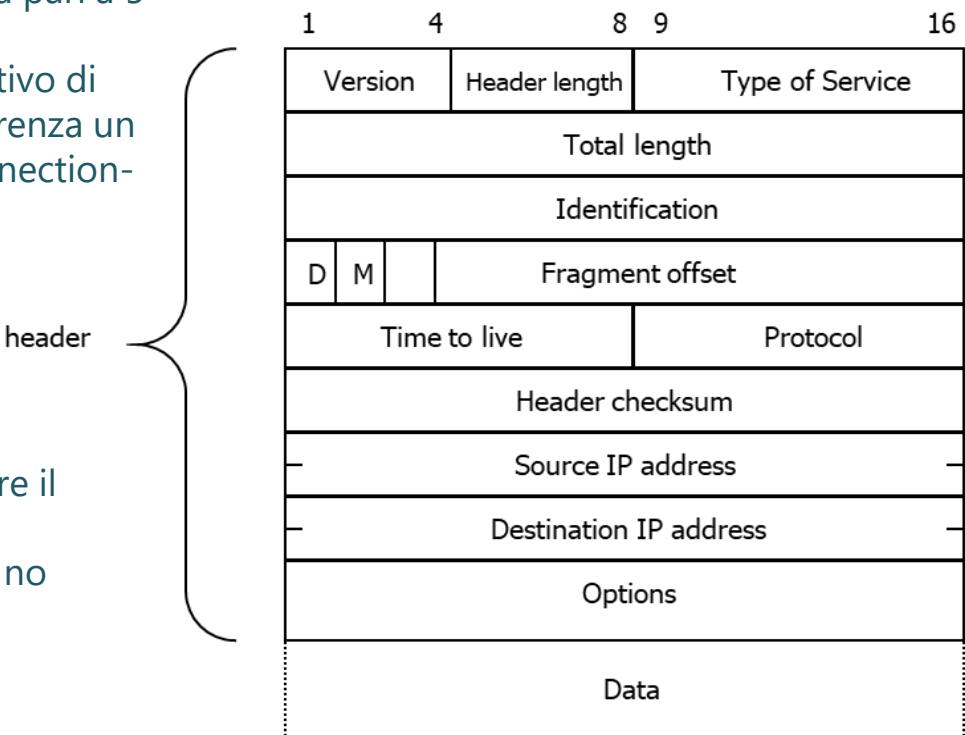
Length: Lunghezza totale di header+dati. Massima pari a 65536 byte

Identification: Identifica il fragment rispetto al datagram di cui e' parte

Flags D bit: don't fragment. Il router dovrebbe scegliere una rete che possa far viaggiare il datagram senza frammentarlo.
 M bit: more fragments. Indica se il frammento e' l'ultimo di un datagram oppure no

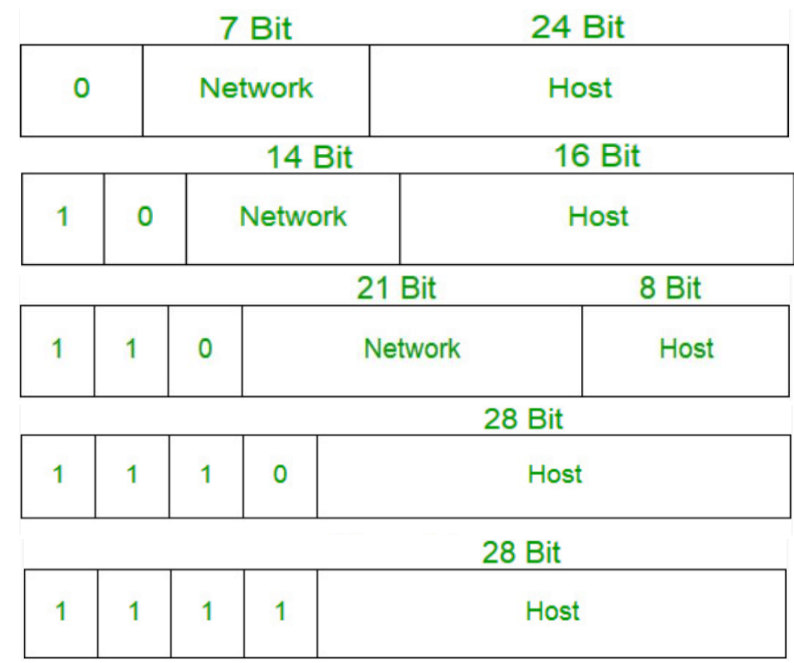
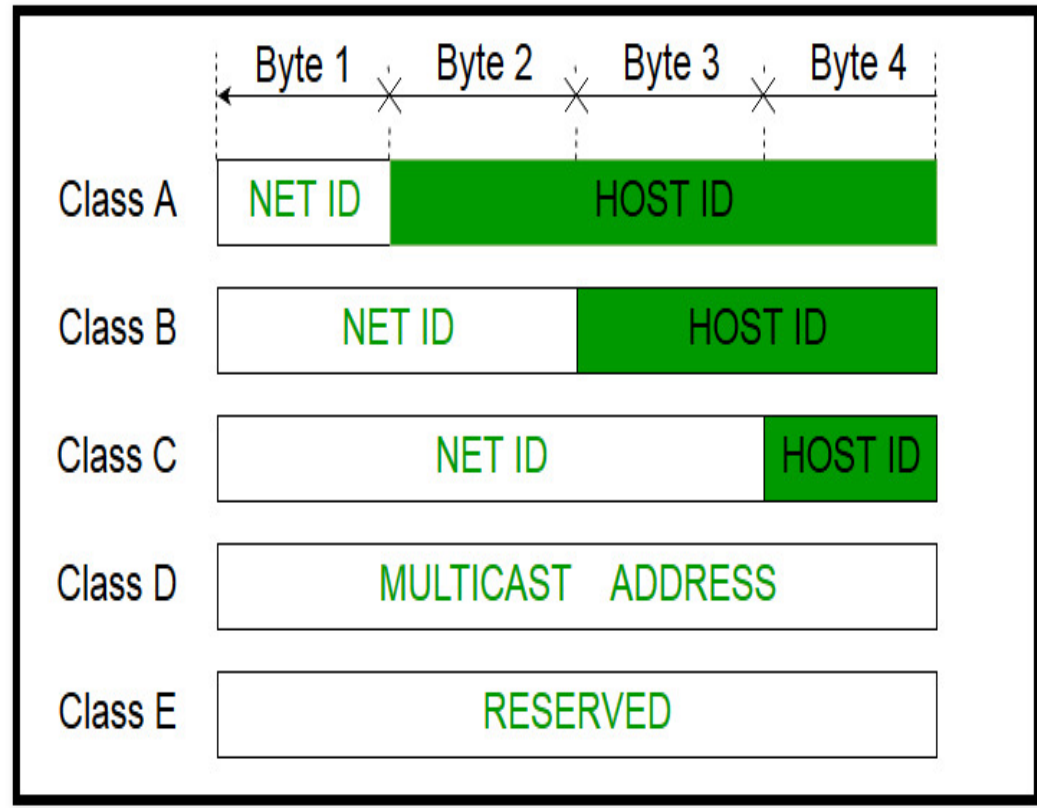
Fragmen offset: posizione del frammento rispetto al datagram

Time to live: tempo massimo che il datagram ha a disposizione per transitare sulla rete prima di arrivare a destinazione. In secondi, inizializzato dall'IP di partenza, e decrementato da ogni router di una quantità predefinita. Arrivato a zero, il datagram viene eliminato.



TCP/IP Networking

Internet Protocol



TCP/IP Networking

Internet Protocol

L'indirizzo IP è un intero a 32 bit assegnato da un amministratore di rete per identificare univocamente un sistema all'interno di una internetwork. Gli indirizzi IP sono suddivisi in classi, che definiscono reti di diversa grandezza.

La classe di appartenenza di un indirizzo dipende dal valore dei primi 4 bit. I bit rimanenti indicano l'indirizzo di rete e l'indirizzo del sistema, (indicati nel seguito con netid e hostid), ciascuno con un numero di bit dipendente dalla classe di appartenenza:

classe A:	netid = 7 bit	hostid = 24 bit	valore decimale del primo byte: 1 - 126
classe B:	netid = 14 bit	hostid = 16 bit	" 128 - 191
classe C:	netid = 21 bit	hostid = 8 bit	" 192 - 223

In questo modo si va dagli indirizzi di classe A che consentono reti con un numero elevato di sistemi (fino a 224), fino a quelli di classe C con 256 sistemi per rete.

L'indirizzo in cui la parte relativa al sistema è tutti zero indica un indirizzo di rete, mentre quello in cui è tutti 1 si riferisce a tutti i sistemi su una rete (indirizzo di broadcast).

Per comodità gli indirizzi sono divisi in quattro byte, e convertiti nell'equivalente decimale separando i byte con un punto (notazione decimale puntata).

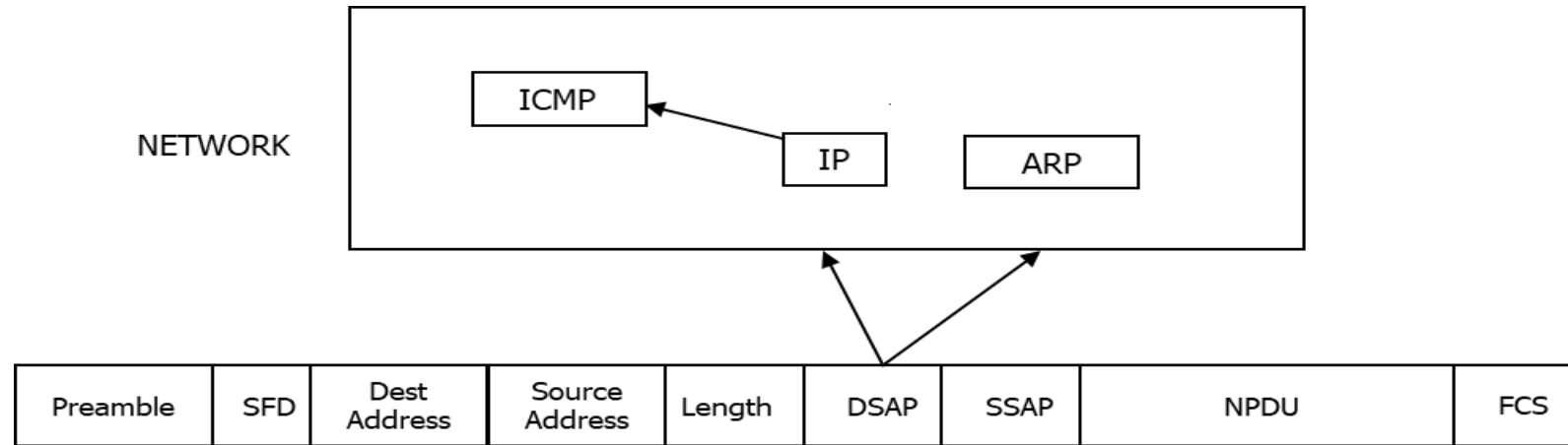
Per esempio:

00001010 00000000 00000000 00000000	=	10.0.0.0	classe A, rete 10
10000000 00000011 00000010 00000011	=	128.3.2.3	classe B, rete 128.3 e host 2.3
11000000 00000000 00000001 11111111	=	192.0.1.255	classe C, indirizzo di broadcast della rete 192.0.1

La classe D è riservata al multicasting, ovvero al "computer-supported cooperative working" (CSCW), che permette la comunicazione tra gruppi di sistemi, indirizzando la trasmissione solo ai membri del gruppo.

TCP/IP Networking

Address Resolution Protocol



L'IP non è l'unico protocollo di livello network.

L'ARP (Address Resolution Protocol) serve per conoscere l'indirizzo MAC corrispondente all'indirizzo IP del sistema di destinazione, se questo si trova sulla stessa rete di quello di partenza.

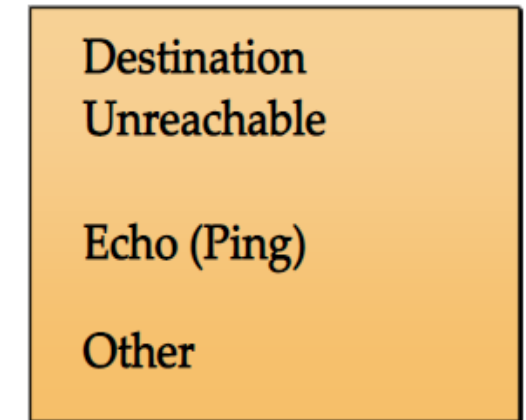
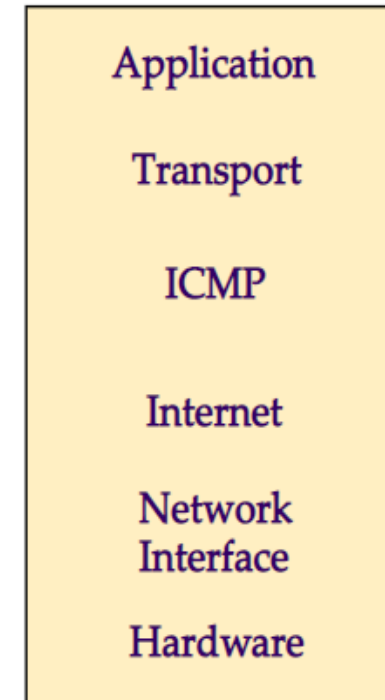
Se invece si trova su una rete differente, sempre tramite l'ARP l'indirizzo IP di destinazione viene fatto corrispondere all'indirizzo MAC del router intermedio, che a sua volta conosce l'indirizzo di livello data link del destinatario - se questo si trova su una rete direttamente connessa - oppure l'indirizzo di livello data link del router successivo lungo il percorso verso la rete di destinazione.

L'ICMP (Internet Control Message Protocol) viene usato dall'IP per gestire il reporting degli errori.

TCP/IP Networking

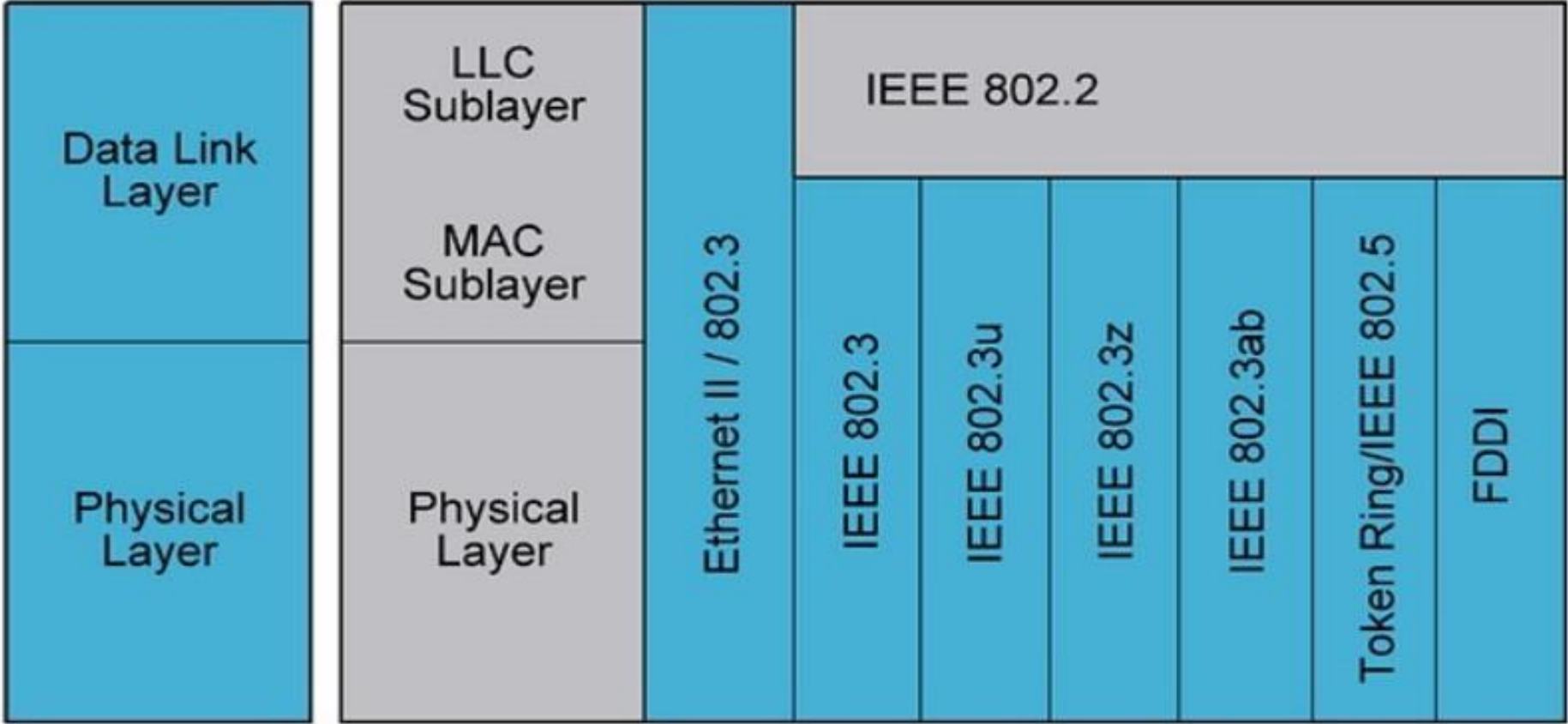
Internet Control Message Protocol

- Fornisce messaggi di errori, messaggi di stato e messaggi di amministrazione tra gateway ed host.
- I messaggi si riferiscono al funzionamento di IP.
- Usa IP per inviare i messaggi



TCP/IP Networking

IEEE 802.3



TCP/IP Networking

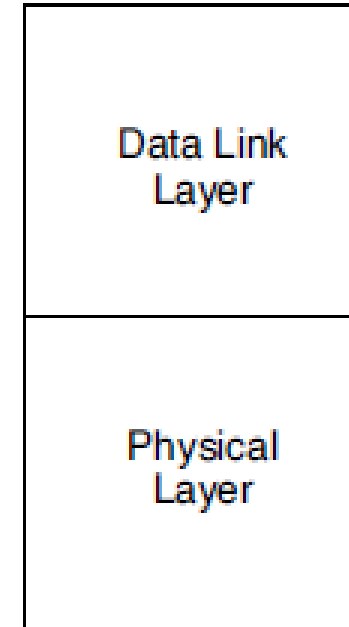
IEEE 802.3

Ethernet e IEEE 802.3: funziona a 10 megabit al secondo (Mbps) e l'algoritmo (CSMA / CD).

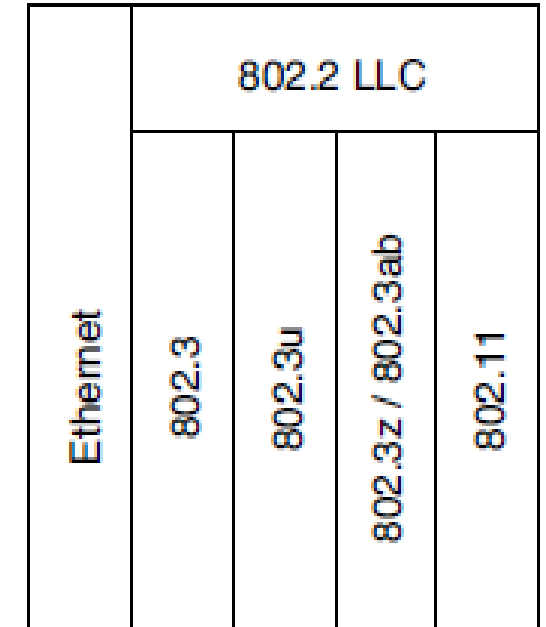
Fast Ethernet (a 100 Mbps): è coperto dalla specifica IEEE 802.3u e utilizza anche la tecnologia CSMA / CD.

Gigabit Ethernet (in esecuzione a 1 e 10 gigabit al secondo [Gbps]): è coperto dalle specifiche IEEE 802.3z, 802.3ab e 802.3ae e utilizza la tecnologia CSMA / CD.

Wireless LAN Standards (WLAN): sono definiti dalle specifiche IEEE 802.11 e sono in grado di raggiungere velocità fino a 600 Mbps secondo la specifica 802.11n. Le WLAN utilizzano un meccanismo CSMA / CA (*carrier sense multiple access collision avoidance*)(rispetto al meccanismo CSMA / CD utilizzato dagli standard Ethernet cablati).



OSI Model



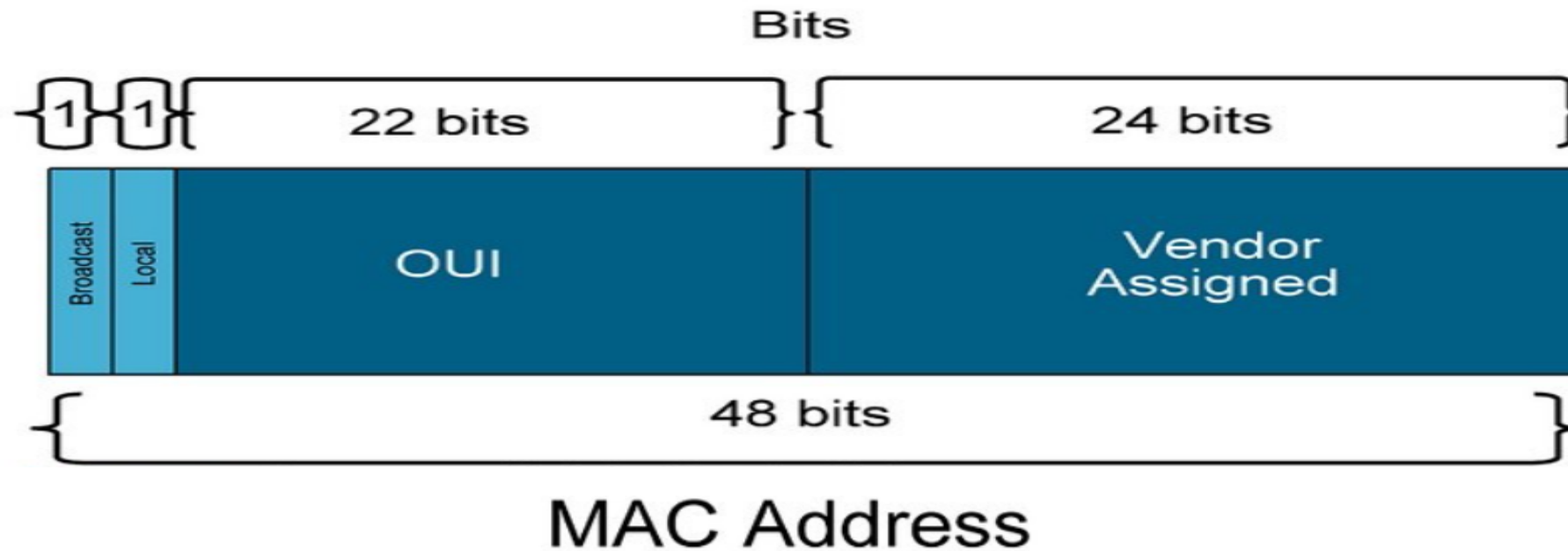
LANs

TCP/IP Networking

MAC Address

MAC (Media Access Control) , indirizzo a 48 bit (numero esadecimale a 12 cifre) assegnato a una scheda NIC (scheda di interfaccia di rete) in fase di costruzione della scheda. La prima metà di un indirizzo MAC è chiamata OUI (Organizationally Unique Identifier), ed è un valore assegnato dall'IEEE (Institute of Electrical and Electronics Engineers), che permette di identificare il costruttore di qualsiasi scheda NIC o interfaccia Ethernet.

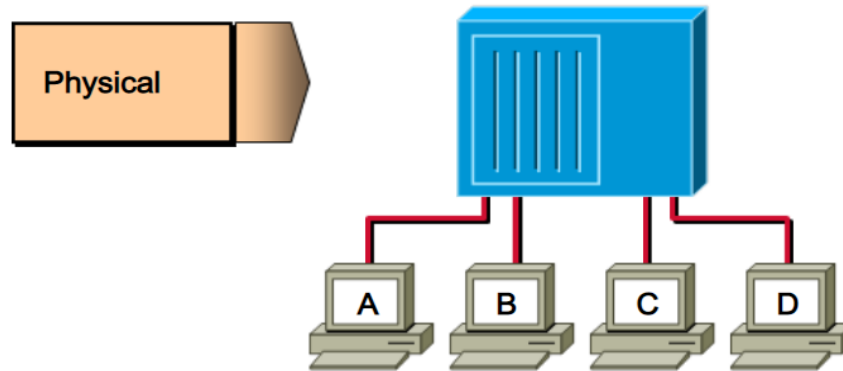
Ogni frame inviato da un host in rete include un indirizzo MAC di destinazione. Tutti gli host di una rete ignorano il frame a meno che l'indirizzo di destinazione dello stesso non coincida con il proprio.



TCP/IP Networking

Network Hardware

HUB



- Un hub è un dispositivo che consente di realizzare una LAN collegando più dispositivi in modo stellare.
- Gli hub possono essere collegati tra loro in cascata.
- Un hub lavora esclusivamente al livello **fisico** (livello 1 del modello OSI).

Sebbene la topologia della rete sia fisicamente a stella da un punto di vista logico essa risulta essere a bus in quanto tutto il traffico generato si propaga su tutti i segmenti della LAN stessa.

L'hub inoltra i dati in arrivo da una qualsiasi delle sue porte su tutte le altre, cioè in maniera diffusiva (broadcasting). Il segnale ricevuto viene elettricamente rigenerato.

Il dominio di collisione in una LAN realizzata tramite hub è l'intera rete.

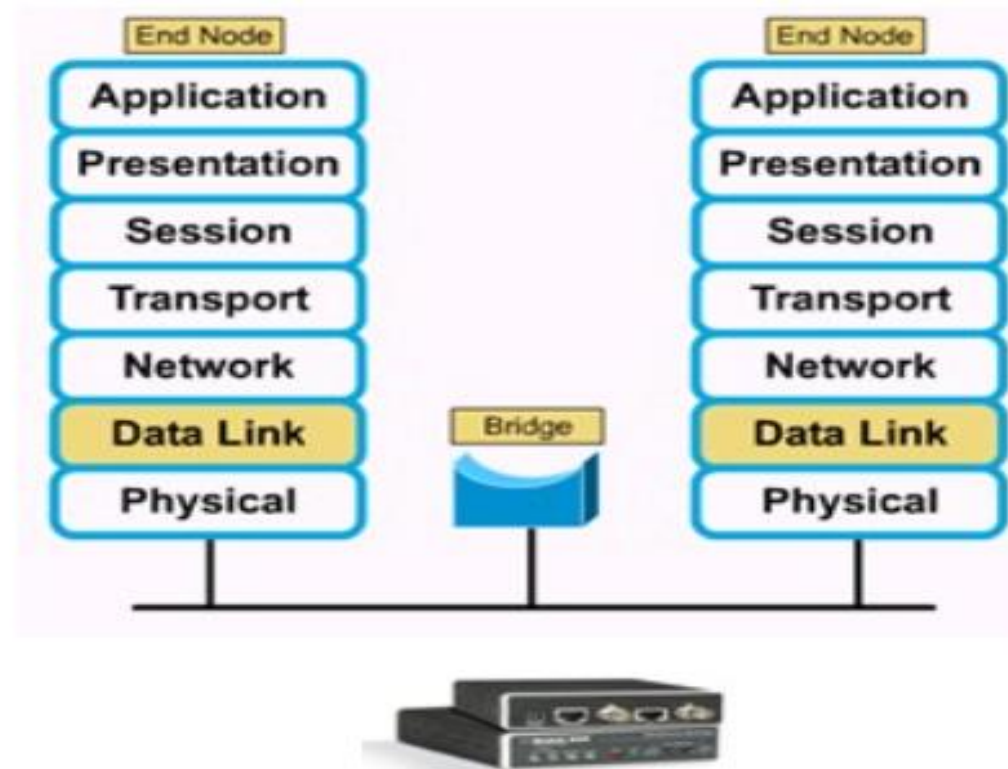
Attualmente gli hub sono praticamente in disuso, essendo sostituiti nella stragrande maggioranza dei casi dagli switch.

TCP/IP Networking

Network Hardware

BRIDGE

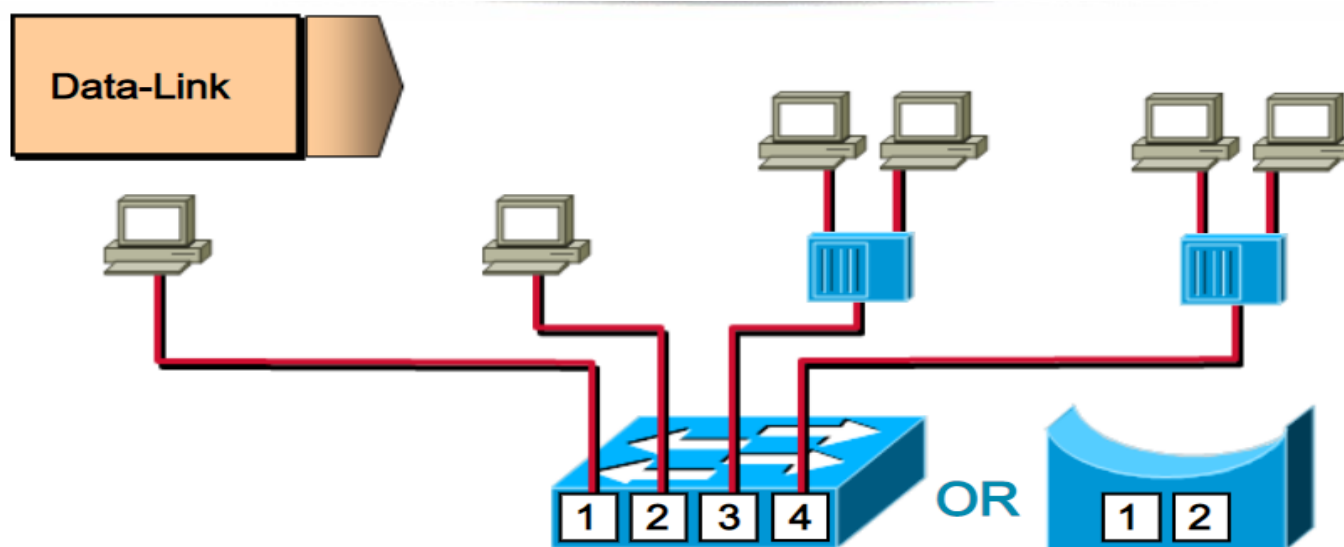
- Un bridge (letteralmente ponte) è un dispositivo in grado di collegare tra di loro due o più reti diverse (solitamente delle LAN) in modo che possano comunicare tra di loro. Esso si colloca al livello data link nel modello OSI. Il comportamento di un bridge è analogo a quello di uno switch.
- Un bridge è uno switch a due porte.



TCP/IP Networking

Network Hardware

SWITCH

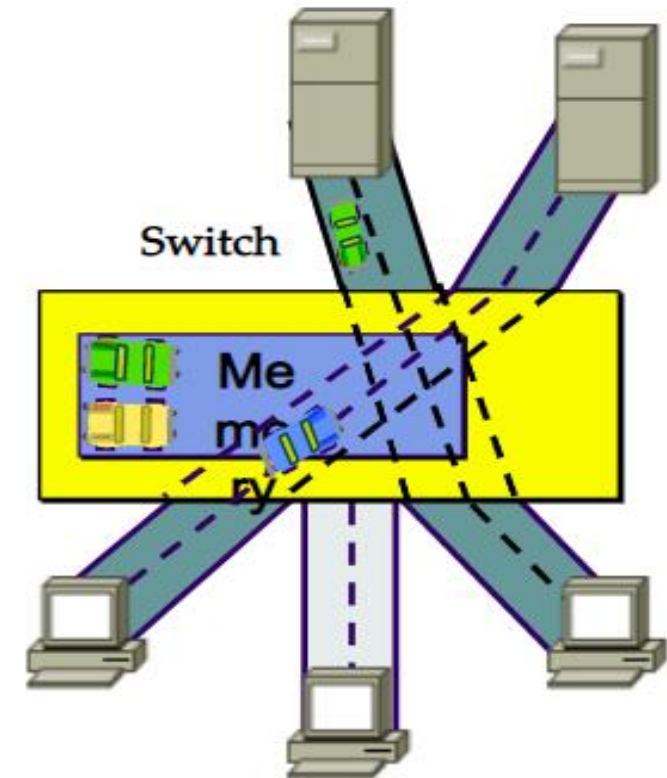
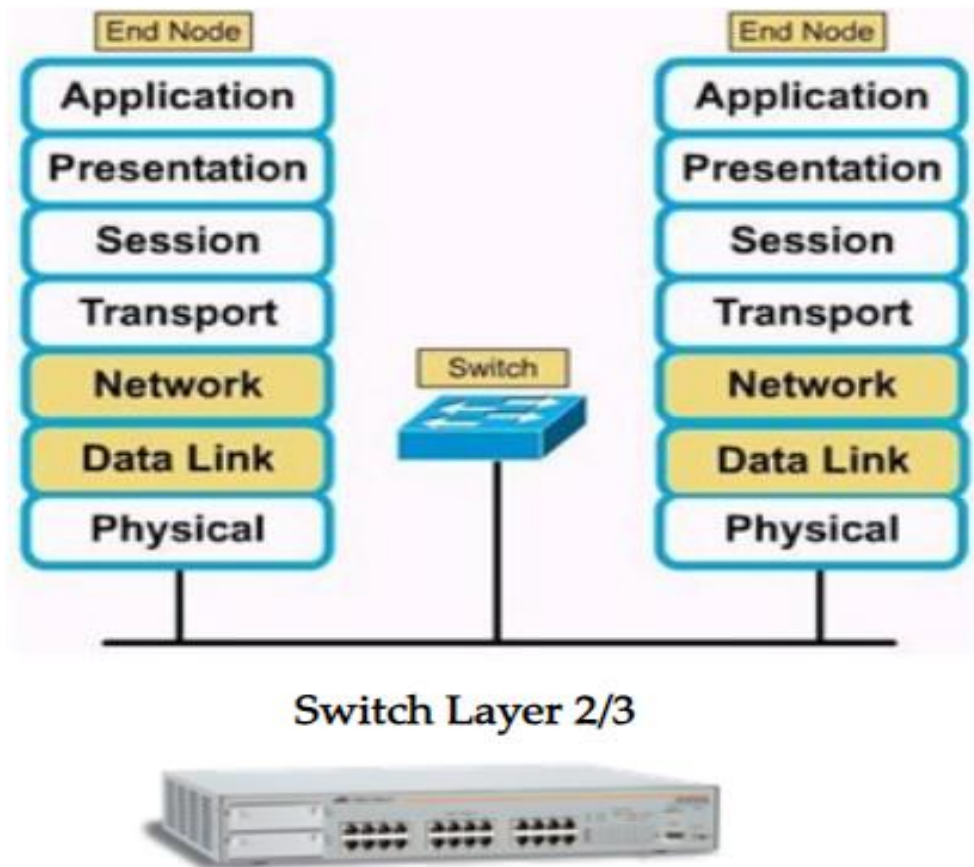


- Lo switch è un dispositivo in grado di instradare i pacchetti di dati in maniera point to point. Questo è possibile perché lo switch, al suo interno, ha una tabella di tutti gli indirizzi delle schede di rete collegate e quando gli arriva un pacchetto sa chi è il destinatario e lo invia solo a lui. Questo permette di risolvere il problema del broadcast che si verificava negli hub, risparmiando quindi notevole banda.

TCP/IP Networking

Network Hardware

SWITCH

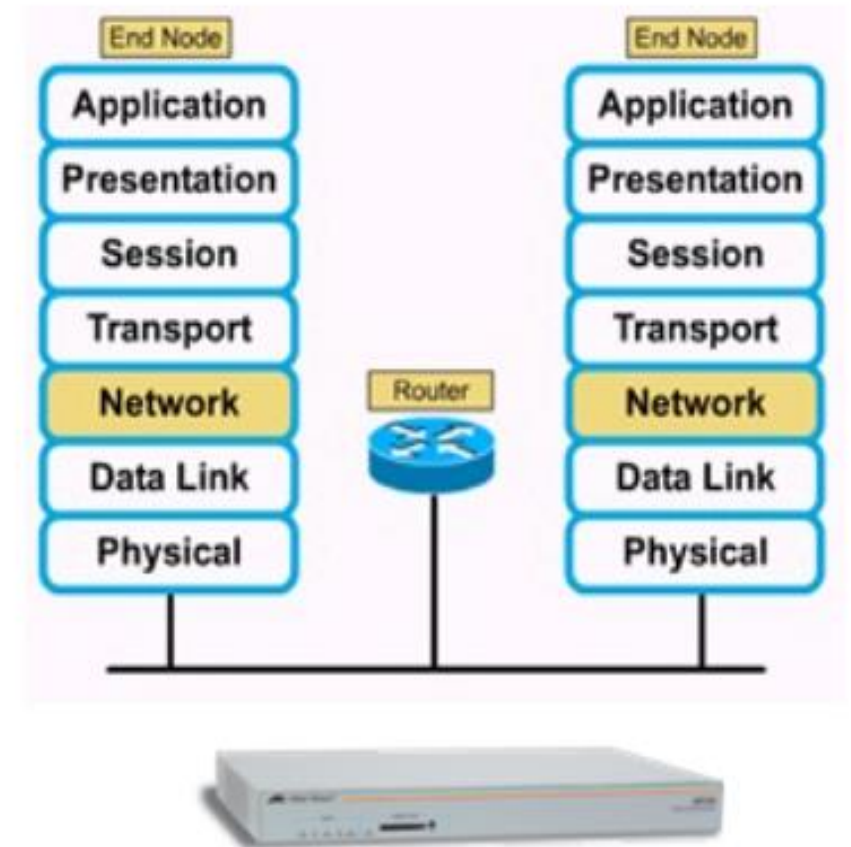


TCP/IP Networking

Network Hardware

ROUTER

- Lo scopo di un router è di esaminare i pacchetti entranti, scegliere il miglior percorso della rete per instradarli verso la destinazione.
- Routers lavorano a livello Network.
- Un router può connettere differenti reti o sottoreti.
- Un router connette:
 - LAN a LANs
 - LANs a WANs
 - WANs a WANs



TCP/IP Networking

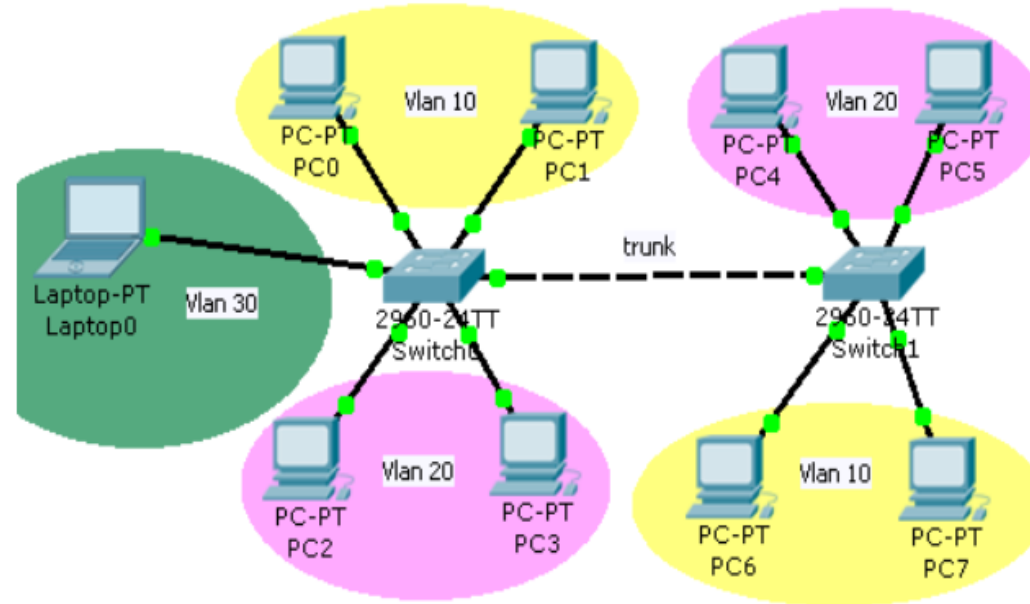
VLAN(Virtual LAN)

Le **VLAN** sono le **reti virtuali logiche** che possono separare grandi reti in reti più piccole. Questo può essere fatto per ridurre il traffico di trasmissione, migliorare le prestazioni della rete, scopi di sicurezza o separare i diversi reparti tra loro e per la flessibilità della rete.

La tecnologia della Virtual LAN permette di segmentare il dominio di broadcast di una LAN, suddividendola in più reti LAN Virtuali, isolate tra loro, ma che condividono la stessa infrastruttura fisica.

Le VLAN operano al livello 2 (il Data Link Layer) dello Stack ISO/OSI.

Ciascuna VLAN si comporta come una LAN separata dalle altre, e per la loro interconnessione si utilizza routing (livello 3).



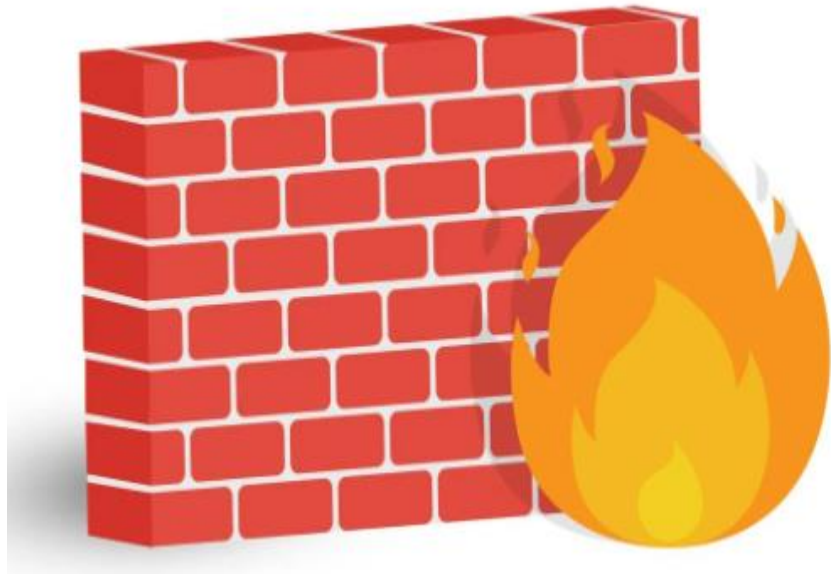
TCP/IP Networking

Firewall

Un firewall è un dispositivo per la sicurezza della rete che permette di monitorare il traffico in entrata e in uscita utilizzando una serie predefinita di regole di sicurezza per consentire o bloccare gli eventi.

Da oltre 25 anni, i firewall rappresentano la prima linea di difesa per la sicurezza della rete. Costituiscono una barriera tra le reti interne, sicure e controllate, e le reti esterne che possono essere affidabili o meno, come Internet.

Un firewall può essere costituito da un componente hardware, software o entrambi.



Firewall

Tipi di Firewall

- **Firewall proxy**

Uno dei primi tipi di dispositivi firewall sviluppati è il firewall proxy, che funge da gateway tra le reti per una specifica applicazione. I server proxy possono offrire funzionalità aggiuntive come il caching e la protezione dei contenuti che impediscono connessioni dirette dall'esterno della rete. Questa soluzione può tuttavia avere ripercussioni sulla velocità di trasmissione e sulle applicazioni supportate.

- **Firewall Stateful Inspection**

Il firewall Stateful Inspection, oggi considerato un tipo di firewall "tradizionale", consente o blocca il traffico secondo regole basate sullo stato, sulle porte e sul protocollo. Monitora tutta l'attività dal momento in cui viene stabilita una connessione fino alla sua chiusura. L'applicazione del filtro viene decisa sulla base delle regole definite dall'amministratore e del contesto, ovvero su informazioni relative a connessioni precedenti e pacchetti appartenenti alla stessa connessione.

Firewall

Tipi di Firewall

- **Firewall Unified Threat Management (UTM)**

Un dispositivo UTM in genere combina, senza una correlazione diretta, le funzioni di un firewall Stateful Inspection con le funzionalità di prevenzione delle intrusioni e dell'antivirus. Può anche includere servizi aggiuntivi e spesso prevede la gestione tramite cloud. I firewall UTM sono concepiti per garantire semplicità e facilità di utilizzo.

- **Next-Generation Firewall (NGFW)**

Oggi i firewall non si limitano più al filtro dei pacchetti e all'esecuzione di Stateful Inspection. La maggior parte delle aziende utilizza soluzioni Next-Generation Firewall per bloccare le minacce più recenti come il malware avanzato e gli attacchi a livello di applicazione.

Un Next-Generation Firewall deve avere le seguenti caratteristiche:

- Funzionalità firewall standard, come la stateful inspection
- Prevenzione delle intrusioni integrata
- Riconoscimento e controllo delle applicazioni per individuare e bloccare le app pericolose
- Percorsi di aggiornamento per includere feed di informazioni futuri
- Tecniche per far fronte alle minacce alla sicurezza in costante evoluzione

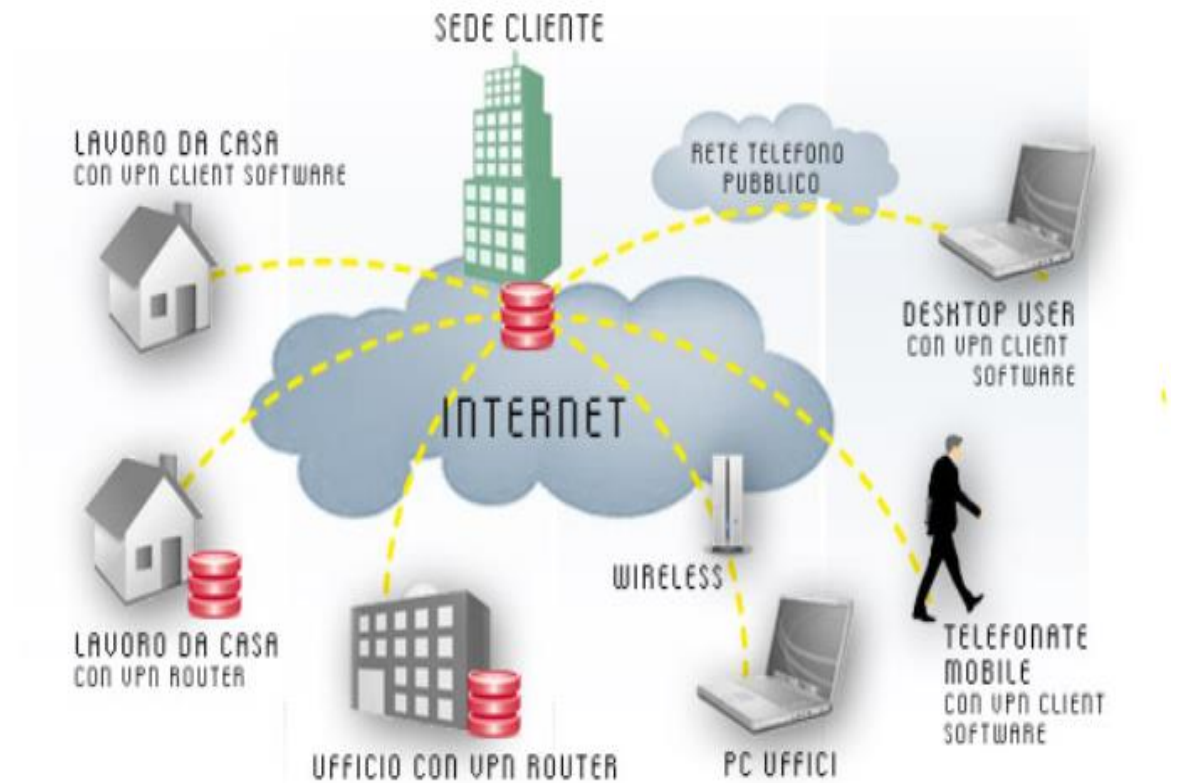
TCP/IP Networking

VPN (Virtual Private Network)

Una VPN è un servizio che crea una connessione crittografata dal tuo dispositivo a un server VPN tramite la tua connessione Internet.

Per proteggere il traffico di rete tra siti e utenti, le organizzazioni utilizzano reti private virtuali (VPN) per creare connessioni di rete private end-to-end. Una VPN è virtuale in quanto trasporta le informazioni all'interno di una rete privata, ma tali informazioni vengono effettivamente trasportate su una rete pubblica. Una VPN è privata in quanto il traffico è crittografato per mantenere riservati i dati mentre vengono trasportati attraverso la rete pubblica.

La figura mostra una raccolta di vari tipi di VPN gestite dal sito principale di un'azienda. Il tunnel consente ai siti e agli utenti remoti di accedere in modo sicuro alle risorse di rete del sito principale.



TCP/IP Networking

VPN (Virtual Private Network)

Vantaggi della VPN

Le VPN moderne ora supportano funzionalità di crittografia, come IPsec (Internet Protocol Security) e VPN SSL (Secure Sockets Layer) per proteggere il traffico di rete tra i siti.

Beneficio	Descrizione
Risparmi	Con l'avvento di tecnologie convenienti e ad alta larghezza di banda, le organizzazioni possono utilizzare le VPN per ridurre i costi di connettività aumentando allo stesso tempo la larghezza di banda della connessione remota.
Sicurezza	Le VPN forniscono il massimo livello di sicurezza disponibile, utilizzando protocolli avanzati di crittografia e autenticazione che proteggono i dati da accessi non autorizzati.
Scalabilità	Le VPN consentono alle organizzazioni di utilizzare Internet, semplificando l'aggiunta di nuovi utenti senza l'aggiunta di infrastrutture significative.
Compatibilità	Le VPN possono essere implementate su un'ampia varietà di opzioni di collegamento WAN, comprese tutte le più diffuse tecnologie a banda larga. I lavoratori remoti possono sfruttare queste connessioni ad alta velocità per ottenere un accesso sicuro alle loro reti aziendali.

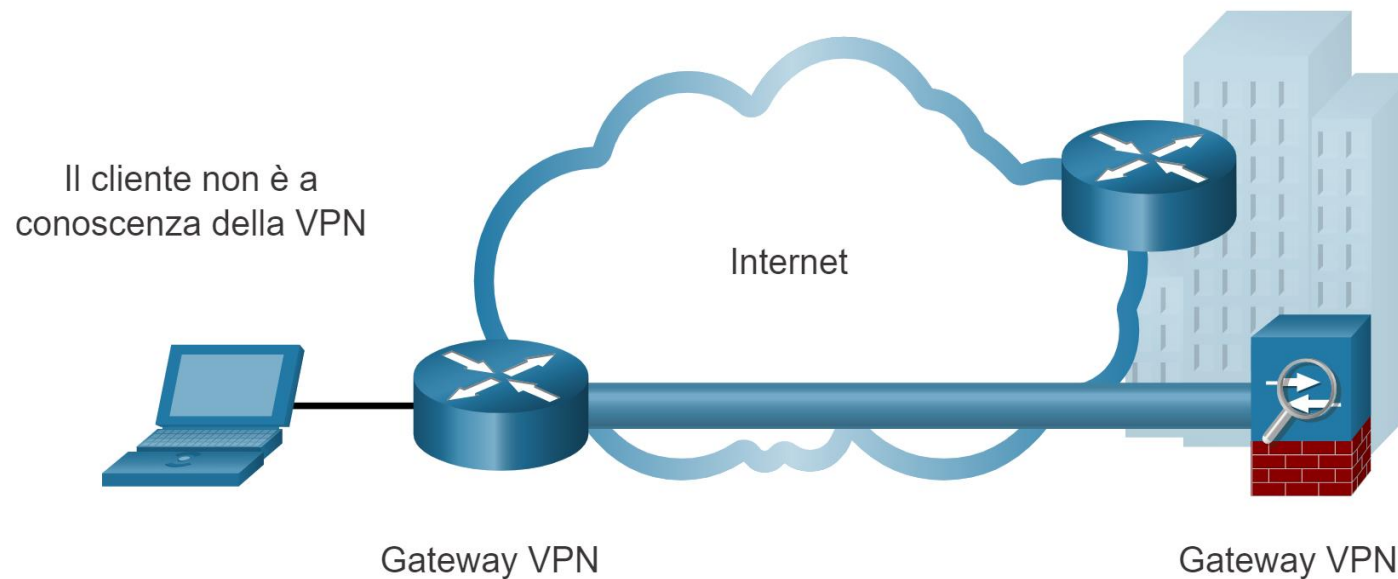
TCP/IP Networking

VPN (Virtual Private Network)

VPN da sito a sito

Le VPN vengono comunemente distribuite in una delle seguenti configurazioni: da sito a sito o accesso remoto.

Una VPN da sito a sito viene creata quando i dispositivi di terminazione VPN, chiamati anche gateway VPN, sono preconfigurati con informazioni per stabilire un tunnel sicuro. Il traffico VPN è crittografato solo tra questi dispositivi. Gli host interni non sanno che viene utilizzata una VPN.

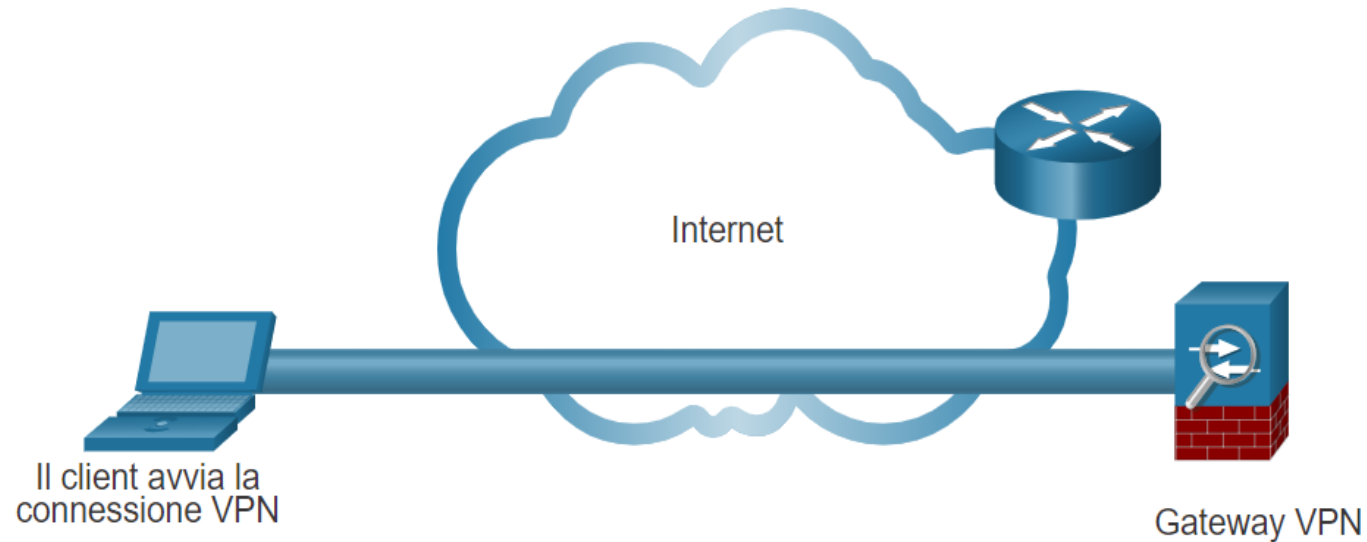


TCP/IP Networking

VPN (Virtual Private Network)

VPN ad accesso remoto

Una VPN ad accesso remoto viene creata dinamicamente per stabilire una connessione sicura tra un client e un dispositivo di terminazione VPN. Ad esempio, una VPN SSL di accesso remoto viene utilizzata quando controlli le tue informazioni bancarie online.



TCP/IP Networking

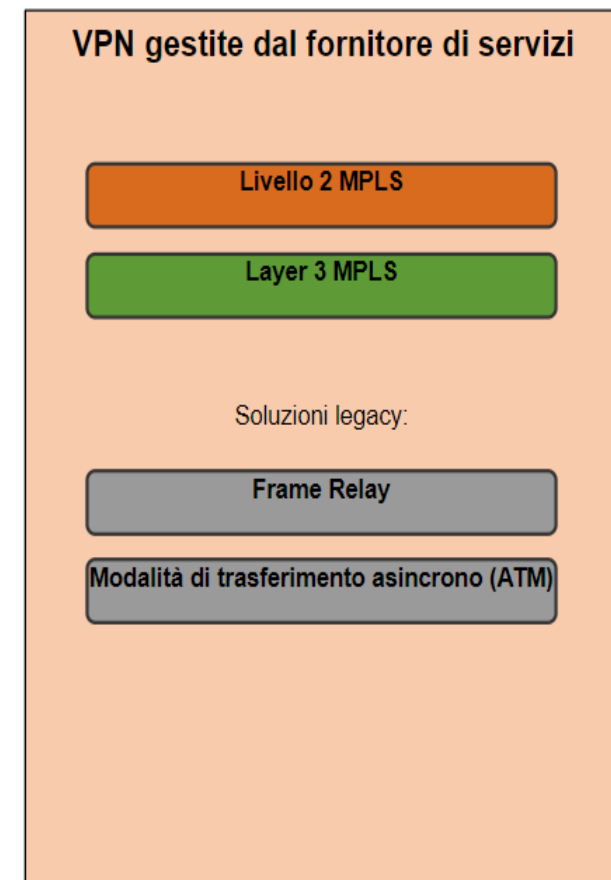
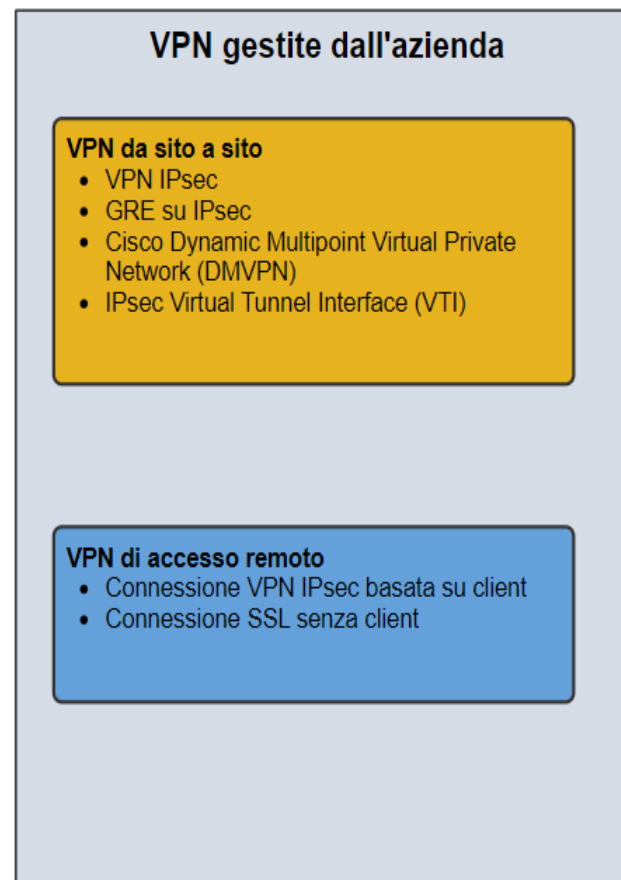
VPN (Virtual Private Network)

VPN aziendali e Service Provider

Sono disponibili molte opzioni per proteggere il traffico aziendale. Queste soluzioni variano a seconda di chi gestisce la VPN.

Le VPN possono essere gestite e implementate come:

- **VPN aziendali:** le VPN gestite dall'azienda sono una soluzione comune per proteggere il traffico aziendale su Internet. Le VPN site-to-site e di accesso remoto vengono create e gestite dall'azienda utilizzando sia IPsec che SSL VPN.
- **VPN del Service Provider:** le VPN gestite dal provider di servizi vengono create e gestite sulla rete del provider. Il provider utilizza Multiprotocol Label Switching (MPLS) a Layer 2 o Layer 3 per creare canali protetti tra i siti di un'azienda. MPLS è una tecnologia di routing utilizzata dal provider per creare percorsi virtuali tra i siti. Questo separa efficacemente il traffico dal traffico di altri clienti. Altre soluzioni legacy includono Frame Relay e VPN in modalità di trasferimento asincrono (ATM).

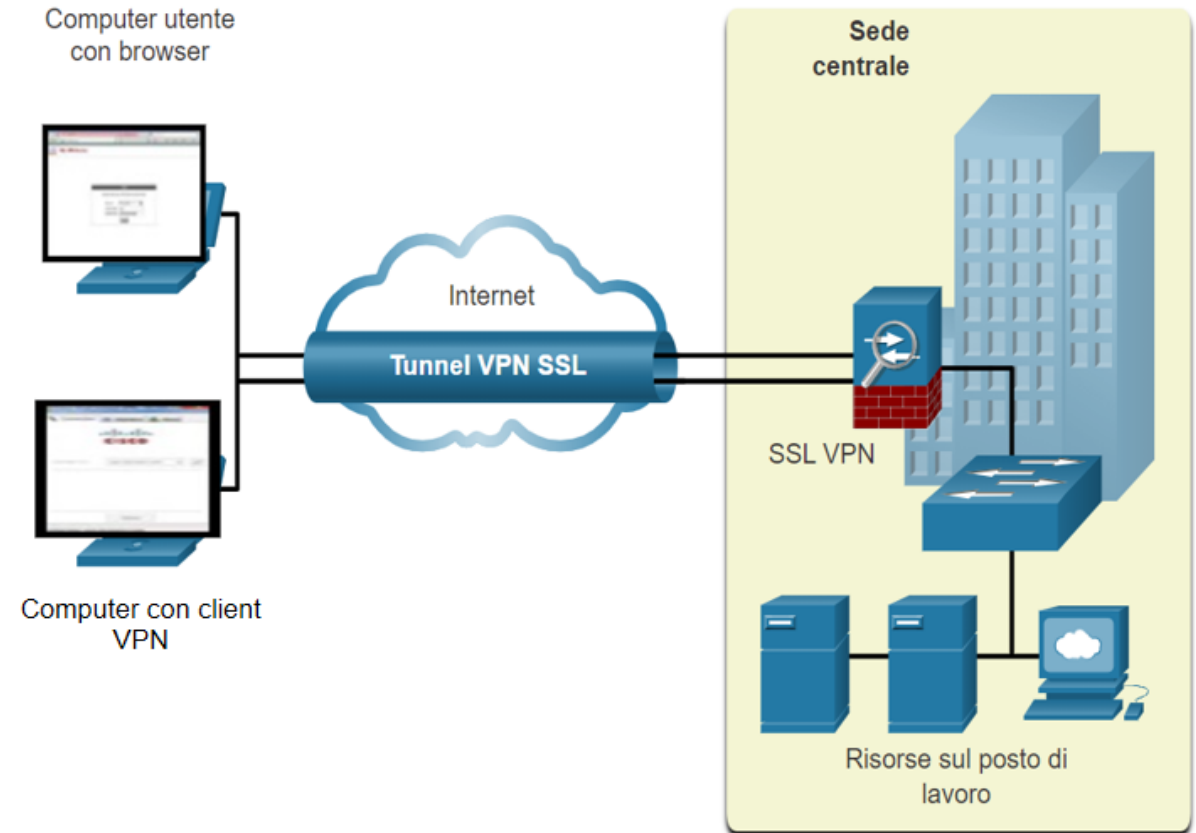


TCP/IP Networking

Tipi di VPN

VPN ad accesso remoto

- **Connessione VPN senza client** : la connessione è protetta tramite una connessione SSL del browser Web. SSL viene utilizzato principalmente per proteggere il traffico HTTP (HTTPS) e protocolli di posta elettronica come IMAP e POP3. Ad esempio, HTTPS è in realtà HTTP che utilizza un tunnel SSL. La connessione SSL viene prima stabilita, quindi i dati HTTP vengono scambiati sulla connessione.
- **Connessione VPN basata su client**: il software client VPN deve essere installato sul dispositivo finale dell'utente remoto. Gli utenti devono avviare la connessione VPN utilizzando il client VPN e quindi autenticarsi al gateway VPN di destinazione. Quando gli utenti remoti vengono autenticati, hanno accesso ai file e alle applicazioni aziendali. Il software client VPN crittografa il traffico utilizzando IPsec o SSL e lo inoltra su Internet al gateway VPN di destinazione.



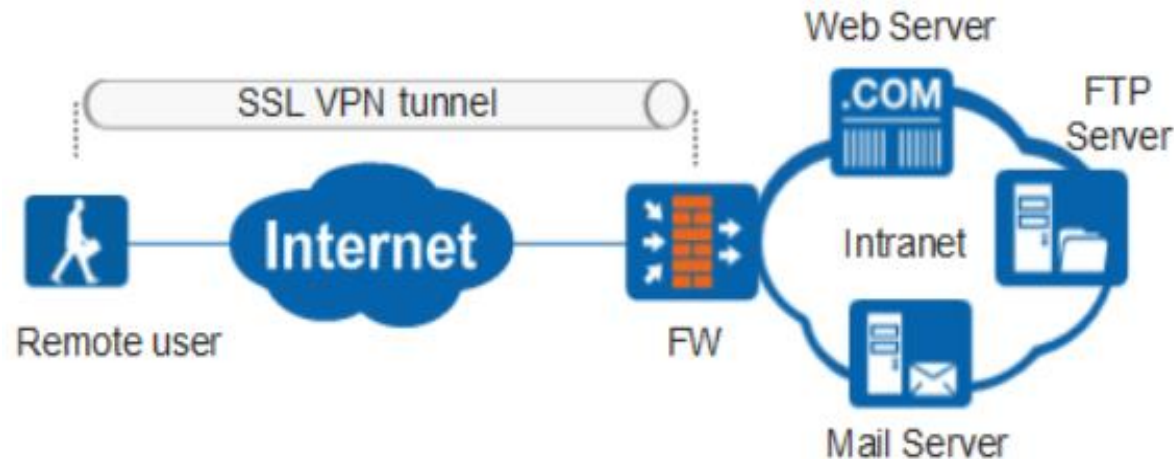
TCP/IP Networking

Tipi di VPN

VPN SSL

Quando un client negozia una connessione SSL VPN con il gateway VPN, si connette effettivamente utilizzando Transport Layer Security (TLS). TLS è la versione più recente di SSL e talvolta è espresso come SSL / TLS. Tuttavia, entrambi i termini sono spesso usati in modo intercambiabile.

SSL utilizza l'infrastruttura a chiave pubblica e certificati digitali per autenticare i peer. Entrambe le tecnologie IPsec e SSL VPN offrono l'accesso praticamente a qualsiasi applicazione o risorsa di rete. Tuttavia, quando la sicurezza è un problema, IPsec è la scelta migliore. Se il supporto e la facilità di implementazione sono i problemi principali, considera SSL. Il tipo di metodo VPN implementato si basa sui requisiti di accesso degli utenti e sui processi IT dell'organizzazione.



TCP/IP Networking

Tipi di VPN

VPN SSL

È importante capire che IPsec e SSL VPN non si escludono a vicenda. Sono invece complementari; entrambe le tecnologie risolvono problemi diversi e un'organizzazione può implementare IPsec, SSL o entrambi, a seconda delle esigenze dei propri telelavoratori.

Caratteristica	IPsec	SSL
Applicazioni supportate	Ampia : tutte le applicazioni basate su IP sono supportate.	Limitato : sono supportate solo le applicazioni basate sul Web e la condivisione di file.
Forza dell'autenticazione	Forte : utilizza l'autenticazione a due vie con chiavi condivise o certificati digitali.	Moderato : utilizzo dell'autenticazione unidirezionale o bidirezionale.
Forza della crittografia	Forte : utilizza lunghezze di chiave comprese tra 56 bit e 256 bit.	Da moderato a forte : con lunghezze della chiave da 40 bit a 256 bit.
Complessità di connessione	Medio : perché richiede un client VPN preinstallato su un host.	Basso : richiede solo un browser Web su un host.
Opzione di connessione	Limitato : possono connettersi solo dispositivi specifici con configurazioni specifiche.	Ampia : qualsiasi dispositivo con un browser Web può connettersi.

TCP/IP Networking

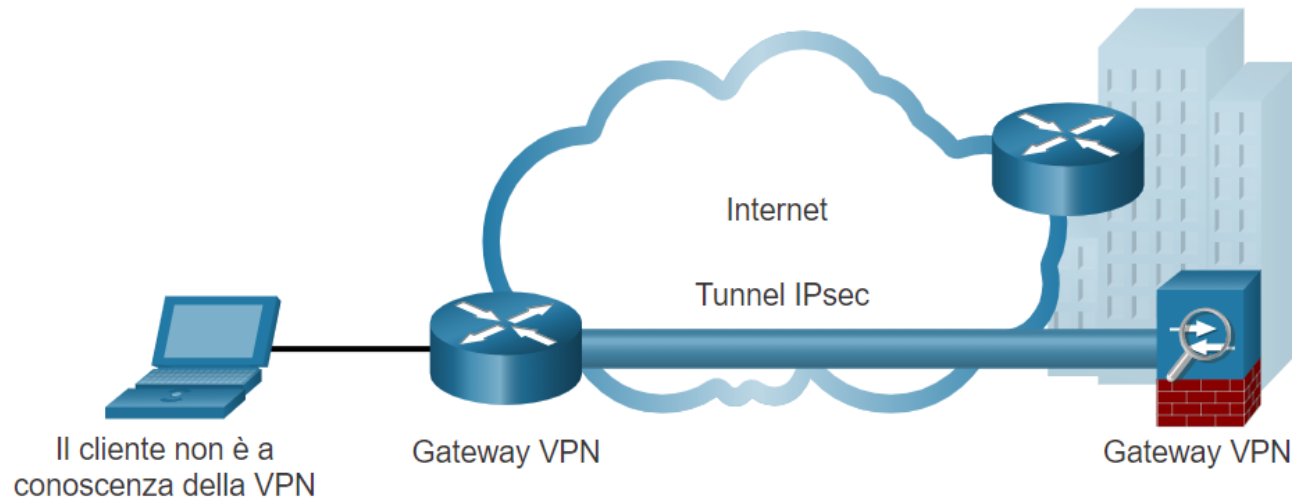
Tipi di VPN

VPN IPsec da sito a sito

Le VPN da sito a sito vengono utilizzate per connettere reti attraverso un'altra rete non attendibile come Internet. In una VPN da sito a sito, gli host finali inviano e ricevono il normale traffico TCP / IP non crittografato tramite un dispositivo di terminazione VPN. La terminazione VPN è generalmente chiamata gateway VPN. Un dispositivo gateway VPN potrebbe essere un router o un firewall.

Il gateway VPN incapsula e crittografa il traffico in uscita. Quindi invia il traffico attraverso un tunnel VPN su Internet a un gateway VPN nel sito di destinazione. Al ricevimento, il gateway VPN ricevente rimuove le intestazioni, decrittografa il contenuto e inoltra il pacchetto all'host di destinazione all'interno della sua rete privata.

Le VPN da sito a sito vengono in genere create e protette utilizzando la protezione IP (IPsec).



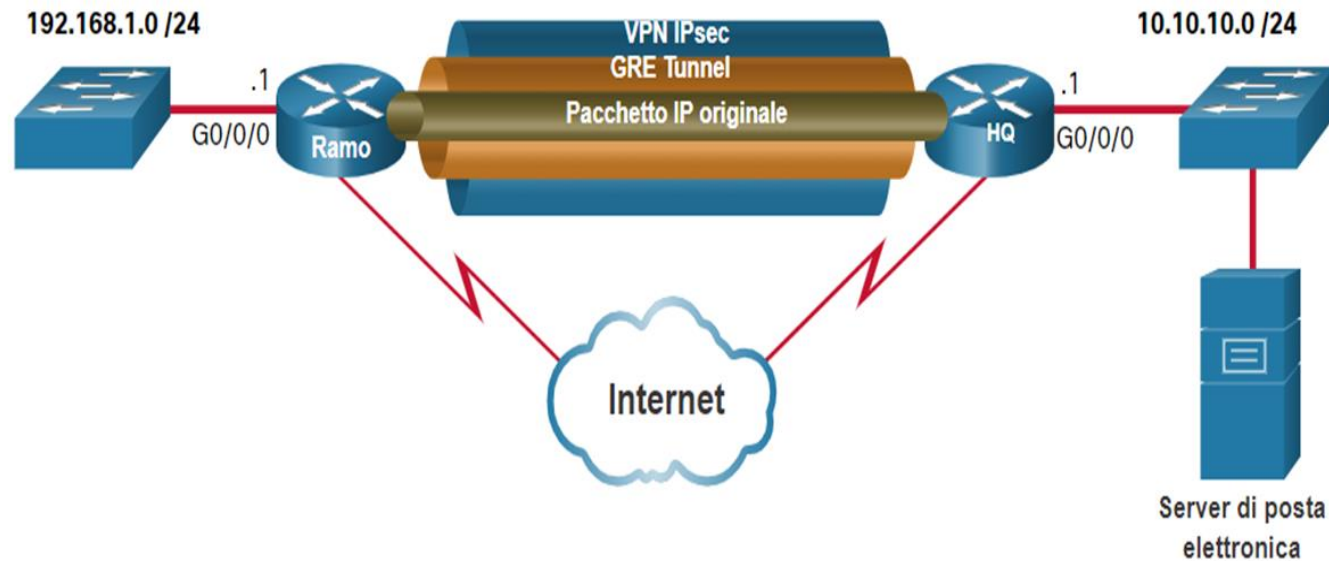
TCP/IP Networking

Tipi di VPN

GRE su IPsec

Generic Routing Encapsulation (GRE) è un protocollo di tunneling VPN da sito a sito non protetto. Può incapsulare vari protocolli di livello di rete. Supporta anche il traffico multicast e broadcast che potrebbe essere necessario se l'organizzazione richiede che i protocolli di routing operino su una VPN. Tuttavia, GRE non supporta la crittografia per impostazione predefinita; e quindi, non fornisce un tunnel VPN sicuro.

Una VPN IPsec standard (non GRE) può creare solo tunnel protetti per il traffico unicast. Pertanto, i protocolli di routing non scambieranno le informazioni di routing su una VPN IPsec.



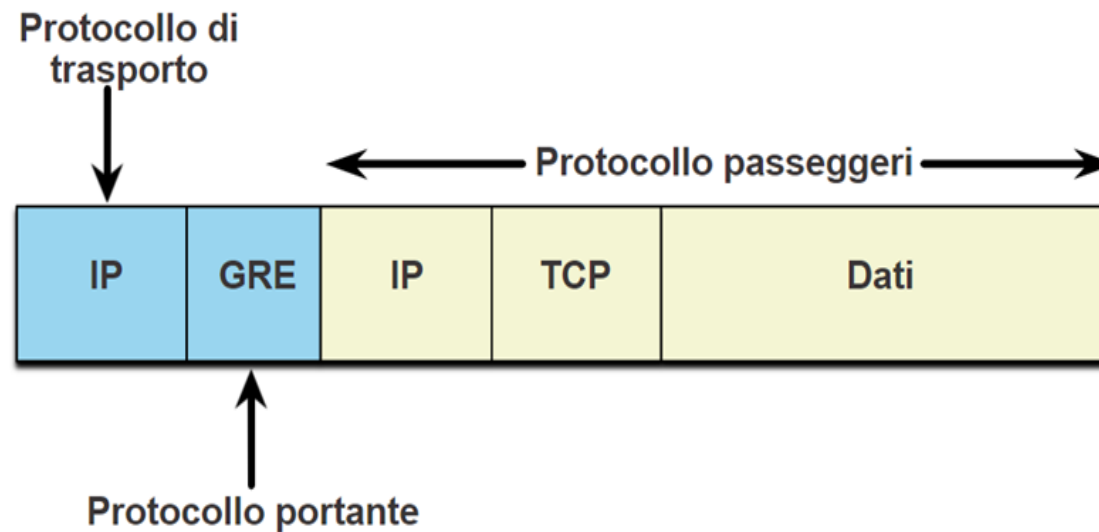
TCP/IP Networking

Tipi di VPN

GRE su IPsec

Per risolvere questo problema, possiamo incapsulare il traffico del protocollo di routing utilizzando un pacchetto GRE, quindi incapsulare il pacchetto GRE in un pacchetto IPsec per inoltrarlo in modo sicuro al gateway VPN di destinazione.

I termini utilizzati per descrivere l'incapsulamento di GRE su tunnel IPsec sono protocollo passeggeri, protocollo del vettore e protocollo di trasporto.



TCP/IP Networking

Reti Cablate e Wireless

Reti Cablate

Le **reti cablate** risultano meno inclini a interruzioni di connessione e sono poco influenzate da fattori locali (muri, pavimenti, armadi, porte). Rispetto al wireless, dunque, l'**affidabilità** è più alta e anche la **velocità di connessione**. Inoltre il cavo è **sicuro** perché la connessione passa attraverso un mezzo fisico: se qualcuno volesse intercettare i dati, dovrebbe entrare fisicamente nella rete locale. D'altro canto la scalabilità di una rete cablata può non essere così semplice: presuppone una pianificazione e dei costi non indifferenti, considerando che già di per sé il costo di una connessione cablata è sempre maggiore di quella wireless. Infine, la scarsa mobilità di una **rete cablata** potrebbe creare problemi strutturali nel caso di integrazione con device e sensori senza fili

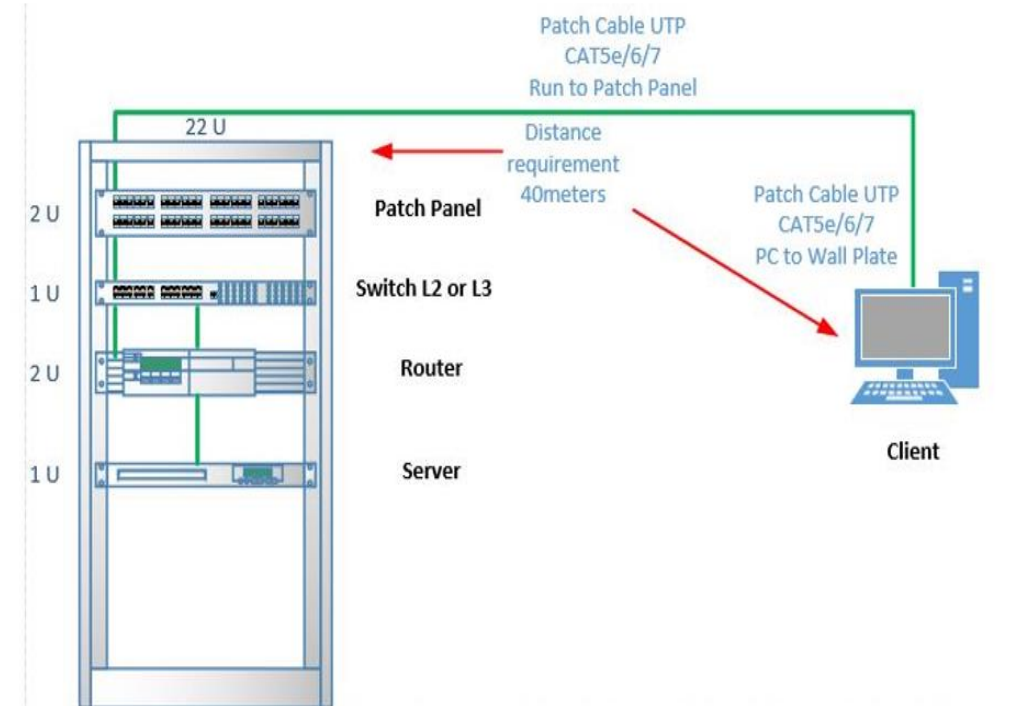


TCP/IP Networking

Reti Cablate

Componenti hardware della reti cablate

- Schede di rete
- Cavi Ethernet
- Switch, Router o Hub
- Server (file server, server di stampa ecc..)



TCP/IP Networking

Wireless

Le **reti wireless** sono, al contrario, facilmente **scalabili** perché richiedono installazioni e **configurazioni semplici e veloci**: l'estensione della rete è possibile perché la struttura in cui è implementata non rappresenta in alcun modo un ostacolo. Senza contare che sono anche molto **più economiche**: non si utilizzano cavi, quindi neanche lavori e manodopera. Di contro, una rete wireless è più soggetta alle interferenze causate dalla vicinanza di dispositivi elettronici e queste **interferenze di segnale** possono influire sulla velocità di trasmissione dati.



TCP/IP Networking

Wireless

Componenti WLAN

NIC Wireless



Router Domestico Wireless



Wireless Access Point



Antenne Wireless



TCP/IP Networking

Protocollo IPV6

IPv6 è la versione dell'Internet Protocol che succede a IPv4. Questo protocollo introduce alcuni nuovi servizi e semplifica molto la configurazione e la gestione delle reti IP.

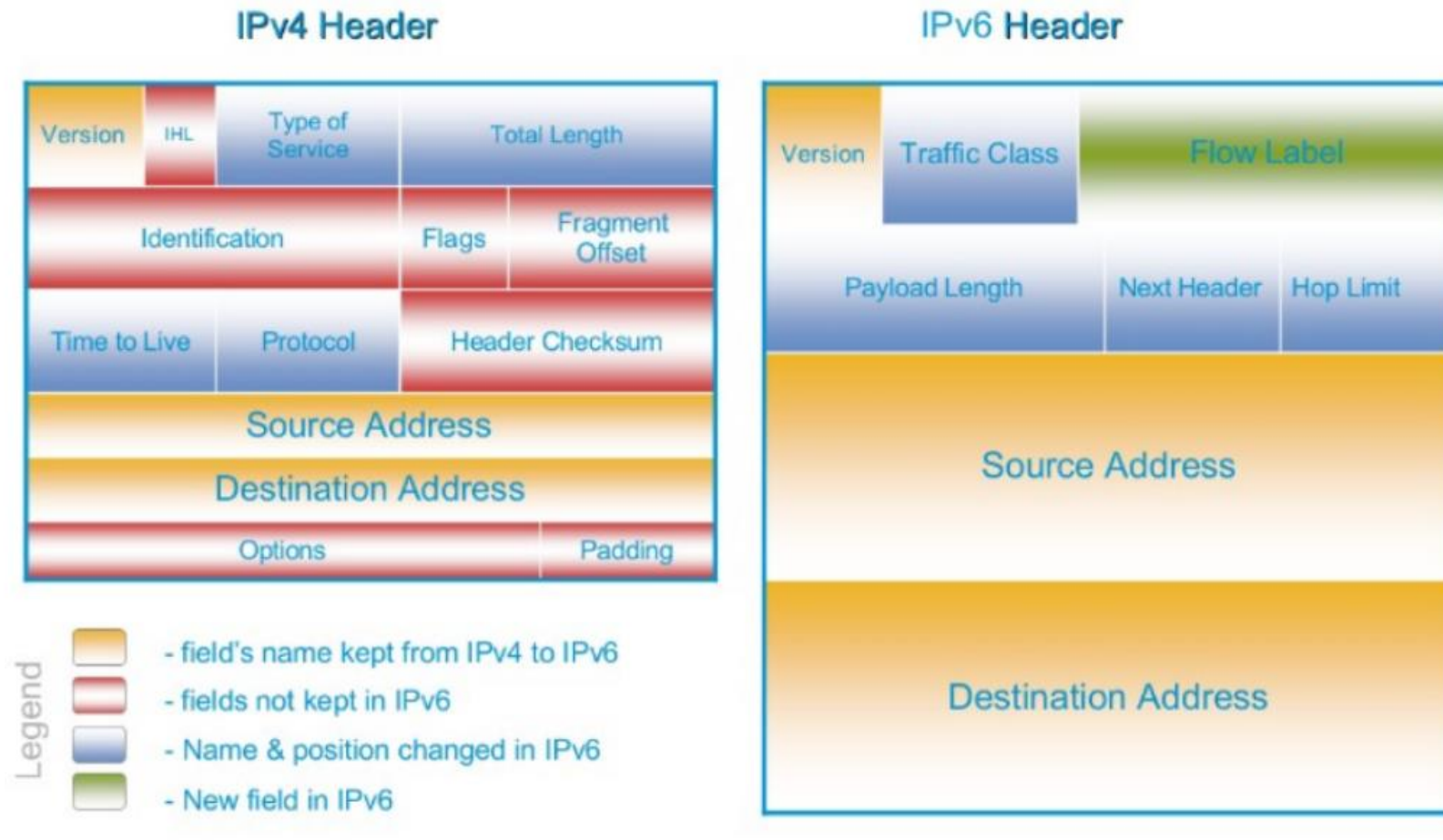
- IPv6 è un sistema a 128 bit rispetto ai 32 di IPv4 per cui
- IPv4 consente circa 4,3 miliardi di indirizzi
- IPv6 $3,4 * 10^{38}$ indirizzi
- IPv6 incorpora altri protocolli come l'ARP
- IPv6 configura automaticamente il gateway di default ed altri parametri.
- Supporta nativamente il QOS (Quality of Service)
- Introduce l'anycast che permette ad un host di raggiungere il più vicino server disponibile. (es. DNS).
- header di lunghezza fissa (40 byte);
- pacchetti non frammentabili dai router;
- eliminazione del campo checksum, ridondante perché presente in altri layer.

Queste ultime tre caratteristiche migliorano l'instradamento e il numero di pacchetti instradati al secondo dei router (throughput). Insieme all'IPv6 inoltre viene definito anche l'ICMPv6, molto simile all'ICMPv4.

TCP/IP Networking

Protocollo IPV6

Confronto fra i header IPV4 e IPV6



IPSec

E' uno standard per reti a pacchetto che si prefigge di ottenere connessioni sicure su reti IP. Tale sicurezza viene raggiunta attraverso l'aggiunta di funzionalità **di autenticazione, cifratura e controllo di integrità dei pacchetti IP** (datagrammi).

La capacità di fornire protezione o sicurezza viene dunque fornita a livello di rete (diversamente da HTTPS, SSL/TLS), fatto che rende questo protocollo trasparente al livello delle applicazioni che quindi non devono essere modificate.

IPsec è una collezione di protocolli formata da:

- Protocolli che implementano lo scambio delle chiavi per realizzare il flusso crittografato (il protocollo **IKE**)
- Protocolli che forniscono la cifratura del flusso di dati.

Esiste un solo protocollo per lo scambio delle chiavi, il protocollo IKE. IPsec è parte integrante di IPv6, mentre è opzionale in IPv4.

Per quanto riguarda il secondo aspetto, esistono due protocolli: **Authentication Header (AH)** e **Encapsulating Security Payload (ESP)**.

AH fornisce **autenticazione** e **integrità del messaggio**, ma non offre la riservatezza.

ESP fornisce invece **autenticazione, riservatezza e controllo di integrità** del messaggio. Per questi motivi ESP è molto più usato di AH.

TCP/IP Networking

IPSec

IPsec supporta due modalità di funzionamento, supportate sia da AH che da ESP:

Transport mode

- connessione host-to-host;
- usato dagli end-point, non dai gateway;
- in caso di cifratura, viene cifrato solo il payload dei datagrammi IP, non l'header;
- computazionalmente leggero;
- ogni host che vuole comunicare deve avere tutto il software necessario ad implementare IPsec;
- si aggiunge solo l'header IPsec; gli indirizzi mittente e destinatario degli end-point sono rilevabili.

Tunnel mode

- connessione gateway-to-gateway;
- in caso di cifratura, viene cifrato tutto il pacchetto IP originale;
- utilizzato per realizzare le VPN;
- computazionalmente oneroso;
- solo i gateway devono avere il software IPsec;
- si hanno punti di centralizzazione, quindi single point of failure;
- utilizza un doppio incapsulamento, ponendo come payload della comunicazione tra indirizzi gateway quanto si ottiene cifrando l'unione di indirizzi mittente e destinatario degli end-point col payload effettivo; adottando il protocollo ESP, gli indirizzi mittente e destinatario degli end-point non sono quindi più rilevabili (restano invece rilevabili adottando AH).

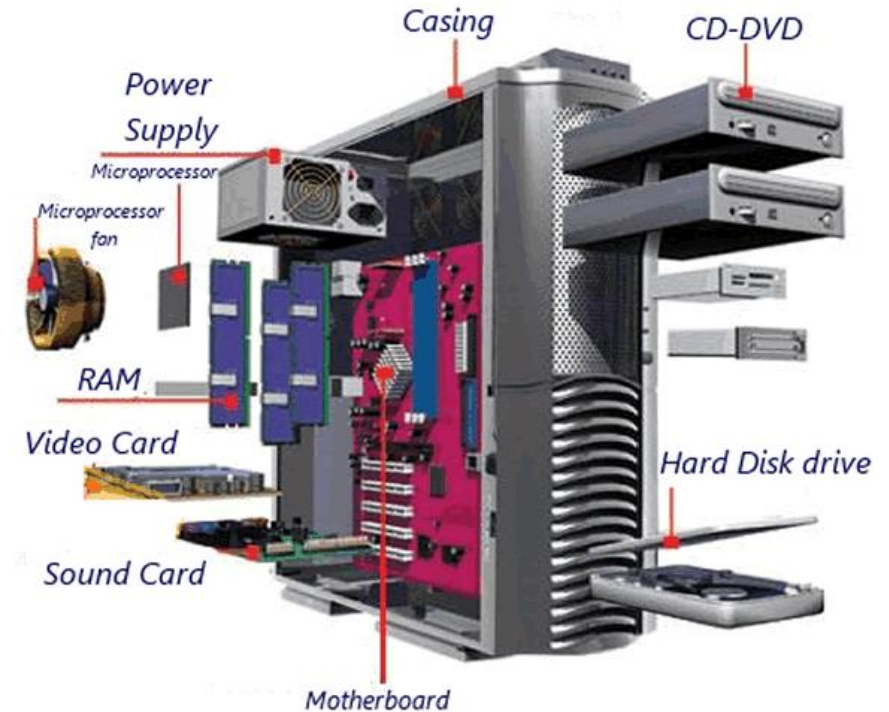
IPsec può essere utilizzato anche per connessioni tra gateway e host.

Computer Systems

Computer Systems

Componenti di un computer

- Software: Sistema operativo
- Firmware: software scolpito nell'hardware come scheda madre, schede grafiche, tastiere, stampanti, ecc...
- Hardware: CPU, memoria RAM e ROM, circuiti logici, dispositivi di archiviazione, dispositivi di input e output, component di sicurezza, bus, e component di networking
- Periferiche: stampanti, lettori ottici
- Controlli per l'interrelazione tra tutte le parti



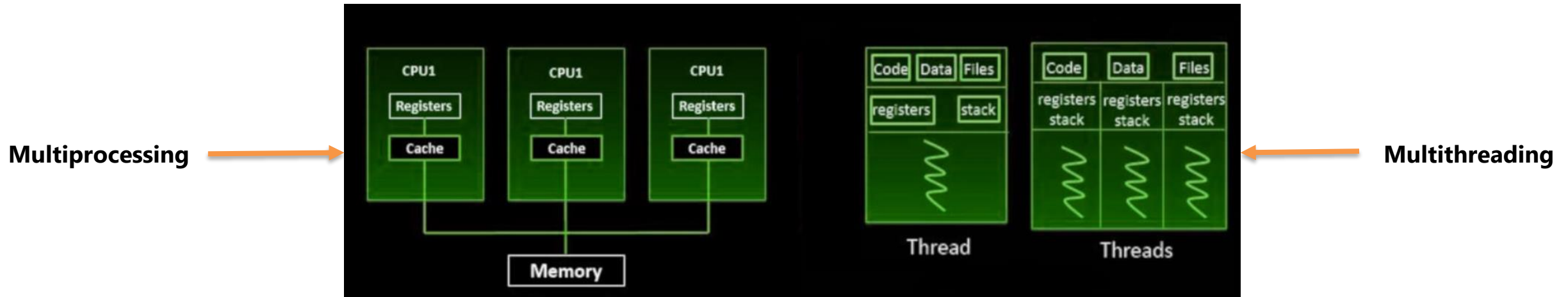
Computer Systems

Multitasking, multiprocessing, multithreading

Multitasking: capacità di esecuzione di compiti (task) multipli in modo simultaneo

Multiprocessing: l'elaborazione di più programmi per computer contemporaneamente, in particolare da un sistema informatico con due o più processori che condividono un'unica memoria

Multithreading: esecuzione di più di un thread nel sistema. Un thread può essere definito come un blocco o un'unità di un processo che può essere identificato come thread a livello di utente o thread a livello di kernel. Di solito viene utilizzato per le sue caratteristiche essenziali ovvero utilizza le risorse di sistema in modo efficiente, prestazioni elevate, molto reattivo e anche per la sua capacità di esecuzione parallela.



Computer o dispositivi dedicati

I dispositivi dedicati non sono come gli smartphone, che utilizziamo per più attività in un dato momento. Invece, i dispositivi dedicati hanno un insieme di funzioni molto specifico:

- usati per un caso d'uso singolo
- eseguono un numero limitato di app
- l'azienda è proprietaria del dispositivo
- sono persistenti e mission-critical: sempre attivi
- necessitano di controlli di sicurezza speciali o specifici

Device	Single Purpose
ATM	Cash Dispensing / Financial Transaction
Airport Kiosk	Flight check-in - Boarding Pass & Baggage claims
POS	Payment Acceptance
Delivery Device	Scanning Packages / Collecting Signatures

Internet of Things (IoT)

È il sistema di connessione dei cosiddetti **smart object**: computer, smartphone, tablet, ma soprattutto degli oggetti che ci circondano all'interno delle nostre case, al lavoro, nelle città, nella vita di tutti i giorni.

Nasce proprio qui: dall'idea di portare nel mondo digitale gli oggetti della nostra esperienza quotidiana.

Amplifica notevolmente i problemi associati al rischio, alle minacce e alle vulnerabilità poiché aumentano i punti di accesso non autorizzato a un qualunque dispositivo connesso in rete.

Anche i dispositivi IoT, di conseguenza, necessitano di misure di sicurezza speciali in quanto la maggior parte di essi non sono sicuri by design.

IoT – un attacco reale

Abbiamo assistito all'infezione a grande scala e improvvisa di dispositivi la cui sicurezza informatica non è mai stata contemplata e per i quali non esisteva un antivirus dedicato.

Questi dispositivi rintracciavano altri dello stesso tipo da poter contagiare e così questo esercito di zombie, chiamati a raccolta dal malware Mirai (che in giapponese significa "futuro") è diventato sempre più grande, in attesa di ricevere istruzioni.

Il 21 ottobre 2016 i proprietari di questa botnet gigante hanno deciso di mettere alla prova le potenzialità di questo esercito, facendo sì che milioni di registratori video digitali, router, fotocamere IP e altri dispositivi "intelligenti" bombardassero di richieste il fornitore di servizi DNS Dyn.

Dyn non ha potuto contrastare un attacco DDoS di tale portata; il DNS e altri servizi che vi si appoggiavano non erano più disponibili, e ciò ha avuto conseguenze importanti su piattaforme online molto popolari quali PayPal, Twitter, Netflix, Spotify, Playstation e altri servizi statunitensi. Dyn alla fine è riuscita a riprendersi, ma la veloce escalation di Mirai ha portato a riflettere sull'effettiva sicurezza dei dispositivi "smart".

Computer Systems

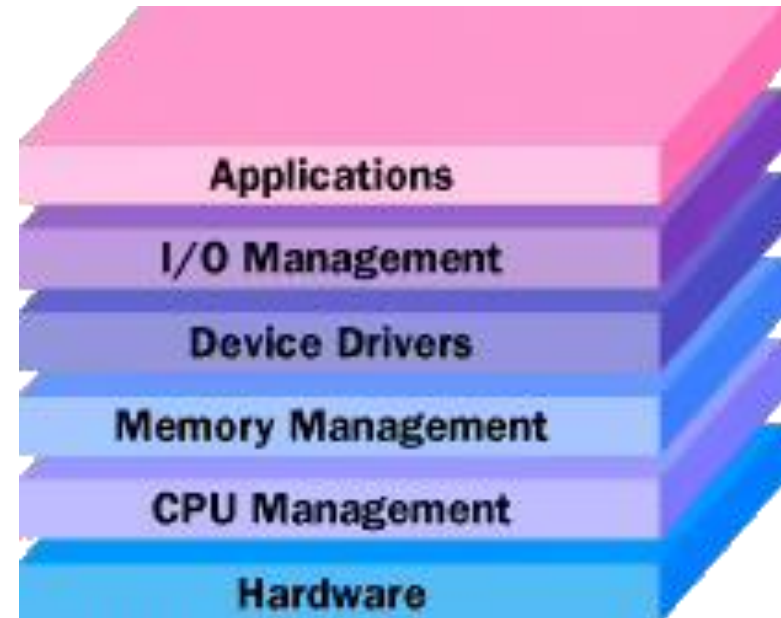
Il sistema operativo

Al livello più semplice, un sistema operativo fa due cose:

- gestisce le risorse hardware e software del sistema. In computer, tablet e smartphone queste risorse includono processori, memoria, spazio su disco e altro ancora.
- fornisce un modo stabile e coerente per le applicazioni di gestire l'hardware senza dover conoscerne tutti i dettagli.

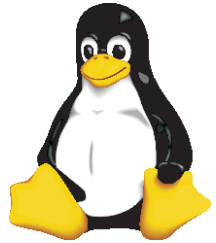
I compiti del sistema operativo, nel senso più generale, rientrano in diverse categorie:

- Gestione del processore
- Gestione della memoria
- Gestione dei dispositivi
- Gestione dell'archiviazione
- Interfaccia dell'applicazione
- Interfaccia utente
- Gestione della sicurezza del sistema



Computer Systems

Principali sistemi operativi



Unix/Linux

Linux è una famiglia di sistemi operativi open source simili a Unix basati sul kernel Linux, un kernel del sistema operativo rilasciato per la prima volta il 17 settembre 1991 da Linus Torvalds. Linux è in genere impacchettato in una distribuzione Linux.



Windows

Microsoft Windows, comunemente indicato come Windows, è un gruppo di diverse famiglie di sistemi operativi grafici proprietari, tutti sviluppati e commercializzati da Microsoft.



iOS / OS X

Mac OS X è un sistema operativo grafico basato su Unix con tecnologie sviluppate presso NeXT (dalla seconda metà degli anni '80 all'acquisto dell'azienda da parte di Apple alla fine del 1996) in combinazione con le tecnologie del sistema operativo "classico" di Apple e le tecnologie di FreeBSD. iOS è una versione speciale di Mac OS X dedicato a dispositivi smart (iPhone, AppleTV, iPod ecc...)

Principali sistemi operativi



Android

Android è un sistema operativo mobile basato su una versione modificata del kernel Linux e altri software open source, progettato principalmente per dispositivi mobili touchscreen come smartphone e tablet. Android è sviluppato da un consorzio di sviluppatori noto come Open Handset Alliance e sponsorizzato commercialmente da Google.



z/OS e z/VM

z/OS è un sistema operativo a 64 bit per mainframe IBM z/Architecture, introdotto da IBM nell'ottobre 2000. Deriva ed è il successore di OS/390, che a sua volta ha seguito una serie di versioni di MVS. z/OS ha gli attributi dei moderni sistemi operativi, ma conserva anche gran parte delle vecchie funzionalità originate negli anni '60 e ancora in uso regolare: z/OS è progettato per la compatibilità con le versioni precedenti.

z/VM è un hypervisor per la piattaforma *IBM System z (famiglia di mainframe IBM)* che fornisce un ambiente di test e produzione altamente flessibile.

Computer Systems

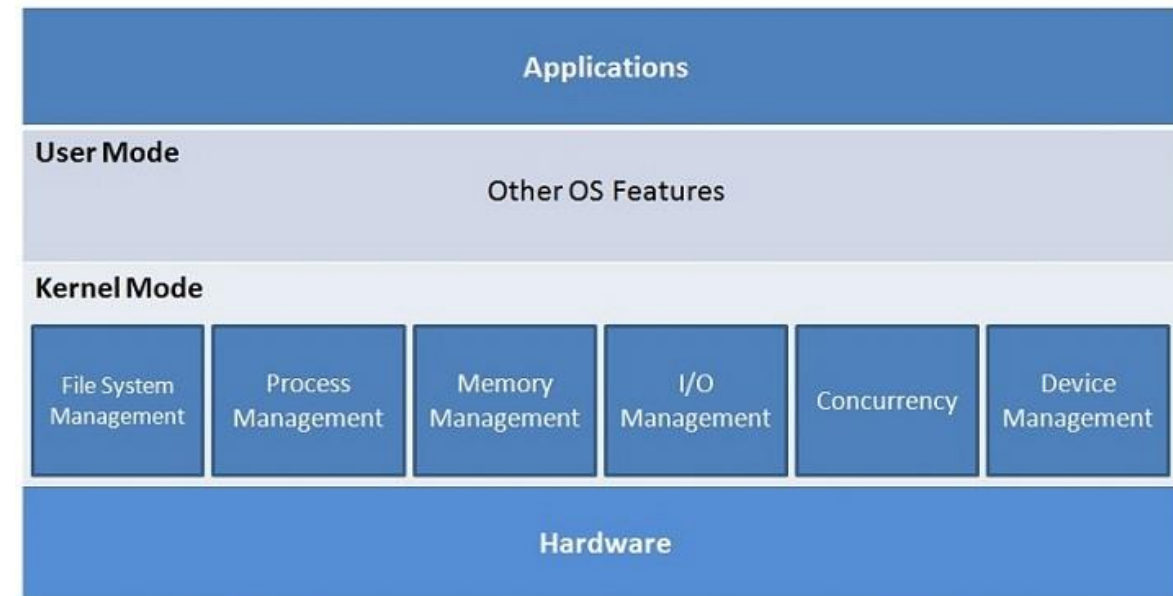
Architettura di un sistema operativo

Monolithic Kernel Architecture

In questa modalità, il sistema operativo viene eseguito in un unico spazio di indirizzi. Il kernel monolitico ha tutte le funzioni o i servizi del sistema operativo all'interno di un singolo kernel. Questo singolo kernel verrà eseguito come un singolo processo in un unico spazio di indirizzi in memoria. L'architettura monolitica consente prestazioni più elevate ma meno flessibile per le modifiche per aggiungere nuove funzionalità o migliorare le funzionalità esistenti.

Esempi:

- Windows 1, Windows 2, Windows 3, Windows 95, Windows 98, Windows ME
- All Linux distributions - CentOS, Ubuntu, Red Hat's Fedora, Red Hat Enterprise, Open SUSE and all other linux distributions
- Android uses a modified Linux Kernel



Monolithic Kernel Architecture

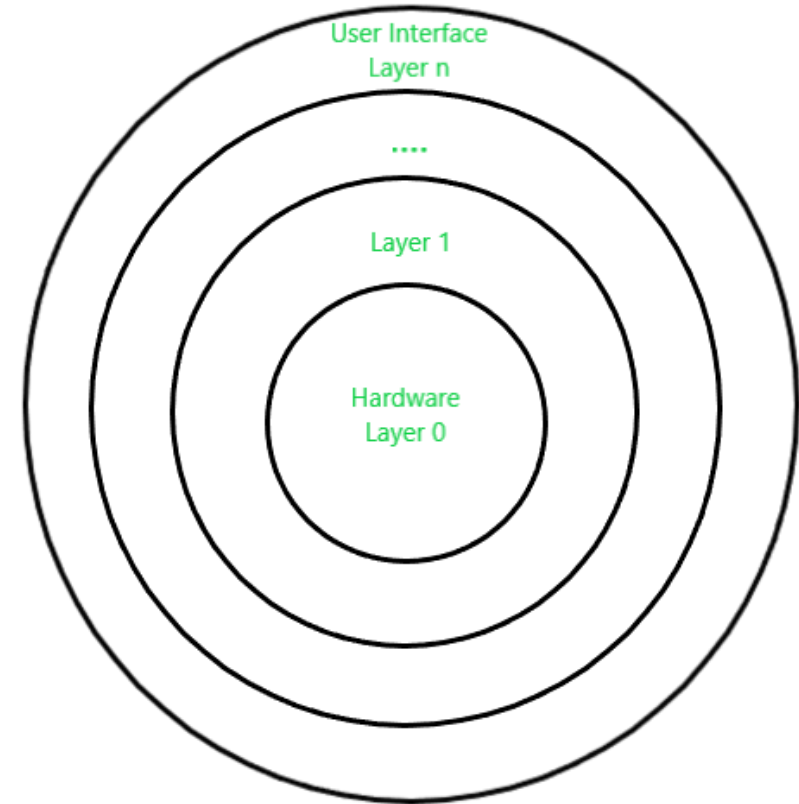
Architettura di un sistema operativo

Layered Kernel Architecture

La struttura a più livelli (layers) è un tipo di struttura di sistema in cui i diversi servizi del sistema operativo sono suddivisi in vari livelli, in cui ogni livello ha un compito specifico e ben definito da eseguire. Nasce per migliorare le strutture preesistenti come la Struttura Monolitica (UNIX) e la Struttura Semplice (MS-DOS).

L'intero sistema operativo è suddiviso in più livelli (da 0 a n) come mostra il diagramma. Ciascuno dei livelli deve avere la propria funzione specifica da svolgere. Ci sono alcune regole nell'implementazione dei livelli:

- il livello più esterno deve essere il livello dell'interfaccia utente.
- lo strato più interno deve essere il livello Hardware
- un particolare livello può accedere a tutti i livelli presenti al di sotto di esso ma non può accedere ai livelli presenti al di sopra di esso.



Architettura di un sistema operativo

Client/Server Architecture

Un **sistema operativo server** è un tipo di sistema operativo progettato e sviluppato per computer server, un computer di fascia alta con configurazioni avanzate. Si tratta di una versione avanzata del sistema operativo con caratteristiche e capacità richieste nell'architettura client-server o in un ambiente informatico aziendale simile.

Un **sistema operativo client** è un sistema operativo che funziona all'interno dei desktop dei computer e di vari dispositivi portatili. Questo sistema è diverso dai server centralizzati perché supporta solo un singolo utente. Qui, una macchina client è un piccolo computer con una configurazione hardware di base.

Caratteristiche base dell'architettura client/server

- Il client server computing funziona con un sistema di richiesta e risposta.
- Il client e il server devono seguire un protocollo di comunicazione comune in modo che possano interagire facilmente tra loro.
- Un server può ospitare solo un numero limitato di richieste client alla volta.

Computer Systems

Redundancy (RAID)

Redundant Array of Independent Drives

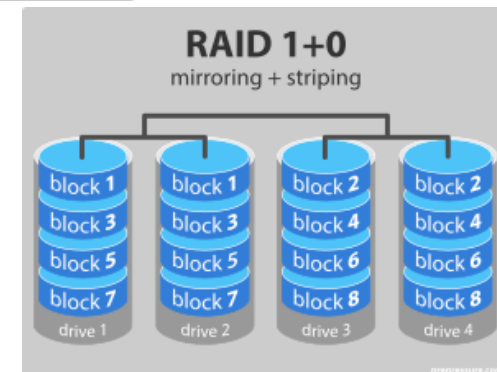
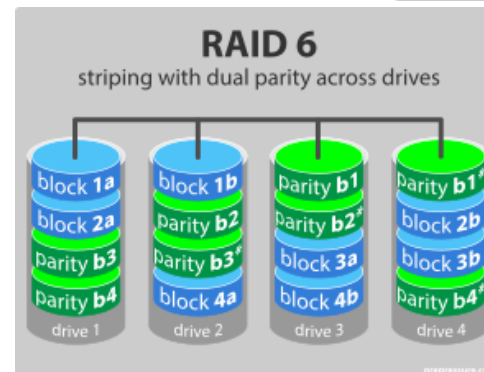
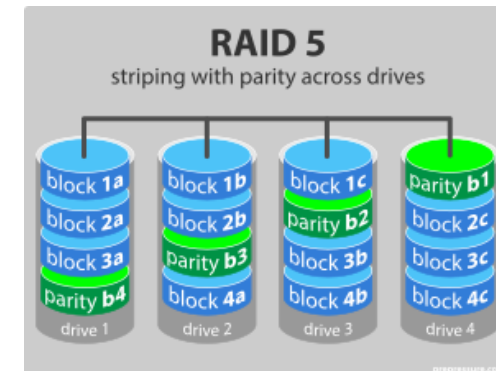
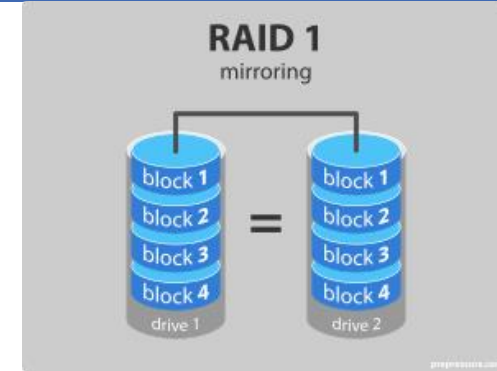
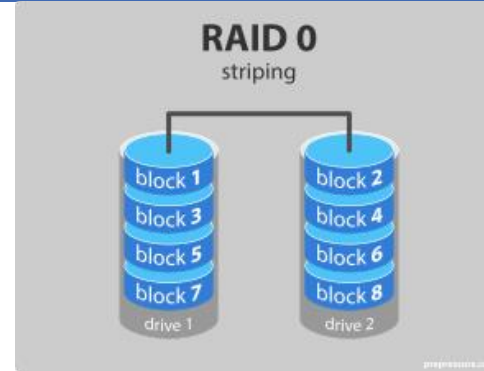
RAID è una tecnologia utilizzata per aumentare le prestazioni e/o l'affidabilità dell'archiviazione dei dati, che consiste nell'avere due o più drive che lavorano in parallel.

Esistono diversi livelli RAID, ciascuno ottimizzato per una situazione specifica. Questi non sono standardizzati da un gruppo industriale o da un comitato di standardizzazione. Questo spiega perché le aziende a volte escogitano numeri e implementazioni univoci.

Le modalità di connessione sono:

- Striping: i dati vengono suddivisi tra più dischi.
- Mirroring: i dati vengono sottoposti a mirroring tra più dischi.
- Parità: detta anche checksum. È un valore calcolato utilizzato per ricostruire matematicamente i dati.

È importante ricordare che RAID non è un backup, né sostituisce una strategia di backup.



Computer Systems

Redundancy (RAID)

RAID mode	Description	Operation	Advantages	Disadvantages	Recovery
RAID 0	Striped disks	Data is split evenly between two or more disks.	Large size and the fastest speed.	No redundancy.	If one or more drives fails, this results in array failure.
RAID 1	Mirrored disks	Two or more drives have identical data on them.	A single drive failure will not result in data loss.	Speed and size is limited by the slowest and smallest disk.	Only one drive is needed for recovery.
RAID 3	Striped set with dedicated parity	Data is split evenly between two or more disks, plus a dedicated drive for parity storage.	High speeds for sequential read/write operations.	Poor performance for multiple simultaneous instructions.	A single drive failure will rebuild.
RAID 5	Striped disks with distributed parity	Data is split evenly between three or more disks. Parity is split between disks.	Large size, fast speed, and redundancy.	The total array size is reduced by parity.	A single drive failure will rebuild.
RAID 10	1+0; Striped set of Mirrored Subset	Four or more drives are made into two mirrors that are striped.	Larger size and higher speed than RAID-1, and more redundancy than RAID-0.	No parity.	Only one drive in a mirrored set can fail.
JBOD	Just a Bunch Of Disks	Any number of drives are accessed independently by the operating system.	Software RAID modes can be used.	Hardware RAID may have better performance.	N/A
Big	Spanning or Concatenation	Data is written on one drive until it is full, and then the next drive(s) until it or they are full.	Creates a very large and simple array.	No redundancy.	N/A
Clone	RAID 1 + Spare	Two drives have identical data, plus one drive is used for rebuilding in case of a primary array failure.	Seamless operation when one drive fails in a RAID-1 array.	Spare drive is not accessible to the user.	Only one drive is needed for recovery.

Applications & Databases

Software Development Lifecycle

Sembra ovvio ma ottenere buoni risultati è piuttosto raro nel mercato della tecnologia.

- Uno studio dello Standish Group International sull'efficienza dei progetti IT ha rivelato che l'88% delle iniziative è in ritardo nei tempi previsti, nel qual caso il ritardo medio rispetto al programma iniziale è di un impressionante 222%.
- Considerando tutti i progetti che sono stati consegnati in ritardo e ad un costo più elevato, solo il 61% delle funzionalità inizialmente previste è stato consegnato correttamente ai clienti.
- Ogni software da sviluppare, semplice o complesso, richiede pianificazione e organizzazione
- Sviluppare software non consiste solo in scrivere del codice funzionante
- Analisi e progettazione, se fatte come si deve, permettono un'implementazione del software più consistente e più rapida

Applications & Databases

Software Development Lifecycle

Il ciclo di sviluppo software, indipendentemente dalla metodologia specifica utilizzata, è la sequenza delle fasi e dei processi da eseguire per la creazione di un software in tutte le sue funzionalità

Essendo una procedura molto variegata saranno coinvolte diverse figure professionali in ognuna delle sue fasi

Project Sponsor
Business Analyst
Project Manager
Product Owner
UX/UI Designer
Database Analyst
Technical Support

CTO
Frontend Engineer
Backend Engineer
Fullstack Engineer
DevOps Engineer
Quality Engineer
Security Engineer



Applications & Databases

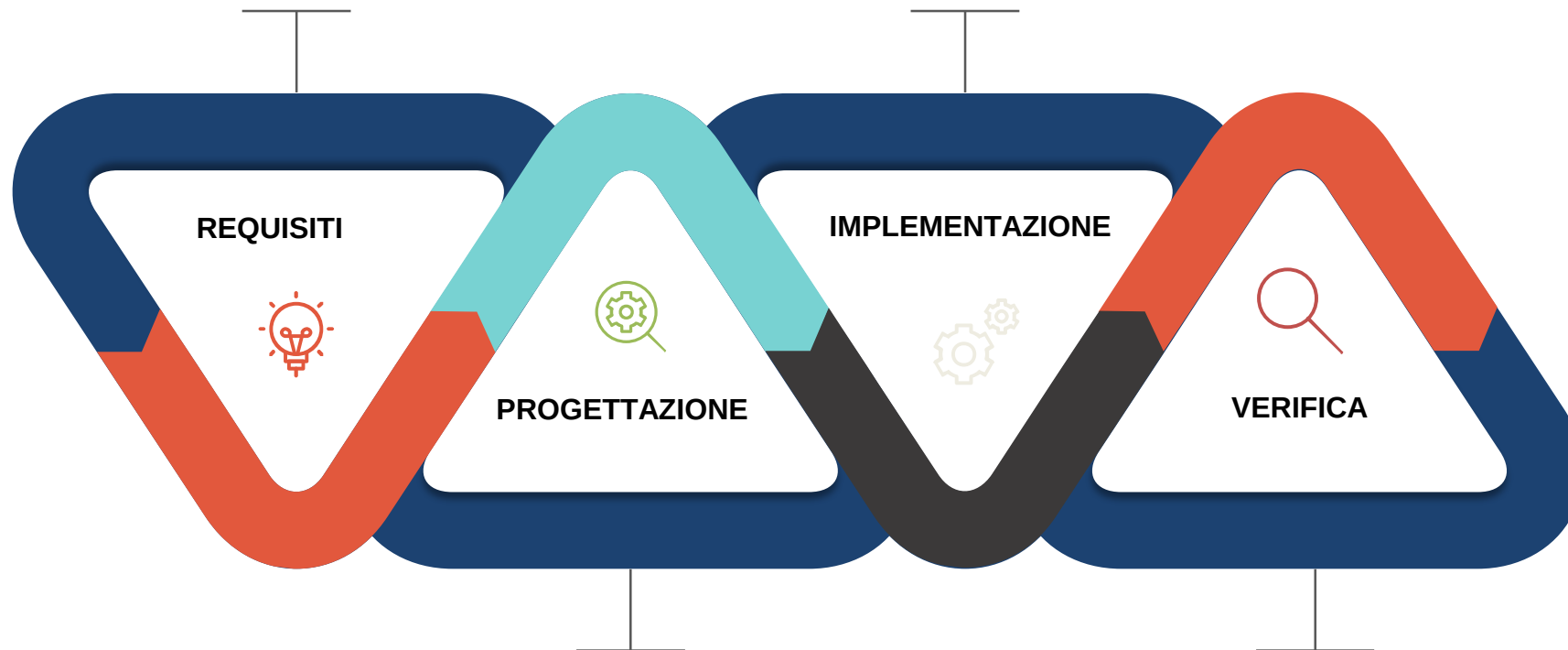
Secure SDLC

Bisogna avere in mente la sicurezza in ogni fase del ciclo di vita del software

Raccogliere non solo i requisiti funzionali
ma anche quelli non funzionali.

Mai dare per scontato funzionalità o controlli di sicurezza

Seguire Best Practices e coding standards



Iniziare ad aggiungere elementi di sicurezza già in fase di studio dell'architettura

Non limitarsi ai test di funzionalità ma approfondire utilizzando anche strumenti di analisi specifici (DAST, SAST)

Secure SDLC

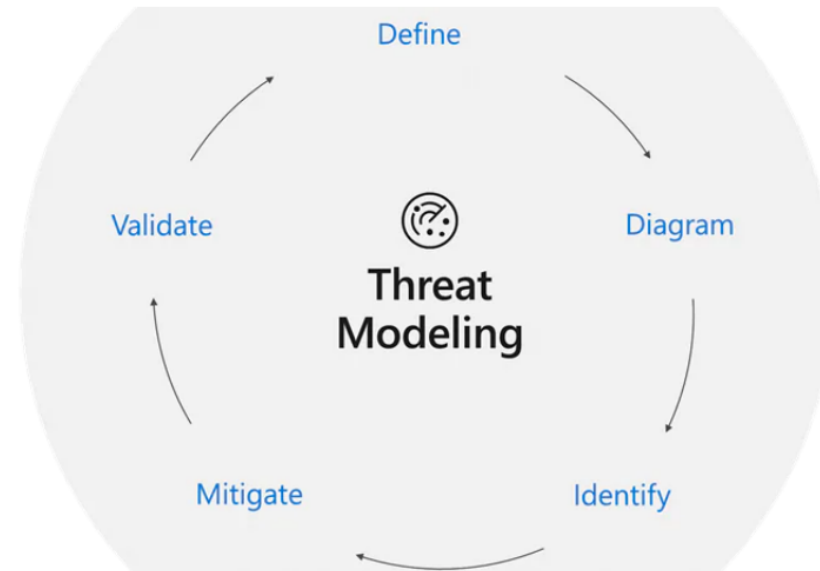
Principali problematiche di sicurezza nello sviluppo del software

- L'interfaccia utente non è ad alta sicurezza
- I dati di input sono analizzati male (attacchi di input non corretti)
- Il traffico di autenticazione non è crittografato
- Vengono utilizzati componenti con vulnerabilità note
- Vengono utilizzate tecniche di crittografia non chiare (o non standard)
- Le credenziali di autenticazione sono scritte nell'applicazione (cablate nel codice)
- Le dimensioni del buffer non vengono controllate (porta a buffer overflow)
- Problemi di sicurezza specifici dell'applicazione Web:
 - Comunicazione e cooperazione apolidi
 - Il lato client non è controllato
 - Tutta la sicurezza deve essere organizzata lato server

Applications & Databases

Secure SDLC

Secure Architecture



There are five major threat modeling steps:

- Defining security requirements.
- Creating an application diagram.
- Identifying threats.
- Mitigating threats.
- Validating that threats have been mitigated.

Threat modeling should be part of your routine development lifecycle, enabling you to progressively refine your threat model and further reduce risk.

Microsoft Threat Modeling Tool

The Microsoft Threat Modeling Tool makes threat modeling easier for all developers through a standard notation for visualizing system components, data flows, and security boundaries. It also helps threat modelers identify classes of threats they should consider based on the structure of their software design. We designed the tool with non-security experts in mind, making threat modeling easier for all developers by providing clear guidance on creating and analyzing threat models.

The Threat Modeling Tool enables any developer or software architect to:

- Communicate about the security design of their systems.
- Analyze those designs for potential security issues using a proven methodology.
- Suggest and manage mitigations for security issues.

Applications & Databases

Secure SDLC

Secure Coding



Nella fase di codifica, dobbiamo scegliere i costrutti di programmazione corretti per rendere il codice sicuro.



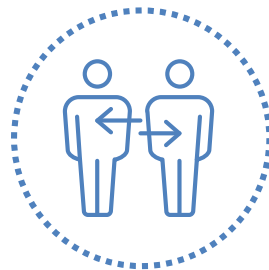
Il progetto CWE (Common Weakness Enumeration) di MITRE elenca oltre 900 punti deboli che i programmatori possono fare, alcuni dei quali sono molto oscuri.



Molti costrutti dipendono dal linguaggio di programmazione e dal framework che è stato scelto, ma la maggior parte di essi segue principi generali.



Quando si scrive codice, è importante sapere quali costrutti si dovrebbero usare e quali evitare. Di solito questo è specificato in cosiddetto Coding Standard.



Tuttavia, fidarsi del fatto che i membri del team scelgano costrutti di programmazione sicuri è positivo, ma una qualche forma di verifica è migliore. Pertanto, le revisioni del codice (code review) sono un buon modo per rilevare gli inevitabili errori di codifica



Esistono molti strumenti automatici per risolvere questo problema. Nonostante il tempo che deve essere investito, le revisioni del codice si sono rivelate molto efficaci. Un'altra pratica che può aiutare è quella di Pair Programming

Applications & Databases

Secure SDLC

Secure Testing

- Penetration Test: Esperti in sicurezza attaccano il nostro sistema prima che possa farlo un attacker.
- Vulnerability Scan: Strumenti per la verifica automatica delle vulnerabilità di un sistema, da quelle relative all'hardening agli attacchi XSS.
- Abuse Test: Test implementati, di norma, prima dello sviluppo del software. Possono essere sviluppati dal team stesso, in quanto a conoscenza di specifiche vulnerabilità non rilevabili da altre tipologie di test .
- Fuzzing: Si studia il comportamento del sistema quando sottoposto ad input generato o modificato in modo casuale. Di norma utilizzati in scenari di elaborazione complessi per cui non è possibile definire test specifici.

I risultati migliori si hanno combinando tutte le tipologie di test elencati alla code review. Purtroppo non sempre è possibile.

Applicazioni: principali problematiche

OWASP Top 10

OWASP (Open Web Application Security Project) è una fondazione senza scopo di lucro fondata nel 2001. Tutto il materiale messo a disposizione sul sito dell'organizzazione è free e Open Source.

Scopo di OWASP è fornire un po' di conoscenza per quanto riguarda la sicurezza, a partire dalle web applications, alle app per dispositivi mobile, IoT.

Esistono vari progetti attivi, tutti consultabili dal sito dell'organizzazione, in ambito di sviluppo, modellazione, test di applicazioni web.

Applicazioni: principali problematiche

OWASP Top 10

I progetti Top 10 di OWASP forniscono informazioni sulle 10 principali problematiche delle applicazioni, suddivise per tipologia.

- OWASP Top Ten (applicazioni web) <https://owasp.org/Top10/>
- Mobile Top Ten <https://owasp.org/www-project-mobile-top-10/>
- Top Ten Client-Side Security Risk <https://owasp.org/www-project-top-10-client-side-security-risks/>
- Top Ten Privacy Risk <https://owasp.org/www-project-top-10-privacy-risks/>
- Top Ten API Security <https://owasp.org/www-project-api-security/>
- Top Ten Serverless <https://owasp.org/www-project-serverless-top-10/>
- Top Ten Docker <https://owasp.org/www-project-docker-top-10/>

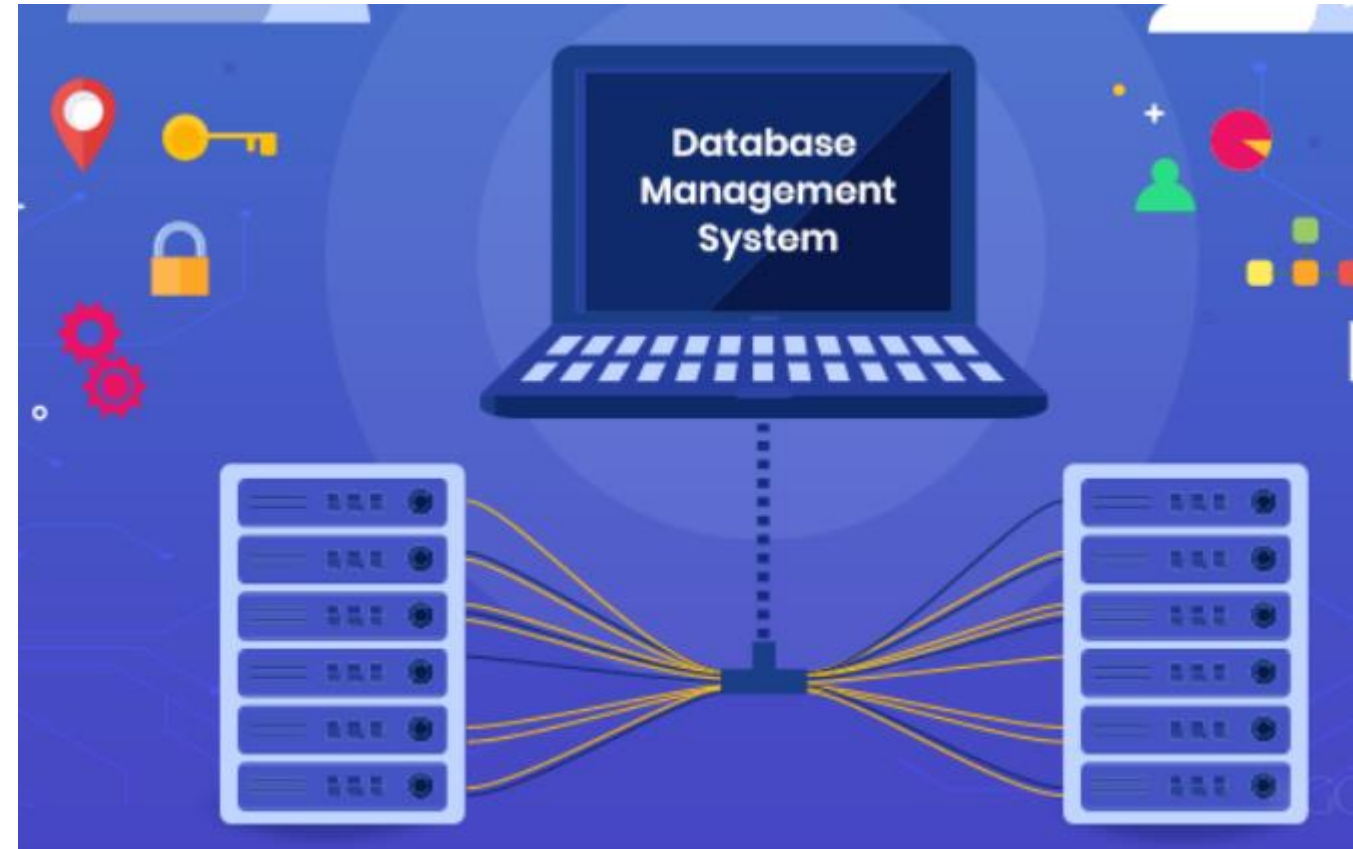
Applications & Databases

Database

Un database è un insieme di informazioni registrate in una memoria di massa

- gestite da un apposito programma (il DBMS)
- strutturate in modo tale da facilitarne la consultazione da parte di uno o più utenti.

Il termine database indica, per estensione, anche il contenitore dove sono raccolte tali informazioni.



Applications & Databases

DBMS

Un termine ampiamente utilizzato che descrive le funzioni e i requisiti per le transazioni del sistema di gestione dei database è **ACID**

A

Atomicity (Atomicità): solo le richieste valide vengono eseguite nell'ordine stabilito, garantendo la correttezza dell'intera transazione.

C

Consistency (Coerenza): le transazioni riuscite devono lasciare un database stabile, che a sua volta richiede una revisione costante di tutte le transazioni.

I

Isolation (Isolamento): le transazioni non si devono ostacolare l'un l'altra, il che è garantito da specifiche funzioni di blocco.

D

Durability (Durabilità): tutti i dati sono memorizzati in modo permanente nel DBMS, anche dopo aver completato una transazione corretta. Questo vale anche o soprattutto in caso di errori di sistema o guasti del DBMS. Per garantire la durabilità sono essenziali ad esempio i registri delle transazioni, che archiviano tutti i processi del DBMS.

Applications & Databases

DBMS

Funzione/requisito	Spiegazione
Archiviazione dei dati	I database archiviano testi, documenti, password e altre informazioni che possono essere richiamati con le query.
Revisione dei dati	La maggior parte dei database consentono, a seconda dei diritti di accesso, di elaborare direttamente le informazioni archiviate.
Cancellazione dei dati	I dati contenuti nei database si possono cancellare completamente. In alcuni casi si riesce a recuperare i dati cancellati, in altri le informazioni sono perse per sempre.
Gestione dei metadati	Le informazioni vengono solitamente archiviate nei database con i metadati e i metatag. In questo modo si ha più ordine all'interno dei database e si rende possibile ad esempio la funzione di ricerca. Anche i diritti di accesso sono spesso regolati attraverso i metadati. La gestione dei dati segue quattro operazioni fondamentali: create, read/retrieve, update e delete. Questo concetto noto come principio CRUD è alla base della gestione dei dati.
Sicurezza dei dati	I database devono essere sicuri, in modo da evitare accessi illegittimi ai dati salvati. Per la sicurezza dei dati sono essenziali sia una gestione attenta, ad opera dell'amministratore responsabile, che un metodo crittografico adeguato. Sicurezza dei dati significa principalmente prendere le dovute precauzioni tecniche per evitare la manipolazione o la perdita di dati. È perciò un concetto base della protezione dei dati .

Applications & Databases

DBMS

Funzione/requisito	Spiegazione
Integrità dei dati	Con integrità dei dati si indica che i dati all'interno di un database contengono regole specifiche, assicurando la correttezza dei dati e definendo la logica aziendale del database. Questo è l'unico modo per garantire che il database nel suo complesso funzioni costantemente in modo coerente. Nei modelli relazionali dei database ci sono quattro regole a riguardo: integrità di settore, integrità dell'entità, integrità referenziale e coerenza logica.
Funzionamento multiutente	Le applicazioni del database consentono l'accesso al database da vari dispositivi. Nel funzionamento multiutente, sono fondamentali la distribuzione dei diritti e la sicurezza dei dati. Una delle sfide per i database multiutente riguarda il mantenere i dati coerenti anche con l'accesso in lettura e scrittura di molti utenti senza compromettere le prestazioni.
L'ottimizzazione delle query	Da un punto di vista tecnico, un database deve essere in grado di elaborare ogni query in modo ottimale al fine di garantire buone prestazioni: se un database necessita "troppa strada" per elaborare una query di dati, ne risentono le prestazioni complessive del sistema di database.
Trigger e stored Procedures	Questi processi sono mini applicazioni salvate all'interno di un sistema di gestione del database, richiamate (triggered) da determinate azioni di modifica. In questo modo tra le altre cose si ottiene un miglioramento dell'integrità dei dati. Per i database relazionali, i trigger di database e le stored procedure sono processi tipici; quest'ultimo può anche contribuire alla sicurezza del sistema se agli utenti è consentito di eseguire azioni utilizzando solo procedure predefinite.
Trasparenza di sistema	La trasparenza di sistema è rilevante soprattutto nei sistemi distribuiti: impedendo la distribuzione e l'implementazione dei dati da parte dell'utente, l'utilizzo del database distribuito è simile a quello di uno centralizzato. Diversi livelli di trasparenza del sistema espongono o offuscano i processi in background. La funzione fondamentale, tuttavia, è semplificare il più possibile l'utilizzo.

Applications & Databases

RDBMS

Il modello di database più popolare al momento è quello **relazionale**.

Il relativo sistema di gestione dei database relazionali è meglio conosciuto sotto l'acronimo RDBMS (relational database management system) e il linguaggio utilizzato è SQL.

Il modello di database relazionale basato su tabelle mette appunto al centro il concetto di "relazione", un concetto matematico ben definito: la formulazione delle relazioni avviene tramite l'algebra relazionale, grazie alla quale si possono ottenere informazioni tramite queste relazioni.

Questo principio è a propria volta alla base del linguaggio SQL del database.

Applications & Databases

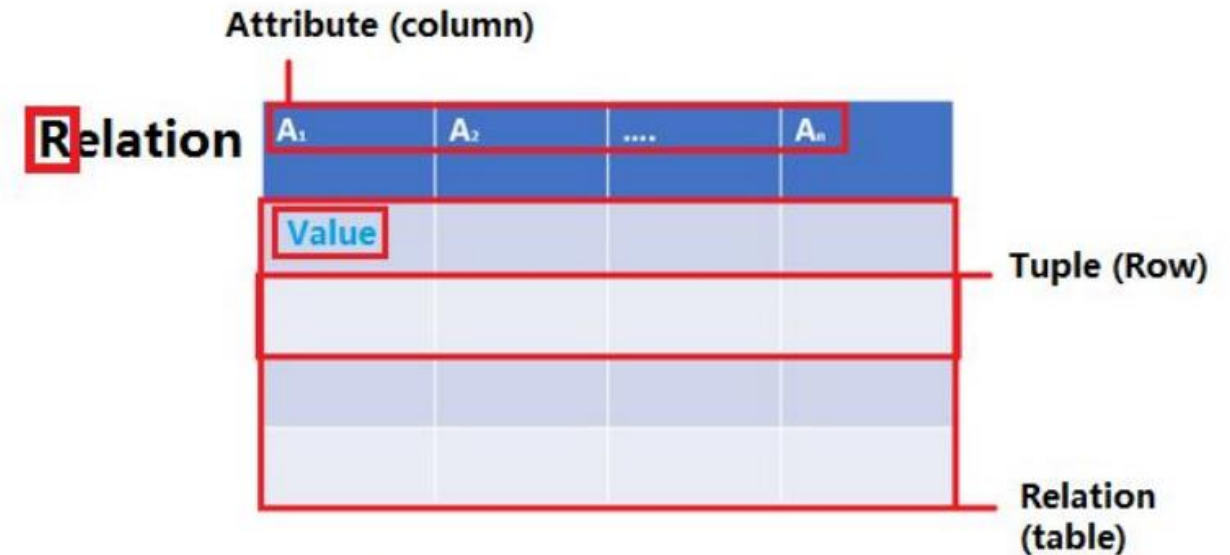
Modello Relazionale

Il modello di database relazionale lavora con singole tabelle che stabiliscono la localizzazione delle informazioni e i suoi collegamenti.

Queste informazioni vanno a formare un record (nell'immagine accanto una riga, row in inglese, o **"tupla"**).

Le singole informazioni vengono raggruppate nelle colonne come attributi (nella figura A1 fino a A_n). La relazione generale ("relation" è una parola spesso utilizzata come sinonimo di "tabella") risulta perciò dagli attributi connessi.

Per la chiara identificazione di un record è necessario la chiave primaria che generalmente è definita dal primo attributo (A1) e che non può mai cambiare. In altre parole la cosiddetta chiave primaria (anche detta "ID") definisce la precisa posizione del record con tutti gli attributi.



Applications & Databases

Modello Relazionale

Vantaggi

Modello di dati semplice: i database relazionali si basano su un modello di dati relativamente semplice da implementare e gestire. Grazie ai modelli di database relazionale risulta facile mappare le numerose informazioni, come i dati dei clienti, le liste di ordini o le movimentazioni dei conti, che le aziende archiviano nel lungo periodo.

Ridotta ridondanza dei dati: il modello di database relazionale utilizza i vari moduli normali per fornire regole ben definite per l'eliminazione della ridondanza. Se i requisiti per la normalizzazione vengono implementati in modo coerente, i sistemi di database relazionali consentono una memorizzazione dei dati quasi priva di ridondanze. Questo facilita soprattutto il mantenimento e la cura delle scorte di dati, poiché le modifiche devono essere effettuate in un unico luogo.

Elevata coerenza dei dati: i database relazionali normalizzati consentono un'archiviazione dei dati senza contraddizioni, contribuendo alla coerenza dei dati. I sistemi di database relazionali forniscono anche funzionalità che definiscono e verificano automaticamente i vincoli di integrità. Le transazioni che mettono a repentaglio la coerenza dei dati vengono escluse.

Elaborazione dei dati orientata alla quantità: il sistema di database relazionale si basa sull'elaborazione dei dati orientata alla quantità, in cui ogni entità è suddivisa in valori atomici. Ciò consente il collegamento di varie entità attraverso il contenuto, nonché query di database complesse come JOIN.

Lingua unificata per le query: per le query sui database relazionali è stato stabilito un SQL standardizzato per la lingua del database attraverso gli organi di ISO e IEC; il fine di questa standardizzazione è di consentire lo sviluppo e l'esecuzione delle applicazioni indipendentemente dal sistema di gestione del database sottostante. Tuttavia fino ad ora il supporto di SQL varia a seconda del DBMS.

Applications & Databases

Modello Relazionale

Svantaggi

Mappatura tabellare dei dati: non tutti i tipi di dati possono essere espressi in uno schema rigido di tabelle bidimensionali interconnessi (Impedance Mismatch). I tipi di dati astratti e i dati non strutturati associati alle applicazioni multimediali e alle soluzioni big data non possono essere mappati nel modello di database relazionale.

Mancanza di uno schema di database gerarchico: i database relazionali, a differenza dei database di oggetti, non offrono la possibilità di implementare schemi di database con classi strutturate gerarchicamente. Concetti come quelli delle “entità figlio” che ereditano le proprietà dalle “entità padre” non possono essere utilizzati..

Segmentazione dei dati: il principio di base dei sistemi di database relazionali, che consiste nella suddivisione delle informazioni su tabelle separate (normalizzazione), porta necessariamente ad una segmentazione dei dati: i dati correlati non sono necessariamente memorizzati insieme. Questo genera query complesse su più tabelle a livello di applicazione. Il conseguente maggior numero di segmenti interrogati di solito ha anche un impatto negativo sulle prestazioni.

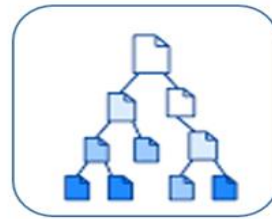
Performance peggiori rispetto ai database NoSQL: il modello di database relazionale ha requisiti molto rigidi in termini di coerenza dei dati che nelle transazioni vanno a discapito della velocità di scrittura.

Applications & Databases

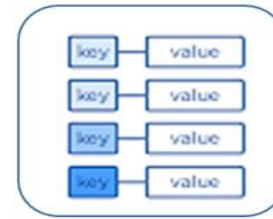
Database NoSQL

È l'acronimo di un database non-SQL. Il database NoSQL non utilizza la tabella per archiviare i dati come il database relazionale. Viene utilizzato per archiviare e recuperare i dati non strutturati nel database e generalmente per memorizzare una grande quantità di dati, ma di norma non garantisce ACID. Supporta un proprio linguaggio di query e fornisce prestazioni migliori su mole di dati elevata.

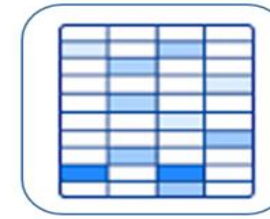
Tecniche di memorizzazione dei dati
Nei database NoSQL



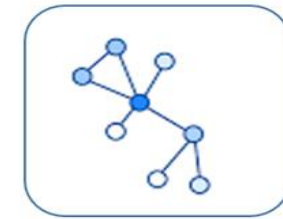
Document
Store



Key-Value
Store



Wide-Column
Store



Graph
Store

I database NoSQL aiutano i professionisti IT e gli sviluppatori a gestire le nuove sfide della diversità in continua espansione di tipi e modelli di dati e sono estremamente efficaci nella gestione di dati imprevedibili, spesso con velocità di query incredibilmente elevate. Forniscono inoltre una migrazione fluida del database al cloud per i carichi di lavoro NoSQL esistenti.

Database NoSQL

Database relazionale e database NoSQL a confronto

Database relazionale	NoSQL
Viene utilizzato per gestire i dati che arrivano a bassa velocità.	Viene utilizzato per gestire i dati che arrivano ad alta velocità.
Fornisce solo scalabilità in lettura.	Fornisce scalabilità sia in lettura che in scrittura.
Gestisce i dati strutturati.	Gestisce tutti i tipi di dati.
I dati arrivano da una o poche posizioni.	I dati arrivano da molte località.
Supporta transazioni complesse.	Supporta transazioni semplici.
Ha un unico punto di errore.	Nessun singolo punto di errore.
Gestisce i dati in meno volume.	Gestisce i dati ad alto volume.
Transazioni scritte in un'unica posizione.	Transazioni scritte in molte località.
Distribuito in modo verticale.	Distribuito in modo orizzontale.

Il linguaggio SQL

Structured Query Language

- Linguaggio utilizzato per interagire con un database
- Linguaggio standard utilizzato dai RDBMS (Relation Database Management System)
- Permette la definizione delle strutture dati
- Permette l'interrogazione e la manipolazione dei dati
- Sebbene sia uno standard molti RDBMS implementano le proprie estensioni di linguaggio

Applications & Databases

Il linguaggio SQL

Categorie dei comandi

DDL – Data Definition Language. Serve a gestire la struttura degli elementi del database

- CREATE: crea elementi del database (tabelle, viste)
- DROP: elimina elementi dal database
- ALTER: modifica elementi del database

DQL – Data Query Language. Serve ad interrogare gli elementi nel database

- SELECT: specifica quali dati recuperare e da quali tabelle e/o viste

DML – Data Manipulation Language. Serve a manipolare (creare,aggiornare,eliminare) i dati all'interno delle tabelle del database

- INSERT: aggiunge una tupla in una tabella
- UPDATE: aggiorna i dati di una tupla o più tuple di una tabella
- DELETE: elimina una o più tuple da una tabella

Il linguaggio SQL

Categorie dei comandi

DCL – Data Control Language. Comandi che permettono la gestione di diritti, permessi e altri controlli del sistema di database

- GRANT: definisce privilegi su utenti/gruppi del database
- REVOKE: revoca i privilegi forniti con GRANT

TCL – Transaction Control Language. Si occupa della gestione di una transazione all'interno del database.

Una transazione è un insieme di operazioni eseguite in modo solitamente sequenziale che permette l'annullamento di tutte le modifiche effettuate nel momento in cui una delle operazione va in errore.

- COMMIT: conclude la transazione
- ROLLBACK: annulla tutte le operazioni effettuate dall'inizio della transazione
- SET TRANSACTION: specifica alcune caratteristiche della transazione
- SAVEPOINT: imposta un punto di salvataggio all'interno della transazione

Data dictionary

Dizionario dati e metadati

Un dizionario di dati contiene metadati, ovvero dati sul database.

Contiene informazioni come cosa c'è nel database, chi può accedervi, dove si trova fisicamente il database ecc.

Gli utenti del database normalmente non interagiscono con il dizionario dei dati, è gestito solo dagli amministratori del database.

Il dizionario dei dati in generale contiene informazioni su

- Nomi di tutte le tabelle del database e dei relativi schemi.
- Dettagli su tutte le tabelle nel database, come i loro proprietari, i loro vincoli di sicurezza, quando sono state create, ecc.
- Informazioni fisiche sulle tabelle (dove e come sono archiviate).
- Vincoli di tabella (attributi della chiave primaria, informazioni sulla chiave esterna, ecc.)
- Informazioni sulle viste del database visibili.

Applications & Databases

Data dictionary

Active Data Dictionary

La struttura del database o le sue specifiche cambiano in qualsiasi momento e l'aggiornamento del dizionario di dati è responsabilità del DBMS.

Il dizionario dei dati viene aggiornato automaticamente dal sistema di gestione del database quando vengono apportate modifiche al database.

Passive Data Dictionary

Un dizionario dati passivo viene mantenuto separatamente dal database i cui contenuti sono archiviati nel dizionario. Ciò significa che se il database viene modificato, il dizionario del database non viene aggiornato automaticamente come nel caso di Active Data Dictionary ma deve essere aggiornato manualmente in modo che corrisponda al database.

Ciò richiede un'attenta gestione, altrimenti il database e il dizionario dei dati non sono sincronizzati.

Applications & Databases

Data warehouse & data mining

Data warehouse

Il data warehousing è una raccolta di strumenti e tecniche che consentono di estrarre più conoscenze da una grande quantità di dati. Questo aiuta con il processo decisionale e migliorando le risorse informative. Il data warehouse è fondamentalmente un database di strutture dati uniche che consente l'esecuzione relativamente rapida e semplice di query complesse su una grande quantità di dati. È creato da più fonti eterogenee.

Data mining

Il data mining si riferisce all'estrazione di conoscenza da grandi quantità di dati. Le origini dati possono includere database, data warehouse, web ecc. Gli scopi sono principalmente due:

- Previsione automatizzata di tendenze e comportamenti: il data mining automatizza il processo di ricerca delle informazioni predittive in database di grandi dimensioni.
- Scoperta automatizzata di pattern precedentemente sconosciuti: il data mining esplora il database e identifica i pattern precedentemente nascosti. Ad esempio: in un negozio al dettaglio il data mining analizzerà l'intero database e troverà il modello per gli articoli che di solito vengono comprati insieme.

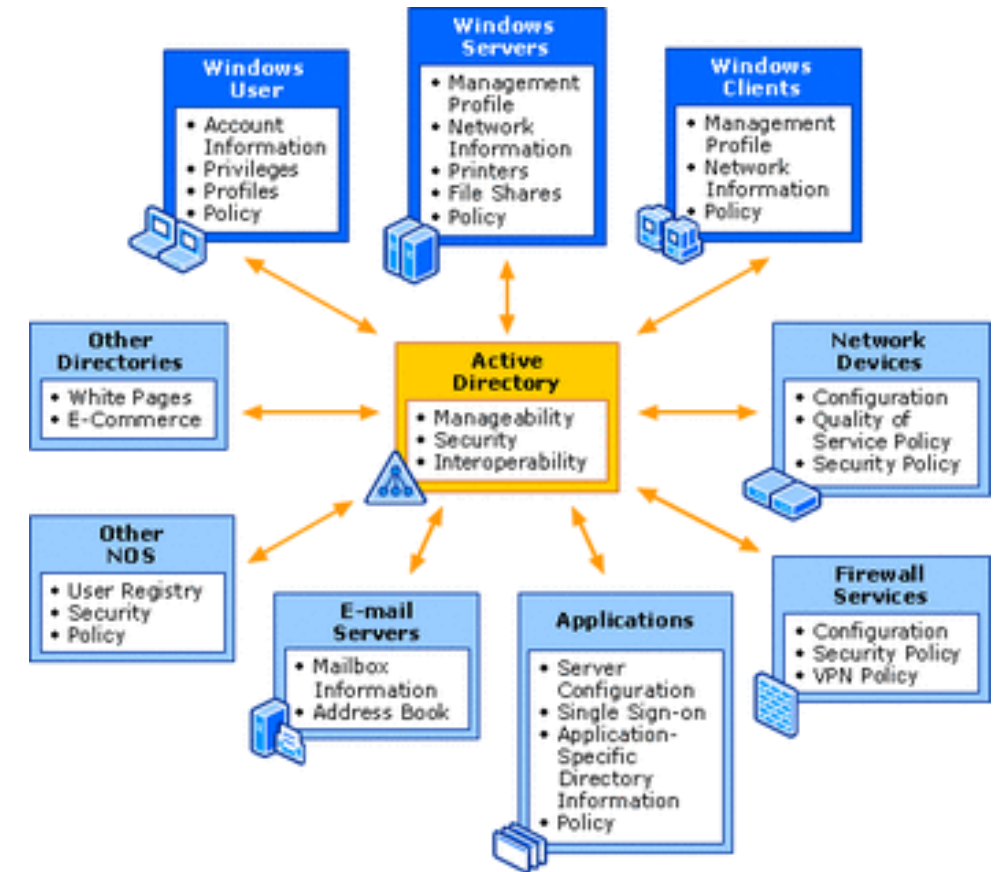
Applications & Databases

Servizi Directory

Un servizio di directory o un servizio di nomi associa i nomi delle risorse di rete ai rispettivi indirizzi di rete. Si tratta di un'infrastruttura informativa condivisa per individuare, gestire, amministrare e organizzare gli oggetti quotidiani e le risorse di rete, che possono includere volumi, cartelle, file, stampanti, utenti, gruppi, dispositivi, numeri di telefono e altri oggetti.

Un servizio di directory è un componente critico di un sistema operativo di rete. Un *directory server* o *name server* è un server che fornisce tale servizio.

Ogni risorsa sulla rete è considerata un oggetto dal server di directory. Le informazioni su una particolare risorsa vengono archiviate come una raccolta di attributi associati a quella risorsa o oggetto.



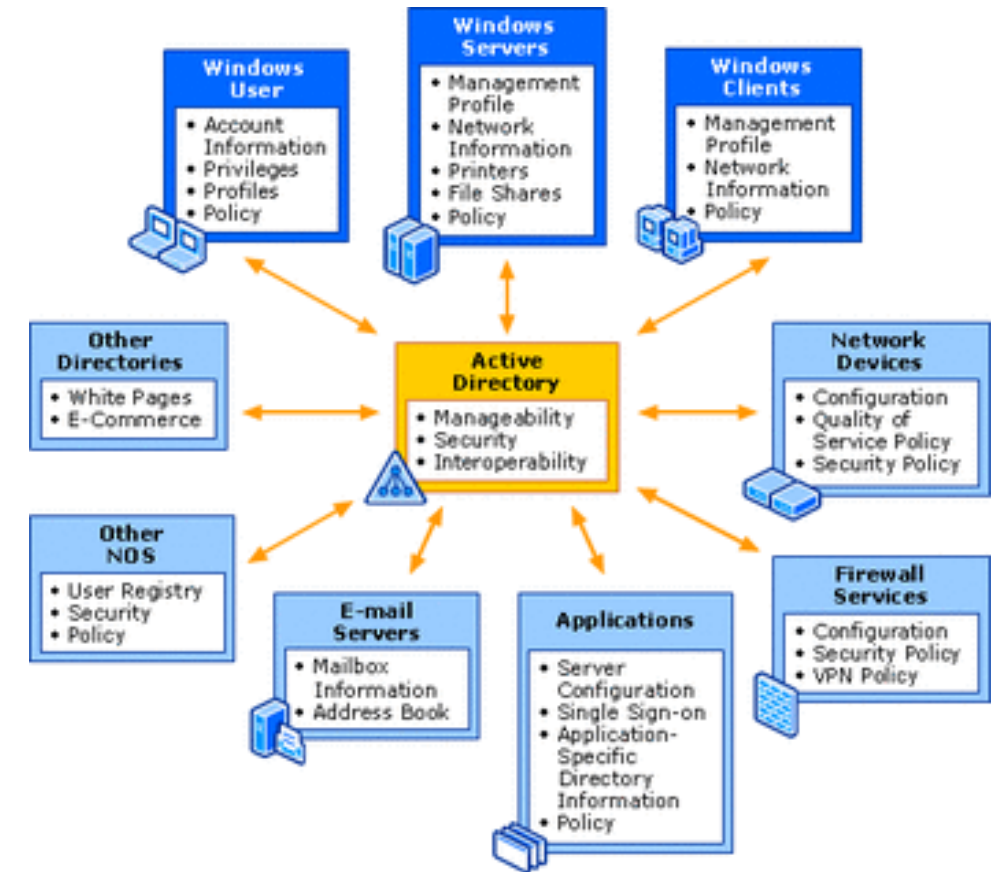
Applications & Databases

Servizi Directory

Un servizio di directory o un servizio di nomi associa i nomi delle risorse di rete ai rispettivi indirizzi di rete. Si tratta di un'infrastruttura informativa condivisa per individuare, gestire, amministrare e organizzare gli oggetti quotidiani e le risorse di rete, che possono includere volumi, cartelle, file, stampanti, utenti, gruppi, dispositivi, numeri di telefono e altri oggetti.

Un servizio di directory è un componente critico di un sistema operativo di rete. Un *directory server* o *name server* è un server che fornisce tale servizio.

Ogni risorsa sulla rete è considerata un oggetto dal server di directory. Le informazioni su una particolare risorsa vengono archiviate come una raccolta di attributi associati a quella risorsa o oggetto.



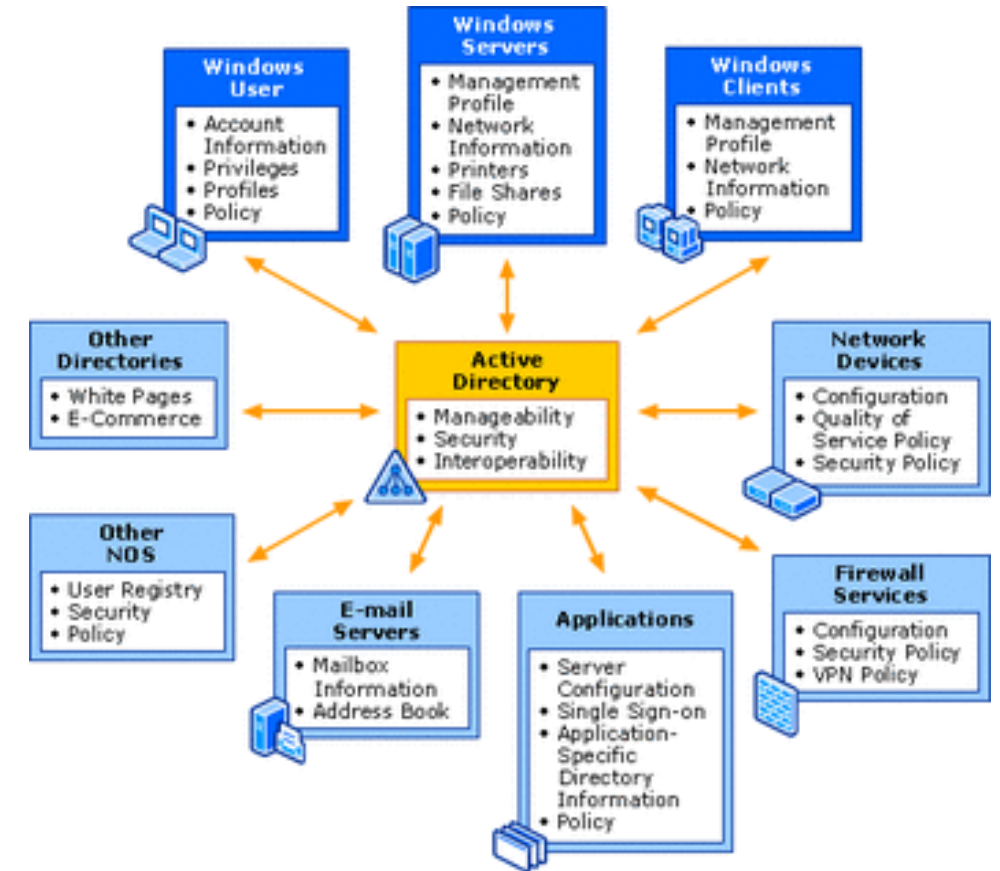
Applications & Databases

Servizi Directory

Un servizio di directory definisce uno spazio dei nomi per la rete. Lo spazio dei nomi viene utilizzato per assegnare un nome (identificatore univoco) a ciascuno degli oggetti.

Le directory in genere hanno una serie di regole che determinano il modo in cui le risorse di rete vengono denominate e identificate, che di solito include il requisito che gli identificatori siano univoci e non ambigui. Quando si utilizza un servizio di directory, un utente non deve ricordare l'indirizzo fisico di una risorsa di rete; fornendo un nome individua la risorsa

Alcuni servizi di directory includono disposizioni per il **controllo dell'accesso**, che limitano la disponibilità delle informazioni di directory agli utenti autorizzati.



X.500 e LDAP

X.500 è una serie di protocolli che definiscono l'utilizzo dei servizi di directory sviluppato dal Telecommunication Standardization Sector of the International Telecommunications Union (ITU-T) . Alcuni protocolli inclusi sono:

- Directory Access Protocol (DAP)
- Directory System Protocol (DSP)
- Directory Information Shadowing Protocol (DISP)
- Directory Operational Bindings Management Protocol (DOP)
- Certificate Authority Subscription Protocol (CASP)
- Authorization Validation Management Protocol (AVMP)
- Trust Broker Protocol (TBP)

Il **Lightweight Directory Access Protocol (LDAP)** si basa sui servizi di informazioni sulla directory X.500, utilizzando lo stack TCP/IP e uno schema di codifica delle stringhe DAP (Directory Access Protocol) X.500 su Internet.

X.500 e LDAP

X.500 è una serie di protocolli che definiscono l'utilizzo dei servizi di directory sviluppato dal Telecommunication Standardization Sector of the International Telecommunications Union (ITU-T) . Alcuni protocolli inclusi sono:

- Directory Access Protocol (DAP)
- Directory System Protocol (DSP)
- Directory Information Shadowing Protocol (DISP)
- Directory Operational Bindings Management Protocol (DOP)
- Certificate Authority Subscription Protocol (CASP)
- Authorization Validation Management Protocol (AVMP)
- Trust Broker Protocol (TBP)

Il **Lightweight Directory Access Protocol (LDAP)** si basa sui servizi di informazioni sulla directory X.500, utilizzando lo stack TCP/IP e uno schema di codifica delle stringhe DAP (Directory Access Protocol) X.500 su Internet.

Applications & Databases

Database: problematiche di sicurezza

- **Aggregazione e inferenza:** l'aggregazione può verificarsi quando un utente non dispone dell'autorizzazione o dei privilegi per accedere all'insieme di informazioni completo, ma dispone *dell'autorizzazione o dei privilegi per alcuni elementi dell'insieme di informazioni*. L'inferenza è quando un soggetto *deduce l'insieme di informazioni completo (o storia) dai componenti dell'insieme di informazioni*. È un risultato di aggregazione
- **Bypass attack:** utenti accedono alle informazioni bypassando i controlli nel front-end del database.
- **Compromissione delle viste del database:** una vista del database viene compromessa quando un utente ottiene l'accesso a viste limitate o modifica una vista esistente. Poiché tutti gli oggetti devono avere un'etichetta di sicurezza che identifichi la sensibilità nel database, il software utilizzato per classificare le informazioni deve anche disporre di un meccanismo per verificare la sensibilità delle informazioni. Le viste limitano i dati che gli utenti vedono, non limitano le operazioni che possono essere eseguite sulle viste.
- **Concorrenza:** la concorrenza consente a più utenti di accedere ai dati tutti contemporaneamente. Questo comporta problemi di integrità qualora non siano presenti meccanismi di sincronizzazione in fase di scrittura dei dati

Database: problematiche di sicurezza

- **Contaminazione dei dati:** si riferisce allo stato dei dati in cui è stata violata l'integrità. La contaminazione dei dati può verificarsi a causa di errori di immissione dei dati, aggiornamenti incoerenti, elaborazione errata, perdita di dati o quando un utente malintenzionato modifica i dati.
- **Deadlocking:** si verifica quando più utenti tentano di accedere alle stesse informazioni contemporaneamente
- **DoS attack:** si riferisce a qualsiasi atto o evento che potrebbe impedire agli utenti di accedere alle proprie informazioni.
- **Intercettazione dei dati:** avviene quando i dati trasmessi vengono ricevuti o alterati da un utente non autorizzato.
- **Query attacks:** si verificano quando gli strumenti di query vengono utilizzati per accedere a dati che normalmente non sono consentiti dal front-end attendibile.
- **Server access:** accesso al server di database con conseguente accesso non autorizzato alle informazioni in esso contenute

Database: contromisure

- Controlli mirati alla mitigazione della contaminazione dei dati in base a procedure di analisi e validazione dell'input e dell' output
- OLTP (Online Transaction Processing): la caratteristica distintiva delle transazioni OLTP è l'atomicità e la concorrenza. La concorrenza impedisce a più utenti di modificare gli stessi dati contemporaneamente. L'atomicità (o indivisibilità) garantisce che tutti i passaggi transazionali siano completati affinché la transazione abbia esito positivo. Se un passaggio non riesce o è incompleto, l'intera transazione non riesce.
- Metadata controls: controlli sui metadata del database
- View-based access controls: meccanismo di gestione degli accessi agli oggetti del database basati su viste utente. Il sistema di database crea una vista per ogni utente che limita i dati che esso è in grado di vedere. Anche se potrebbero esserci più dati nel database, l'utente può accedere solo ai dati definiti nella vista.
- Grant and revoke access controls: verificare i permessi/privilegi associati agli utenti in modo da limitare l'accesso o le operazioni eseguibili sugli elementi del database, revocandoli se necessario.

Database: contromisure

- Misdirection: fornire informazioni errate sulla sicurezza del database
- Stored procedures: query parametrizzate che mitigano gli attacchi si SQL-Injection
- Auditing & monitoring: monitorare sia il server ospitante che il database per individuare eventuali attività malevoli. Audit delle transazioni del database e esame dei log per individuare attività dannose.
- Installazione di software anti-virus, firewall, IDS/IPS sul server del database
- Installazione delle patch di sicurezza il più presto possibile

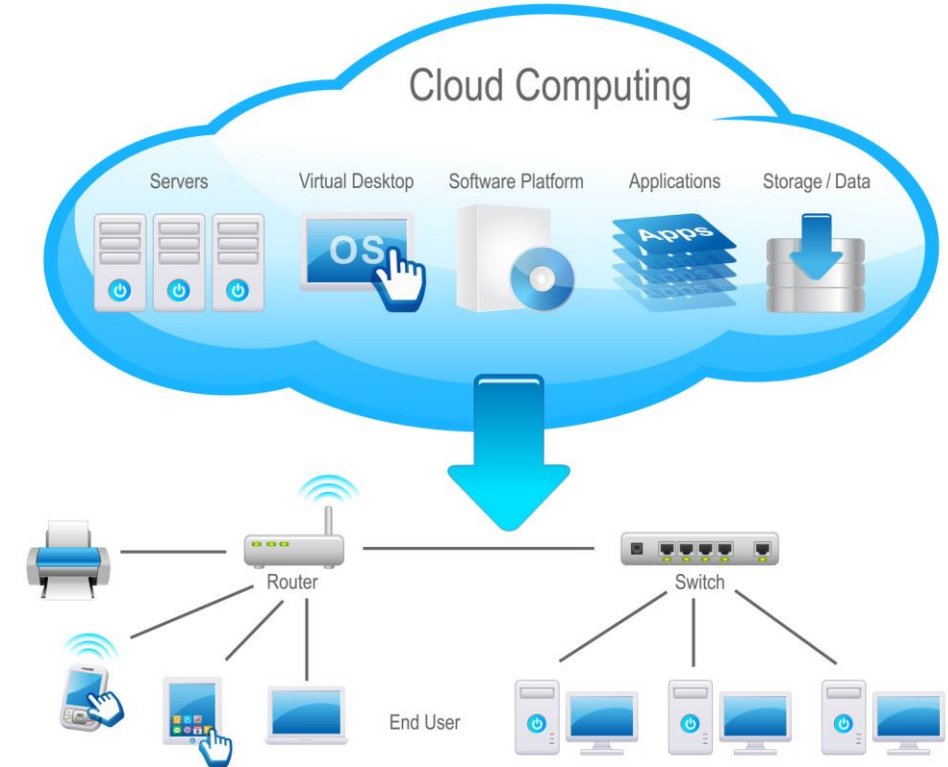
Cloud Computing

Cloud Computing

La definizione del **NIST** di cloud computing è:

«Il cloud computing è un modello per abilitare, tramite la rete, l'accesso diffuso, agevole e a richiesta, ad un insieme condiviso e configurabile di risorse di elaborazione (ad esempio reti, server, memoria, applicazioni e servizi) che possono essere acquisite e rilasciate rapidamente e con minimo sforzo di gestione o di interazione con il fornitore di servizi»

In poche parole, il cloud computing permette di avere a disposizione risorse di elaborazione con possibilità di estenderle o ridurle a seconda delle necessità, con relativa facilità e (quasi) senza assistenza del fornitore di servizi.



Cloud Computing

Le 5 caratteristiche

	Caratteristiche	Descrizione	Parametro
1	Ampio accesso alla rete	Disponi del servizio ovunque	Dove
2	On-demand self-service	Disponi del servizio quando vuoi	Quando
3	Pool delle risorse e virtualizzazione	Pool di infrastrutture, piattaforme virtuali e applicazioni	Come
4	Rapida Elasticità	Pool di risorse condivise per abilitare la scalabilità orizzontale	Come
5	Servizio Misurato	Pagare il servizio in base a quanto lo si usa	Quanto

Cloud Computing

Pro e contro

PRO

Automazione	Mobilità
Accesso anticipato	Scalabilità
Flessibilità	Velocità
Concentrarsi sul core business	Time-to-market
Bassi costi	Green

CONS

Acquisti così com'è	Sforzo di migrazione
Conformità	Privacy
Dipende da Internet	Sicurezza
Integrazione	Accordi sul livello di servizio
Ubicazione dei dati	Blocco del fornitore

Modelli di servizio

Software come Servizio (SaaS da Software as a Service)

La facoltà fornita al consumatore è quella di utilizzare le applicazioni del fornitore funzionanti su un'infrastruttura cloud.

Le applicazioni sono accessibili da diversi dispositivi attraverso un'interfaccia leggera (thin client), come ad esempio un'applicazione email su browser, oppure da programmi dotati di apposita interfaccia.

Il consumatore non gestisce o controlla l'infrastruttura cloud sottostante, compresi rete, server, sistemi operativi, memoria, e nemmeno le capacità delle singole applicazioni, con la possibile eccezione di limitate configurazioni a lui destinate (parametrizzazione).

Esempi tipici di soluzioni SaaS

- CRM
- HR
- ERP
- Fatturazione Elettronica
- Web Hosting
- E-commerce
- Collaborazione online
- ...

Modelli di servizio

Piattaforma come Servizio (PaaS da Platform as a Service)

La facoltà fornita al consumatore è quella di distribuire sull'infrastruttura cloud applicazioni create in proprio oppure acquisite da terzi, utilizzando linguaggi di programmazione, librerie, servizi e strumenti supportati dal fornitore.

Il consumatore non gestisce né controlla l'infrastruttura cloud sottostante, compresi rete, server, sistemi operativi, memoria, ma ha il controllo sulle applicazioni ed eventualmente sulle configurazioni dell'ambiente che le ospita.

L'utilizzo "su richiesta" di una piattaforma informatica può far risparmiare sui costi di proprietà, gestione e manutenzione.

Esempi tipici di soluzioni PaaS

- AWS Elastic Beanstalk
- Windows Azure
- Heroku
- Force.com
- Google App Engine
- Apache Stratos
- Openshift
- ...

Modelli di servizio

Infrastruttura come Servizio (IaaS da Infrastructure as a Service)

La facoltà fornita al consumatore è quella di acquisire elaborazione, memoria, rete e altre risorse fondamentali di calcolo, inclusi sistemi operativi e applicazioni.

Il consumatore non gestisce né controlla l'infrastruttura cloud sottostante, ma controlla sistemi operativi, memoria, applicazioni ed eventualmente, in modo limitato, alcuni componenti di rete (esempio firewall)

Esempi tipici di soluzioni IaaS

- DigitalOcean
- Linode
- Rackspace
- Amazon Web Service (AWS)
- Cisco Metapod
- Microsoft Azure
- Google Compute Engine (GCE)
- ...

Cloud Computing

Altri modelli di servizio

Esempi:

Storage as a service (SaaS)

Desktop as a Service (DaaS)

Disaster Recovery as a Service (DRaaS)

Network as a Service (NaaS)

Identity as a Service (IDaaS)

Servizi emergenti:

Marketing as a Service

Healthcare as a Service

Tecnologie emergenti come:

Quantum Computing as a Service (QCaaS)

Artificial Intelligence as a Service (AIaaS)

Blockchain as a Service (BaaS)

Cloud Computing

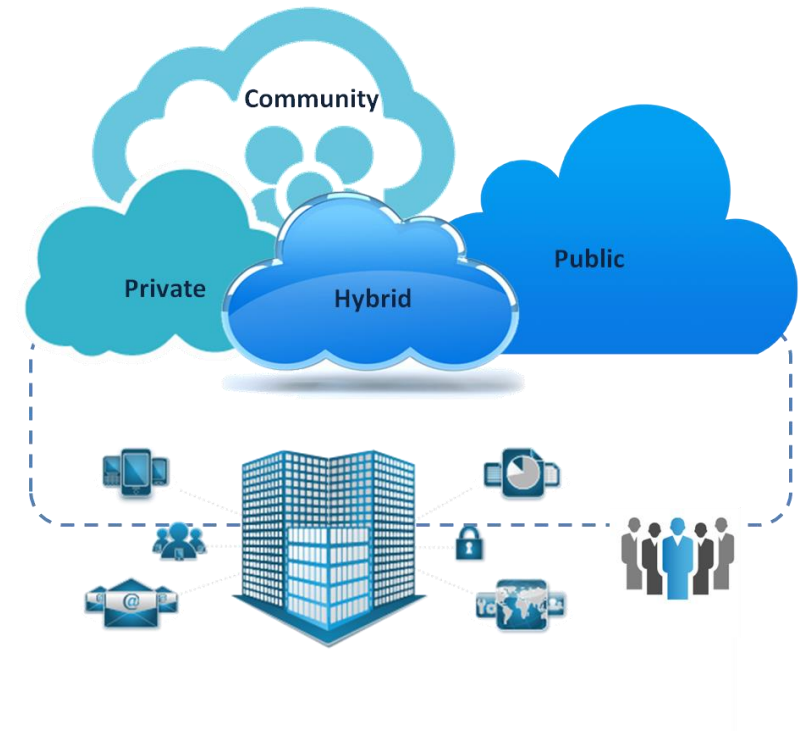
Modelli di distribuzione

Public cloud

L'infrastruttura cloud è fornita per un uso aperto a qualsiasi consumatore.

Può essere posseduta, diretta e gestita da un'azienda, da un'organizzazione accademica o governativa oppure da una combinazione delle precedenti. Esiste dentro le sedi del fornitore cloud.

- Fornitura di servizi «off-site» su Internet
- Condivisione delle risorse
 - Multi-tenancy significa un livello inferiore di sicurezza e privacy
- Rivolto a un vasto pubblico
- Servizi interessanti come e-mail e social media
- Abilita il social networking e la collaborazione



Cloud Computing

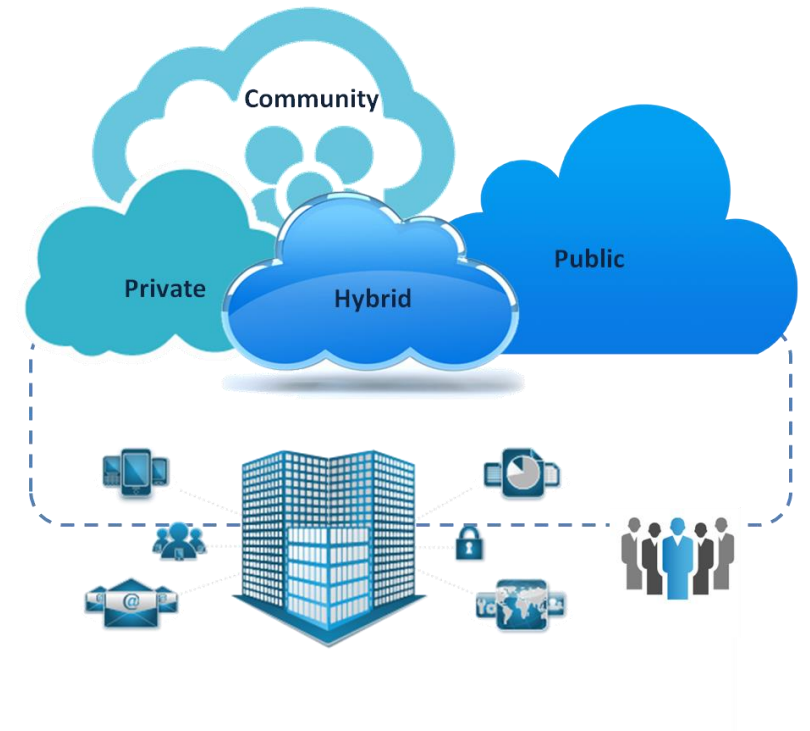
Modelli di distribuzione

Private cloud

L'infrastruttura cloud è fornita per uso esclusivo da parte di una singola organizzazione comprendente molteplici consumatori (ad esempio filiali).

Può essere posseduta, diretta e gestita dall'organizzazione stessa, da un società terza o da una combinazione delle due, e può esistere dentro o fuori le proprie sedi.

- Risiede su una rete privata che gira su (è parte di) un data center utilizzato esclusivamente da un'organizzazione
- Di proprietà, gestito dall'organizzazione stessa, da una terza parte o da una combinazione dei due
- Supporta gli obiettivi di business dell'organizzazione in modo economico
- Elevata sicurezza (conformità a leggi e regolamenti)



Cloud Computing

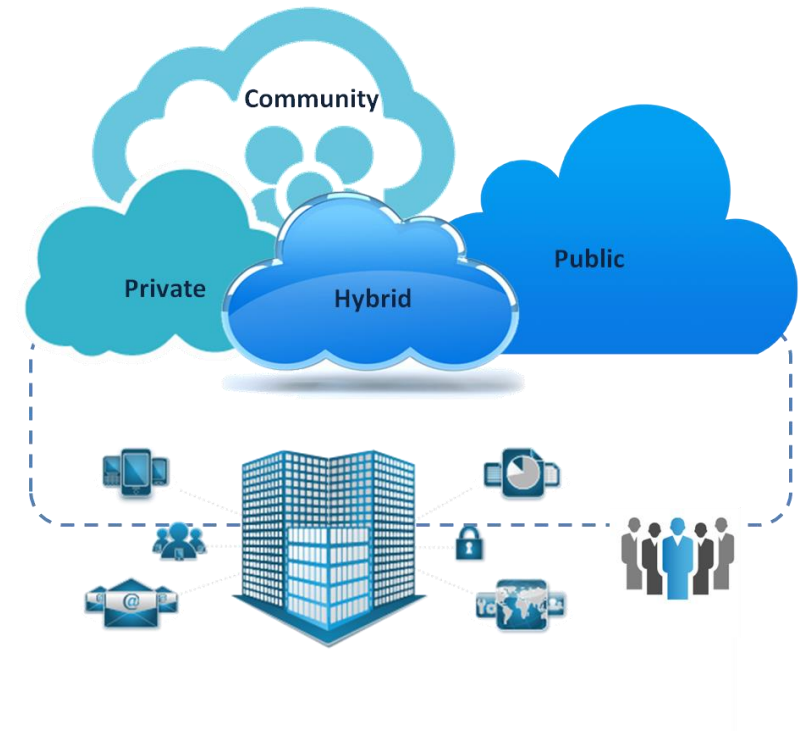
Modelli di distribuzione

Community cloud

L'infrastruttura cloud è fornita per uso esclusivo da parte di una comunità di consumatori di organizzazioni con interessi comuni (ad esempio missione, requisiti di sicurezza, vincoli di condotta e di conformità).

Può essere posseduta, diretta e gestita da una o più delle organizzazioni della comunità, da una società terza o una combinazione delle due e può esistere dentro o fuori le proprie sedi.

- Un tipo di cloud privato condiviso
- Fornisce servizi a un gruppo specifico di organizzazioni e/o individui che condividono un obiettivo comune
- Condivisione di dati, piattaforme e applicazioni
- Condivisione delle spese in conto capitale per strutture altrimenti (troppo) costose
- Accesso e supporto 24 ore su 24, 7 giorni su 7
- Contratti di assistenza e supporto condivisi
- Economia di scala



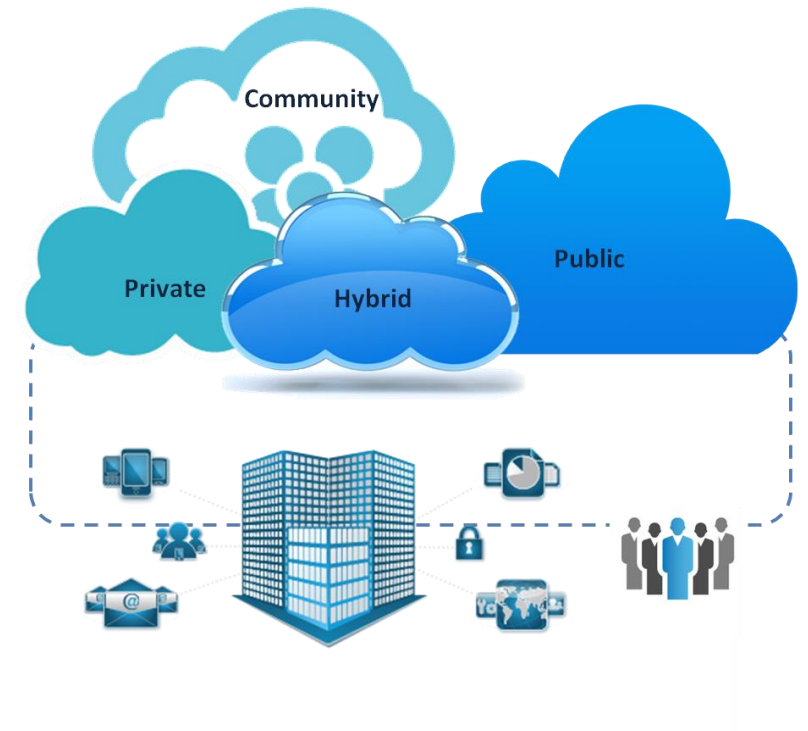
Cloud Computing

Modelli di distribuzione

Hybrid cloud

L'infrastruttura è una composizione di due o più infrastrutture cloud (privata, comunitaria o pubblica) che rimangono entità distinte, ma unite attraverso tecnologie standard o proprietarie, che abilitano la portabilità di dati e applicazioni (ad esempio per bilanciare il carico di lavoro tra cloud).

- Un mix degli altri modelli
- Combinazione di diverse soluzioni cloud private e pubbliche di diversi fornitori in un'unica infrastruttura IT (virtuale)
- La scelta di servizi specifici per l'idoneità del cloud privato o pubblico è bilanciare:
 - ✓ Sicurezza
 - ✓ Privacy
 - ✓ Conformità contro prezzo



Cloud Computing

Problemi di sicurezza

A differenza di un data center tradizionale, la gestione dei servizi informatici basati su cloud implica la condivisione della responsabilità di mitigare eventuali rischi e minacce con il provider di servizi cloud. Questo ulteriore livello di complessità presenta alcuni problemi e sfide di sicurezza unici che sono specifici dell'ambiente cloud.

Shared Responsibility Model for Security in the Cloud			
On-Premises (for reference)	IaaS (infrastructure-as-a-service)	PaaS (platform-as-a-service)	SaaS (software-as-a-service)
User Access	User Access	User Access	User Access
Data	Data	Data	Data
Applications	Applications	Applications	Applications
Operating System	Operating System	Operating System	Operating System
Network Traffic	Network Traffic	Network Traffic	Network Traffic
Hypervisor	Hypervisor	Hypervisor	Hypervisor
Infrastructure	Infrastructure	Infrastructure	Infrastructure
Physical	Physical	Physical	Physical

Customer Responsibility

Cloud Provider Responsibility

Cloud Computing

Problemi di sicurezza

Accesso non autorizzato

La capacità di fornire funzionalità su richiesta tramite funzionalità self-service offre una maggiore efficienza per l'implementazione di prodotti PaaS e SaaS.

Tuttavia, aumenta anche la probabilità di utilizzo non autorizzato.

Le organizzazioni sono particolarmente esposte quando i servizi e le funzionalità vengono forniti o utilizzati all'insaputa dell'IT (shadow IT).

I dipendenti in grado di accedere ai dati ospitati in remoto da dispositivi informatici remoti come tablet, laptop e cellulari, potrebbero introdurre minacce alla sicurezza esterne, presentando problemi di sicurezza del cloud computing e sfide per le aziende, in particolare quando è coinvolta la negligenza dei dipendenti e l'uso improprio delle credenziali.

Cloud Computing

Problemi di sicurezza

Visibilità e controllo ridotti

Durante la migrazione a un modello di elaborazione basato su cloud, le organizzazioni perderanno un certo grado di visibilità e controllo, con una parte della responsabilità per le policy e l'infrastruttura che passerà al provider cloud.

L'entità effettiva dei cambiamenti di responsabilità sarà determinata dai modelli di servizio cloud utilizzati, SaaS vs PaaS vs IaaS, e la mancanza di visibilità e controllo può creare numerosi problemi di sicurezza del cloud computing e sfide per le organizzazioni.

L'accesso non autorizzato, la replica dei dati e la gestione impropria possono causare problemi di protezione dei dati nel cloud, riducendo l'efficacia dei metodi di controllo della sicurezza.

L'implementazione di piani di risposta agli incidenti per analizzare i dati e identificare attività insolite degli utenti può aiutare ad alleviare tali rischi.

La mancanza di visibilità è il problema più comune di sicurezza del cloud che le organizzazioni devono affrontare.

Cloud Computing

Problemi di sicurezza

API e interfacce non sicure

Le API sono essenziali per un'esperienza cloud personalizzata, ma allo stesso tempo rappresentano una minaccia per la sicurezza. Le API consentono alle aziende di personalizzare le funzionalità della soluzione cloud in base alle proprie esigenze. Inoltre, offrono crittografia, accesso e riconoscimento dei dati.

Le interfacce mal progettate tendono ad essere sfruttabili e portano a violazioni della riservatezza dei dati. Sebbene le API siano utili per gli sviluppatori, allo stesso tempo, se non esaminate per design e sicurezza scadenti, possono causare anche rischi per la sicurezza. Tuttavia, il corretto monitoraggio dell'attività tramite la gestione degli accessi potrebbe aiutare a rilevare eventuali API e interfacce non protette.

Cloud Computing

Problemi di sicurezza

Vulnerabilità del sistema

Le reti di infrastrutture cloud sono complesse e supportate da terze parti, e quindi più soggette a vulnerabilità del sistema.

I bug sfruttabili spesso rendono i sistemi vulnerabili, consentendo così agli hacker di sfruttare le debolezze e violare le informazioni riservate.

Le vulnerabilità del sistema presentano diversi problemi e sfide di sicurezza del cloud computing, come sistemi operativi non sicuri e memoria e risorse condivise.

Cloud Computing

Problemi di sicurezza

Violazioni, perdita o fuga di dati

Una risorsa significativa e la chiave per la collaborazione nel cloud è la facilità di condivisione dei dati nel cloud. Tuttavia, ciò crea anche seri problemi relativi a violazioni, perdite o fughe di dati.

Il Cloud semplifica la condivisione dei dati archiviati al loro interno. Tuttavia, quando i tuoi dati sono accessibili online, c'è sempre il rischio di una violazione dei dati. I sistemi basati su cloud consentono di condividere facilmente i dati, tramite inviti e-mail diretti o condividendo un collegamento pubblico, con altre parti.

Gli strumenti sono prontamente disponibili per cercare in Internet eventuali implementazioni cloud non protette, che rappresentano un rischio per tali dati.

Altri problemi di sicurezza

- Ottenere la garanzia dai fornitori di servizi cloud può essere complicato
- La giurisdizione può essere poco chiara o incerta
- Crittografia scarsa dei dati "in transito" e dei dati «a riposo»
- Capacità limitata di definire controlli e funzioni di sicurezza specifici
- Distribuzioni multi-tenant (più organizzazioni client)
- Archiviazione e archiviazione dei dati
- API specifiche
- Vendor lock-in o customer lock-in